

Daily Vulnerability Report - 2026-09-08

Window (UTC): 2026-09-08T00:00 to 2026-09-09T00:00 | Sources: NVD, CISA KEV, FIRST EPSS | Generated 2026-09-17 05:51:41 UTC

Total	KEV (exploited)	Critical	High	Medium	Low	Unscored	Watchlist
3128	22	293	1559	1118	123	34	1655

P1 - Act now (KEV / high EPSS)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84869	9.9	CRIT	Yes	0.007	connectwise:screenconnect	A condition in the ScreenConnect client may allow files to be transferred and executed through an active remote session without authorization or Host confirmation in certain circumstances. ScreenConnect servers are not impacted.
CVE-2025-67038	9.3	CRIT	Yes	0.193	lantronix:e213f102s, lantronix:e213f102s_firmware, lantronix:e214f002s, lantronix:e214f002s_firmware, lantronix:e214f00c	An issue was discovered in Lantronix EDS5000 2.1.0.0R3. The HTTP RPC module executes a shell command to write logs when user's authentication fails. The username is directly concatenated with the command without any sanitization. This allow attackers to inject arbitrary OS commands into the username parameter. Injected commands are executed with root privileges.
CVE-2026-85046	8.8	HIGH	Yes	0.015	google:chrome, google:v8	Type confusion in V8 in Google Chrome prior to 152.0.7977.82 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2025-38352	7.8	HIGH	Yes	0.013	debian:debian_linux, linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: posix-cpu-timers: fix race between handle_posix_cpu_timers() and posix_cpu_timer_del() If an exiting non-autoreaping task has already passed exit_notify() and calls handle_posix_cpu_timers() from IRQ, it can be reaped by its parent or debugger right after unlock_task_sighand(). If a concurrent posix_cpu_timer_del() runs at that moment, it won't...
CVE-2026-31431	7.8	HIGH	Yes	0.999	amazon:amazon_linux, arista:cloudvision_agni, arista:cloudvision_portal, arista:netvisor_os, arista:velocloud_edge, aris	In the Linux kernel, the following vulnerability has been resolved: crypto: algif_aead - Revert to operating out-of-place This mostly reverts commit 72548b093ee3 except for the copying of the associated data. There is no benefit in operating in-place in algif_aead since the source and destination come from different mappings. Get rid of all the complexity added for in-place operation and just copy the AD direc...
CVE-2026-81963	7.8	HIGH	Yes	0.006	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Improper link resolution before file access ('link following') in Windows Update Stack allows an authorized attacker to elevate privileges locally.
CVE-2026-85880	7.8	HIGH	Yes	0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows ALPC allows an authorized attacker to elevate privileges locally.
CVE-2025-25249			Yes	0.024	fortinet:multiple products	Fortinet FortiOS, FortiSwitchManager, and FortiSASE contain a heap-based buffer overflow vulnerability that allows an attacker to execute unauthorized code or commands via specially crafted packets.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19490			Yes	0.056	citrix:netscaler	Citrix NetScaler ADC and NetScaler Gateway contain an authentication-bypass vulnerability involving an alternate path or channel. When the NetScaler appliance is configured as an AAA virtual server or as a Gateway (SSL VPN, ICA Proxy, CVPN, or RDP Proxy), an unauthenticated remote threat actor may be able to bypass authentication.
CVE-2026-20079			Yes	0.758	cisco:secure firewall management center (fmc) and security cloud control (scc) firewall management	Cisco Secure Firewall Management Center (FMC) Software and Cisco Security Cloud Control (SCC) Firewall Management contain an authentication Bypass using an alternate path or channel vulnerability that could allow an unauthenticated, remote attacker to bypass authentication and execute script files on an affected device to obtain root access to the underlying operating system.
CVE-2026-42016			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an incorrect authorization vulnerability that leads to a privilege escalation attack due to a validation check of the token signature/issuer and not the token's scope.
CVE-2026-42018			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an improper authentication vulnerability that could return an internal anonymous-user token to an unauthenticated caller when anonymous access is disabled, potentially exposing sensitive resources.
CVE-2026-58704			Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-67277			Yes	0.009	mikrotik:routeros	MikroTik RouterOS contains a missing authentication for critical function vulnerability which allows kernel memory disclosure and denial of service in the btest service.
CVE-2026-75650			Yes	0.021	adobe:commerce and magento	Adobe Commerce and Magento Open Source contain an improper neutralization of special elements used in a template engine vulnerability that could allow an attacker to execute arbitrary code.
CVE-2026-76460			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-76461			Yes	0.02	cisco:secure email gateway	Cisco AsyncOS software for Cisco Secure Email Gateway (SEG) contains a SQL injection vulnerability that could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system.
CVE-2026-85706			Yes	0.12	gitlab:community edition and enterprise edition	GitLab Community Edition and Enterprise Edition contains a path traversal vulnerability that allows an unauthenticated user to read arbitrary files due to an improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-86060			Yes	0.011	mikrotik:routeros	MikroTik RouterOS contains an improper neutralization of argument delimiters in a command vulnerability which allows an attacker to change the trusted RouterOS policy mask, leading to privilege escalation.
CVE-2026-86218			Yes	0.007	n-able:n-central	N-able N-central contains a static code injection vulnerability that could allow for pre-authentication remote code execution.
CVE-2026-87491			Yes	0.01	google:chromium v8	Google Chromium V8 contains an out of bounds write vulnerability that allows a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. This vulnerability could affect multiple web browsers that utilize Chromium, including, but not limited to, Google Chrome, Microsoft Edge, and Opera.
CVE-2026-87886			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.
CVE-2023-52251	8.8	HIGH		0.868	provectus:ui	An issue discovered in provectus kafka-ui 0.4.0 through 0.7.2 allows remote attackers to execute arbitrary code via the q parameter of /api/clusters/local/topics/{topic}/messages. No fixed release is available; the project has had no commit since 2024-04-08.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-43284	8.8	HIGH		0.932	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: xfrm: esp: avoid in-place decrypt on shared skb frags MSG_SPLICE_PAGES can attach pages from a pipe directly to an skb. TCP marks such skbs with SKBFL_SHARED_FRAG after skb_splice_from_iter(), so later paths that may modify packet data can first make a private copy. The IPv4/IPv6 datagram append paths did not set this flag when splicing pages in...

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19188	10.0	CRIT		0.019		A critical OS command injection vulnerability has been identified in the Haiwell IoT Cloud HMI Gateway product. The vulnerability exists in the Net Check feature accessible via the /setting endpoint. The cmdPing Socket.io event fails to properly sanitize user-supplied input before passing it to the underlying operating system, allowing an attacker to inject and execute arbitrary OS commands with root privileges.
CVE-2026-28659	10.0	CRIT		0.001	google:android_xr	In MicroXR Blobstore, there is a possible way to access other app's files due to a missing permission check. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-44756	10.0	CRIT		0.003		A memory safety vulnerability exists in the Extended Passport Protocol (EPP) processing library. Under specific conditions, an unauthenticated attacker could exploit a crafted network request containing a malformed EPP header, potentially resulting in undefined behavior and abnormal program termination. Successful exploitation may have a high impact on the confidentiality, integrity, and availability of the applic...
CVE-2026-48168	10.0	CRIT		0.009		PraisonAI is a multi-agent teams system. In versions prior to 4.6.40, the bundled Claude GitHub Actions workflow is vulnerable to command injection because it embeds an attacker-controlled pull request branch name into a Bash run: block without quoting or validation. Additionally, the workflow allows any @claude comment to trigger the job regardless of whether the commenter is a trusted collaborator. An outside co...
CVE-2026-49883	10.0	CRIT		0.001	google:android	In checkReadPermission of PermissionsManager.java, there is a possible way to monitor sensitive device state data due to a missing permission check. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-70352	10.0	CRIT		0.006		Missing authentication for critical function in Azure AI Language allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-75754	10.0	CRIT		0.002		Missing Authentication for Critical Function, Server-Side Request Forgery (SSRF), and Use of Hard-coded Credentials in ASUS Control Center allow an unauthorized user to obtain the encryption key via an HTTP request, causing a local service to enable SSH on port 2222. The attacker can then log in with the hardcoded credentials to obtain a root shell, enabling direct reading, writing, and deletion of data on ASUS Con...
CVE-2026-77995	10.0	CRIT		0.003		Joomla Extension - miniorange.com - Arbitrary account takeover in miniOrange OAuth Client < 3.2.0, OAuth Single Sign-On – OIDC SSO < 1.2.2, Login with Keycloak OAuth Single Sign-On (SSO) < 1.2.2, Single Sign-On for Educational Institutes < 1.2.2 - The manipulation of a cookie value allows actors to login as arbitrary accounts, including admins.
CVE-2026-77998	10.0	CRIT		0.003		Joomla Extension - miniorange.com - Unauthenticated Authentication Bypass via SAMLResponse Parameter in miniOrange SAML SSO < 11.0.2, SAML SP Single Sign On – Login with ADFS < 6.4, SAML SP Single Sign On – SAML SSO login with Google Apps < 6.4 - This is due to the mo_saml_validate_signature() function performing a loose boolean check on the raw tri-state integer returned by PHP's openssl_verify(), causing an err...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80098	10.0	CRIT		0.003	microsoft:copilot_studio	Improper verification of cryptographic signature in Copilot Studio allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-82004	10.0	CRIT		0.014	adobe:campaign	Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-83711	10.0	CRIT		0.006		Authorization bypass through user-controlled key in Microsoft Azure Active Directory B2C allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-12645	9.9	CRIT		0.012		A Missing Authorization vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.
CVE-2026-12646	9.9	CRIT		0.012		A Missing Authorization vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.
CVE-2026-12647	9.9	CRIT		0.012		A Missing Authorization vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.
CVE-2026-12650	9.9	CRIT		0.015		A Deserialization of Untrusted Data vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.
CVE-2026-19232	9.9	CRIT		0.006	adobe:experience_manager	Adobe Experience Manager is affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user, potentially gaining elevated access or control over the victim's account or session. A low-privileged attacker could exploit this vulnerability to gain elevated access or control over the victim's account or session. Exploitation of this issue does not r...
CVE-2026-26084	9.9	CRIT		0.002		A improper access control vulnerability in Fortinet FortiSandbox 5.0.0 through 5.0.5, FortiSandbox 4.4.0 through 4.4.8, FortiSandbox Cloud 5.0.4 through 5.0.5, FortiSandbox PaaS 5.0.4 through 5.0.5 may allow attacker to access sensitive information via crafted HTTP requests.
CVE-2026-48086	9.9	CRIT		0.003		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.2, a TENANT_ADMIN promotes themselves to platform-wide GLOBAL_ADMIN through a single PUT request. The role-update handler accepts the `GLOBAL_ADMIN` enum value from any tenant admin updating their own tenant's staff. No policy check enforces that "only an existing GLOBAL_ADMIN may grant ...
CVE-2026-48273	9.9	CRIT		0.019	adobe:coldfusion	ColdFusion is affected by an Improper Neutralization of Directives in Dynamically Evaluated Code ('Eval Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-55166	9.9	CRIT		0.003		Lemur manages TLS certificate creation. Prior to 1.9.2, authenticated users could influence an ACME authority acme_url without an effective server-side destination restriction and trigger AcmeHandler.setup_acme_client to make backend requests. An attacker could target cloud instance metadata or internal services from Lemur network context, potentially obtaining credentials available to the host. The advisory also ...
CVE-2026-55565	9.9	CRIT		0.005		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs LikeExpression.fillCode_getValueReturn in yamcs-core/src/main/java/org/yamcs/yarch/streamsql/LikeExpression.java inserts an unescaped LIKE pattern into Java source compiled by Expression.getCompiledExpression through SimpleCompiler.cook instead of applying ValueExpression.escapeJavaString. The pattern can originate from POST /api/archive/{inst...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-65818	9.9	CRIT		0.003	microsoft:power_platform	Server-side request forgery (ssrf) in Power Automate allows an authorized attacker to elevate privileges over a network.
CVE-2026-66627	9.9	CRIT		0.004		Unrestricted Upload of File with Dangerous Type vulnerability in EDGE22 Studios Ltd. GP Premium allows Remote Code Inclusion. This issue affects GP Premium: from n/a through 2.5.5.
CVE-2026-66795	9.9	CRIT		0.003		A flaw was found in the managedcluster-import-controller. The Certificate Signing Request (CSR) auto-approval logic improperly validates incoming CSRs, specifically by not inspecting the signer name or decoding the PEM-encoded x509 CSR. This vulnerability allows a privileged service account on a spoke cluster to submit a malicious CSR. Successful exploitation can lead to privilege escalation, enabling the attacker...
CVE-2026-72733	9.9	CRIT		0.006		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the backup.restoreBackupWithLogs tRPC subscription builds database restore shell pipelines from the user-controlled databaseName and backupFile fields without safely separating them from shell syntax. packages/server/src/utils/restore/utls.ts interpolates databaseName into database-specific restore commands, while packages/server/src...
CVE-2026-72735	9.9	CRIT		0.007		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, writeTraefikConfigRemote in packages/server/src/utils/traefik/application.ts serializes user-controlled Traefik configuration with yaml.stringify and interpolates the resulting yamlStr into an echo command executed through execAsyncRemote. Single quotes in redirect regex and replacement fields, basic authentication usernames, domain h...
CVE-2026-72736	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy passes user-controlled values directly into shell commands via unquoted template literal interpolation in the registry credential testing and Docker Swarm cluster management endpoints. Both endpoints have a safe local code path (using execFileAsync or the Docker API) but a vulnerable remote path (using execAsyncRemote which r...
CVE-2026-72738	9.9	CRIT		0.007		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the backup.listBackupFiles tRPC endpoint in apps/dokploy/server/api/routers/backup.ts passes the search parameter through normalizeS3Path and interpolates it into an rclone lsjson command executed by child_process.exec(), allowing an authenticated user with backup:read permission to execute arbitrary commands on the Dokploy host. This...
CVE-2026-72740	9.9	CRIT		0.007		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, packages/server/src/utils/providers/git.ts parses the user-controlled customGitUrl with sanitizeRepoPathSSH and interpolates its domain into the ssh-keyscan command from addHostToKnownHostsCommand without shell quoting, allowing an authenticated member with service deployment permission and an attached SSH key to execute arbitrary com...
CVE-2026-72862	9.9	CRIT		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the mariadb.ts, mongo.ts, mysql.ts, postgres.ts, redis.ts, and libsql.ts Dokploy database service deployment functions pass user-controlled dockerImage fields unquoted into docker pull \${dockerImage} shell commands on the remote-server code path. This vulnerability is fixed in 0.29.13.
CVE-2026-72863	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy's WebSocket handlers (in-app terminals and log streamers) authenticate the session but never authorize it. They establish who the user is via validateRequest() and then proceed without consulting the role/permission model that every tRPC procedure enforces. Any authenticated member, can therefore open an interactive shell into...
CVE-2026-72864	9.9	CRIT		0.003		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the local branch of /docker-container-terminal in apps/dokploy/server/wss/docker-container-terminal.ts authenticates with validateRequest but does not authorize the attacker-controlled containerId against the caller's role, organization, or service access before passing it to `docker exec`, allowing any authenticated member to obtain ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72865	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the compose.update operation stores an unvalidated composePath that packages/server/src/utls/builders/compose.ts and packages/server/src/services/compose.ts interpolate into docker compose -f, docker stack deploy -c, and touch shell commands executed through /bin/sh -c. An authenticated member with compose write and deploy permission...
CVE-2026-72867	9.9	CRIT		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). From 0.29.3 until 0.29.13, the incomplete fix for CVE-2026-45628 leaves packages/server/src/db/schema/compose.ts branch fields without server-side validation, allowing a direct compose.update request to store a malicious customGitBranch, branch, gitlabBranch, bitbucketBranch, or giteaBranch. A low-privileged authenticated user can trigger compose.deplo...
CVE-2026-72868	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, apps/dokploy/server/api/routers/destination.ts interpolates the accessKey, secretAccessKey, region, endpoint, provider, and bucket fields from destination.testConnection into an rclone ls command executed through child_process.exec. The `withPermission("destination", "create")` path permits a low-privileged organization member to reac...
CVE-2026-72869	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the backup.restoreBackupWithLogs tRPC subscription passes the databaseName parameter to restore builders in packages/server/src/utls/restore/utls.ts, where PostgreSQL, MariaDB, MySQL, and MongoDB commands embed the value in nested shell text executed by Node.js exec. An authenticated user with backup:restore permission can supply a ...
CVE-2026-72872	9.9	CRIT		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, application.saveBitbucketProvider stores bitbucketOwner and bitbucketRepository without validation and cloneBitbucketRepository in packages/server/src/utls/providers/bitbucket.ts interpolates those values into git clone commands executed through execAsync or execAsyncRemote, allowing a member with service deployment permission to exe...
CVE-2026-72876	9.9	CRIT		0.006		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, swarm.getNodes, swarm.getNodeInfo, swarm.getNodeApps, and swarm.getAppInfos in apps/dokploy/server/api/routers/swarm.ts accept another organization's serverId without an activeOrganizationId ownership check, and getNodeInfo in packages/server/src/services/docker.ts interpolates nodeId into execAsyncRemote, allowing a caller with serve...
CVE-2026-72880	9.9	CRIT		0.003		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the apiCreateCertificate schema in packages/server/src/db/schema/certificate.ts accepts a client-supplied certificatePath, and packages/server/src/services/certificate.ts joins that value to the certificate root without confinement. An authenticated user with certificate create or delete permission can use certificatePath to write att...
CVE-2026-72882	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). In 0.28.8 and earlier, an authenticated user who can create or update file mounts for a service can inject shell metacharacters into filePath, causing Dokploy to execute attacker-controlled commands on the configured remote managed server over SSH. In the default deployment model, this yields direct remote host RCE from the web interface.
CVE-2026-72886	9.9	CRIT		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). From 0.29.2 until 0.29.13, schedule.create and schedule.update in apps/dokploy/server/api/routers/schedule.ts derive serviceId from applicationId or composeId and execute the owner/admin host-schedule gate only in the alternative branch, allowing a member with access to one application to attach its applicationId to a dokploy-server schedule and run a ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72901	9.9	CRIT		0.006		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy allows an authenticated low-privilege member to execute arbitrary commands on the control-plane host because the volumeName field accepted by volumeBackup.create and volumeBackup.runManually is interpolated without quoting in packages/server/src/utlis/volume-backups/backup.ts and executed through child_process.exec, with Docke...
CVE-2026-72902	9.9	CRIT		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy allows an authenticated user to execute arbitrary commands on a local or SSH-connected target server because registry.testRegistry and registry.testRegistryById in apps/dokploy/server/api/routers/registry.ts interpolate the password field into an execAsyncRemote shell command instead of using safeDockerLoginCommand. This issue...
CVE-2026-73268	9.9	CRIT		0.005		A flaw was found in the cluster-curator-controller component of multicluster engine (MCE). A tenant with create or update permissions on ClusterCurator resources can inject an arbitrary Job specification. This is possible because the CreateJob() function does not validate user-controlled input when unmarshaling the spec.install.overrideJob raw extension. Successful exploitation allows the injected Job to run with ...
CVE-2026-73269	9.9	CRIT		0.003		A flaw was found in the cluster-curator-controller component. A local user, by creating a ClusterCurator resource with a specific naming convention, can trigger the creation of a cluster-scoped ClusterRoleBinding. This allows the user to escalate their privileges from namespace-local access to cluster-wide control. This privilege escalation grants broad permissions, including the ability to access and manipulate s...
CVE-2026-78234	9.9	CRIT		0.002		A flaw was found in hawtio-operator. The operator reads the OpenShift Service CA private signing key from the openshift-service-ca namespace and uses it to mint client certificates with a Subject Common Name (CN) supplied by the author of a namespaced Hawtio custom resource. Because the operator ships a ClusterRole that aggregates Hawtio CR permissions into the edit and admin roles, any user with edit access in an...
CVE-2026-79748	9.9	CRIT		0.003		MCPHub is a unified hub for centrally managing and dynamically orchestrating multiple MCP servers/APIs into separate endpoints with flexible routing strategies. Prior to version 0.12.15, the POST /api/servers and PUT /api/servers/:name endpoints in MCPHub create/update MCP server configurations and then immediately spawn the configured stdio process via child_process.spawn. Authentication is required, but there is...
CVE-2026-86464	9.9	CRIT		0.004		In the current development version of Eclipse aeriOS, for which no official release has yet been published, the Identity Manager (IdM) deployment included insecure default configurations and credentials for security-sensitive services. The Helm chart exposed the Keycloak service and its PostgreSQL backing database through Kubernetes NodePort services by default, while the Docker Compose deployment similarly ex...
CVE-2023-42179	9.8	CRIT		0.003		Bird Home Automation GmbH D1101V-F 000140 is vulnerable to Incorrect Access Control via the Key derivation process, password validation process.
CVE-2024-11080	9.8	CRIT		0.004		The Post Grid and Gutenberg Blocks – ComboBlocks plugin for WordPress is vulnerable to Unauthenticated Hook Injection in versions 2.2.32 to 2.3.1 via several functions in the ~/includes/blocks/form-wrap/function.php file. This makes it possible for unauthenticated attackers to execute actions with hooks in WordPress, granted no other security controls are present in the function.
CVE-2025-70149	9.8	CRIT		0.004	codeastro:membership_management_system	CodeAstro Membership Management System 1.0 is vulnerable to SQL Injection in print_membership_card.php via the ID parameter.
CVE-2025-70150	9.8	CRIT		0.006	codeastro:membership_management_system	CodeAstro Membership Management System 1.0 contains a missing authentication vulnerability in delete_members.php that allows unauthenticated attackers to delete arbitrary member records via the id parameter.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-70152	9.8	CRIT		0.004	fabian:scholars_tracking_system	code-projects Community Project Scholars Tracking System 1.0 is vulnerable to SQL Injection in the admin user management endpoints /admin/save_user.php and /admin/update_user.php. These endpoints lack authentication checks and directly concatenate user-supplied POST parameters (firstname, lastname, username, password, user_id) into SQL queries without validation or parameterization.
CVE-2026-10196	9.8	CRIT		0.006		The Mail Mint – Email Marketing, Newsletter, Email Automation & WooCommerce Emails plugin for WordPress is vulnerable to PHP Object Injection in all versions up to, and including, 1.31.0 via deserialization of untrusted input in the 'handle_form_submission' function. This makes it possible for unauthenticated attackers to inject a PHP Object. The additional presence of a POP chain allows attackers to execute code ...
CVE-2026-12744	9.8	CRIT		0.022		A Deserialization of Untrusted Data vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote unauthenticated attacker to execute arbitrary code on the server.
CVE-2026-12745	9.8	CRIT		0.021		A Deserialization of Untrusted Data vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote unauthenticated attacker to execute arbitrary code on the server.
CVE-2026-13447	9.8	CRIT		0.004		The Mstore Api plugin for WordPress is vulnerable to Authentication Bypass via JWT Forgery in versions up to, and including, 4.20.0 This is due to missing cryptographic signature verification in the FirebasePhoneAuthHelper::verify_id_token() function, which decodes and validates Firebase ID token claims (alg, kid, aud, iss) but never calls openssl_verify() or any equivalent to validate the JWT signature against Go...
CVE-2026-16310	9.8	CRIT		0.003		The MemberDash plugin for WordPress is vulnerable to Insecure Direct Object Reference in all versions up to, and including, 1.8.5 via the 'id' parameter due to missing validation on a user controlled key. This makes it possible for unauthenticated attackers to change the password of any WordPress user, including administrators, by supplying an arbitrary user ID during registration, and take over their account with...
CVE-2026-16504	9.8	CRIT		0.004		Deployment of the VPS.org one-click Zulip template deploys a hardcoded application signing key, a default database password ("zulip"), and DISABLE_HTTPS=True.
CVE-2026-18221	9.8	CRIT		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to gain unauthorized access due to improper validation of client-supplied authentication parameters.
CVE-2026-18749	9.8	CRIT		0.004		The type=track branch authorises on _is_my_case(t_attach.case) only and never checks VinceTrackAttachment.shared. A coordinator-uploaded case artefact that has NOT been marked shared is still retrievable by any case member who has (or is sent) its uuid — leaks not-yet-released coordinator material to vendors on the case.
CVE-2026-18922	9.8	CRIT		0.006		A flaw was found in 389 Directory Server. During SASL PLAIN authentication, a stale identity carried in a Cyrus SASL auxiliary property from a prior failed bind attempt can be installed on a connection following a subsequent, unrelated successful bind, regardless of which SASL mechanism completes that second bind. An attacker can send a SASL PLAIN bind as cn=Directory Manager with an incorrect password, then compl...
CVE-2026-26035	9.8	CRIT		0.006	fortinet:fortiweb	An Improper Authentication vulnerability [CWE-287] vulnerability in Fortinet FortiWeb 8.0.0 through 8.0.2, FortiWeb 7.6.0 through 7.6.6, FortiWeb 7.4.0 through 7.4.11, FortiWeb 7.2.0 through 7.2.12, FortiWeb 7.0.0 through 7.0.12 may allow a remote unauthenticated attacker to login into the Fortiweb GUI/CLI with a random username and password
CVE-2026-28606	9.8	CRIT		0.003	google:android	In handleBondStateChanged of AdapterService.java, there is a possible way to skip pairing due to a logic error in the code. This could lead to remote escalation of privilege without user consent with no additional execution privileges needed. User interaction is not needed for exploitation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-31020	9.8	CRIT		0.006		In DocsGPT 0.15.0 and below, the application provides a custom prompt feature that allows users to define prompt content used during chatbot interactions. This functionality renders user-supplied prompt data using Jinja templates without input sanitization or sandboxing. An unauthenticated attacker can inject malicious template expressions, leading to a server-side template injection (SSTI) vulnerability that can ...
CVE-2026-35868	9.8	CRIT		0.014		A Command Injection vulnerability exists in the bs_SetLimitCli_info function within the libshare.so library of LB-link Router AC2100_AZ3 V1.0.4. This flaw occurs due to insufficient validation and sanitization of user-supplied input before it is passed to a system-level command execution context. An attacker can exploit this vulnerability by injecting specially crafted shell metacharacters or payloads into the vul...
CVE-2026-35869	9.8	CRIT		0.013		A Command Injection vulnerability exists in the bs_SetLimitCli_info function within the libshare.so library of LB-link Router AC450M V4.0.0. This flaw occurs due to insufficient validation and sanitization of user-supplied input before it is passed to a system-level command execution context. An attacker can exploit this vulnerability by injecting specially crafted shell metacharacters or payloads into the vulnera...
CVE-2026-37003	9.8	CRIT		0.016		Agno up to and including 2.5.8 is vulnerable to Remote Code Execution (RCE) via prompt injection. The PythonTools and ShellTools components pass unsanitized, LLM-generated arguments directly to execution sinks including exec(), runpy.run_path(), and subprocess.run(). An unauthenticated attacker can exploit this by embedding malicious instructions in content processed by the agent (such as web pages or documents), ...
CVE-2026-37236	9.8	CRIT		0.004		grpc-gateway v2.28.0 is vulnerable to Incorrect Access Control. The application processes the X-HTTP-Method-Override header in ServeMux.ServeHTTP without restricting allowed methods. When a POST request with Content-Type application/x-www-form-urlencoded includes this header, the request method is rewritten to an arbitrary attacker-supplied value before routing. This allows bypassing method-based access controls e...
CVE-2026-43501	9.8	CRIT		0.006	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ipv6: rpl: reserve mac_len headroom when recompressed SRH grows ipv6_rpl_srh_rcv() decompresses an RFC 6554 Source Routing Header, swaps the next segment into ipv6_hdr->daddr, recompresses, then pulls the old header and pushes the new one plus the IPv6 header back. The recompressed header can be larger than the received one when the swap reduce...
CVE-2026-45117	9.8	CRIT		0.008		MyBB is free and open source forum software. From 1.8.13 until 1.8.40, the installer module does not properly escape user-supplied database configuration values written to the configuration file, resulting in PHP code injection and remote code execution when the installer is available. install/index.php processes the values with addslashes(), but the \$characters argument added in MyBB 1.8.13 does not include the ...
CVE-2026-45538	9.8	CRIT		0.006		OpenSIPS is a Session Initiation Protocol (SIP) server implementation. In versions 4.0.0 and prior, processing a SIP message with a header name longer than 255 bytes causes a stack buffer overflow when sip_to_json() is called in the routing script. Function sip_to_json() (modules/sipmsgops/sipmsgops.c) copies SIP header names into a fixed 255-byte stack buffer without bounds checking, performing a memcpy of the fu...
CVE-2026-48085	9.8	CRIT		0.006		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.1, a fully provisioned OpenReception instance accepts unauthenticated POST requests to `setup/create-admin-account` and creates additional GLOBAL_ADMIN accounts without verifying that an admin already exists. Any unauthenticated network attacker who can submit a same-origin form POST ga...
CVE-2026-48087	9.8	CRIT		0.005		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.2, the registration handler at `POST /api/auth/register/{userId}` validates the relationship between the WebAuthn challenge and the registration cookie's email but never validates that the `userId` in the URL belongs to that email. An unauthenticated attacker requests a challenge for the...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-49921	9.8	CRIT		0.003		In multiple locations, there is a possible memory safety issue due to a heap buffer overflow. This could lead to remote code execution with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-52111	9.8	CRIT		0.003		An issue in fast-note-sync-service <=2.13.7 allows a remote attacker to escalate privileges via the admin configuration endpoint exposes authTokenKey
CVE-2026-52986	9.8	CRIT		0.006	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nf_contrack_sip: don't use simple_strtoul Replace unsafe port parsing in epaddr_len(), ct_sip_parse_header_uri(), and ct_sip_parse_request() with a new sip_parse_port() helper that validates each digit against the buffer limit, eliminating the use of simple_strtoul() which assumes NUL-terminated strings. The previous code dereferenc...
CVE-2026-55559	9.8	CRIT		0.006		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs inserts templateArgs from POST /api/instances and PATCH /api/instances/{instance} into YAML through VarStatement.append in yamcs-core/src/main/java/org/yamcs/templating/VarStatement.java without YAML-context escaping. The rendered configuration is parsed by YamcsServer.createInstance and loaded by YamcsServerInstance, allowing an attacker to i...
CVE-2026-58240	9.8	CRIT		0.003		SAP NetWeaver Message Server does not sufficiently validate the authenticity of internal application server components during registration. An unauthenticated attacker with network access to the affected service could exploit this weakness to register an unauthorized component and potentially perform unauthorized actions within the application environment, resulting in a high impact on the confidentiality, integri...
CVE-2026-58822	9.8	CRIT		0.003		In multiple functions of ftsmooth.c, there is a possible memory safety issue due to improper casting. This could lead to remote code execution with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-62916	9.8	CRIT		0.006	microsoft:entra_id	Authentication bypass using an alternate path or channel in Microsoft Entra ID allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-63223	9.8	CRIT		0.008		CodeIgniter is a PHP full-stack web framework. Prior to 4.7.4, the is_image and mime_in upload validation rules do not independently enforce a safe client filename extension, allowing a remote attacker to upload executable content when an application preserves the client filename and stores uploads in a web-accessible script-enabled directory. Applications are impacted when they validate uploads using is_image or ...
CVE-2026-66302	9.8	CRIT		0.005	microsoft:skype_for_business_server, microsoft:skype_for_business_server_subscription_edition	External control of file name or path in Skype for Business allows an unauthorized attacker to execute code over a network.
CVE-2026-68839	9.8	CRIT		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows USB Mass Storage Class Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-69276	9.8	CRIT		0.009		Integer underflow (wrap or wraparound) in Microsoft UxTheme Library (uxtheme.dll) allows an unauthorized attacker to execute code over a network.
CVE-2026-69408	9.8	CRIT		0.01		Integer overflow or wraparound in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-69431	9.8	CRIT		0.009		Heap-based buffer overflow in Telnet Client allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69463	9.8	CRIT		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code over a network.
CVE-2026-69491	9.8	CRIT		0.009		Heap-based buffer overflow in Windows Microsoft DirectMusic allows an unauthorized attacker to execute code over a network.
CVE-2026-69493	9.8	CRIT		0.01		Out-of-bounds read in Windows Event Logging Service allows an unauthorized attacker to execute code over a network.
CVE-2026-69496	9.8	CRIT		0.01		Heap-based buffer overflow in Windows Compressed Folder allows an unauthorized attacker to execute code over a network.
CVE-2026-69525	9.8	CRIT		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Desktop Services allows an unauthorized attacker to execute code over a network.
CVE-2026-69579	9.8	CRIT		0.01		Use after free in Windows Message Queuing allows an unauthorized attacker to execute code over a network.
CVE-2026-69586	9.8	CRIT		0.01		Integer overflow or wraparound in Microsoft Windows PDF allows an unauthorized attacker to execute code over a network.
CVE-2026-69590	9.8	CRIT		0.01		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-69595	9.8	CRIT		0.011		Use after free in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-69715	9.8	CRIT		0.01		Out-of-bounds read in Windows Direct Show allows an unauthorized attacker to execute code over a network.
CVE-2026-69730	9.8	CRIT		0.011		Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-69768	9.8	CRIT		0.009		Heap-based buffer overflow in Windows RNDIS allows an unauthorized attacker to execute code over a network.
CVE-2026-69769	9.8	CRIT		0.009		Heap-based buffer overflow in Windows HTTP Print Provider allows an unauthorized attacker to execute code over a network.
CVE-2026-69819	9.8	CRIT		0.009		Out-of-bounds write in RPC Runtime allows an unauthorized attacker to execute code over a network.
CVE-2026-69824	9.8	CRIT		0.01		Integer underflow (wrap or wraparound) in Microsoft Standard XPS allows an unauthorized attacker to execute code over a network.
CVE-2026-69829	9.8	CRIT		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Shell allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69845	9.8	CRIT		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Heap-based buffer overflow in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-69910	9.8	CRIT		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Windows Hyper-V allows an unauthorized attacker to execute code over a network.
CVE-2026-70296	9.8	CRIT		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds write in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-71374	9.8	CRIT		0.003		Deserialization of untrusted data vulnerability in Cosminexus Component Container. This issue affects Cosminexus Component Container: from 11-70-01 before 11-70-03, from 11-60 before 11-60-03, from 11-50 through 11-50-03, from 11-40 through 11-40-03, from 11-30 through 11-30-08, from 11-20 before 11-20-10, from 11-10 through 11-10-11, from 11-00 before 11-00-13, from 09-87 before 09-87-10, from 09-80 before 09-80...
CVE-2026-71376	9.8	CRIT		0.01		OS command injection vulnerability in Cosminexus Component Container. This issue affects Cosminexus Component Container: from 11-70-01 before 11-70-03, from 11-60 before 11-60-03, from 11-50 through 11-50-03, from 11-40 through 11-40-03, from 11-30 through 11-30-08, from 11-20 before 11-20-10, from 11-10 through 11-10-11, from 11-00 before 11-00-13, from 09-87 before 09-87-10, from 09-80 before 09-80-05, from 09-...
CVE-2026-71377	9.8	CRIT		0.003		Command Argument Injection Vulnerability in Cosminexus Component Container. This issue affects Cosminexus Component Container: from 11-70-01 before 11-70-03, from 11-60 before 11-60-03, from 11-50 through 11-50-03, from 11-40 through 11-40-03, from 11-30 through 11-30-08, from 11-20 before 11-20-10, from 11-10 through 11-10-11, from 11-00 through 11-00-12, from 09-87 before 09-87-10, from 09-80 through 09-80-04, ...
CVE-2026-72979	9.8	CRIT		0.01		Use after free in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-72982	9.8	CRIT		0.009		Stack-based buffer overflow in Windows Netlogon allows an unauthorized attacker to execute code over a network.
CVE-2026-72983	9.8	CRIT		0.009		Use after free in Windows Internet Connection Sharing (ICS) allows an unauthorized attacker to execute code over a network.
CVE-2026-73009	9.8	CRIT		0.009		Use after free in Windows Secure Socket Tunneling Protocol (SSTP) allows an unauthorized attacker to execute code over a network.
CVE-2026-73010	9.8	CRIT		0.009		Use after free in Windows Failover Cluster allows an unauthorized attacker to execute code over a network.
CVE-2026-73025	9.8	CRIT		0.009		Weak authentication in Windows iSCSI allows an unauthorized attacker to bypass a security feature over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75430	9.8	CRIT		0.009		PowerJob Worker version 5.1.2 (and likely earlier versions) exposes the /worker/deployContainer HTTP endpoint without authentication on the default transport port. This allows a remote attacker to execute arbitrary code.
CVE-2026-75816	9.8	CRIT		0.005		The Frontend Admin by DynamiApps plugin for WordPress is vulnerable to Authentication Bypass to Account Takeover in all versions up to, and including, 3.29.12. This is due to the pre_update_value function lacking any capability or ownership check, and ActionPost::conditions_logic() short-circuiting its current_user_can('edit_post') authorization gate whenever the post ID is non-numeric — such as the string user_1 ...
CVE-2026-76578	9.8	CRIT		0.005		A flaw was found in FreeIPA. The self-managed OTP token ACI does not require authentication and does not restrict which attributes may be added alongside the token entry. An unauthenticated LDAP client can exploit this, combined with a related flaw in the underlying directory server's ACI evaluation (tracked separately), to create an arbitrary attacker-controlled Kerberos principal and have it added to the adminis...
CVE-2026-77493	9.8	CRIT		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Double free in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-77647	9.8	CRIT		0.026		SPIP before 4.4.20 allows unauthenticated remote attackers to execute arbitrary code, as exploited in the wild in August 2026. This is related to incorrect identification of <?php blocks, and var_export's mishandling of certain cases such as presence of a '<' character.
CVE-2026-77806	9.8	CRIT		0.042		SPIP before 4.4.21 allows unauthenticated remote attackers to execute arbitrary code, as exploited in the wild in August 2026. This is related to code injection via an X-Spip-Filtre HTTP request header that is mishandled by analyse_resultat_skel.
CVE-2026-78362	9.8	CRIT		0.003		The SEO Flow by LupsOnline WordPress plugin before 3.0.3 does not correctly validate the credential supplied with its API requests, allowing unauthenticated users to be served as the administrator who configured the SEO Flow by LupsOnline WordPress plugin before 3.0.3 and take over the site. Exploitation requires the SEO Flow by LupsOnline WordPress plugin before 3.0.3 to have been configured, which is its normal ...
CVE-2026-78445	9.8	CRIT		0.009	microsoft:windows_server_2012, microsoft:windows_server_2016, microsoft:windows_server_2019, microsoft:windows_server_20	Use after free in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-78509	9.8	CRIT		0.01	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-78510	9.8	CRIT		0.01	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-79569	9.8	CRIT		0.004		Movie_Recommend v1.0.0 was discovered to contain a SQL injection vulnerability in the sort parameter at /loadingmore. This vulnerability allows attackers to access sensitive database information via a crafted SQL statement.
CVE-2026-79570	9.8	CRIT		0.003		mfish-nocode-pro v1.0.0 was discovered to contain a SQL injection vulnerability in the tableName parameter at /sys/dbConnect/data. This vulnerability allows attackers to access sensitive database information via a crafted SQL statement.
CVE-2026-79574	9.8	CRIT		0.005		An issue in the gateway server of mpush v0.8.1 allows attackers to execute arbitrary code via sending a crafted broadcast message.
CVE-2026-79576	9.8	CRIT		0.003		An issue in the Single-Sign On (SSO) component of Digital-Infrastructure v9.6.7 allows attackers to authenticate as any user, including the Admin, without a password.
CVE-2026-79577	9.8	CRIT		0.003		An issue in the /cas/login component of sso-master v1.0.0 allows attackers to authenticate into the application without a password via sending a crafted POST request.
CVE-2026-82923	9.8	CRIT		0.006		The AI Website Builder WordPress plugin (GitHub build) 1.0.0 does not perform any authorisation or nonce check on its REST API routes, allowing unauthenticated attackers to install and activate plugins and themes, import content from a URL under their control, write a file of their choosing into the uploads directory, and delete site content and media. On a host that serves PHP from the uploads directory, that fil...
CVE-2026-83627	9.8	CRIT		0.008		The Hummingbird – Speed Optimization, Caching, Minify, Compress & CDN plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 3.21.0 via the log_msg() function in core/modules/class-page-cache.php. The page-cache debug log is written to wp-content/wphb-logs/page-caching-log.php, a directly web-accessible PHP file that is supposed to be protected by a leading '<?php die(); ...
CVE-2026-8376	9.8	CRIT		0.004	perl:perl	Perl versions before 5.40.5-RC1, from 5.41.0 before 5.42.3-RC1, from 5.43.0 before 5.43.11 have a heap buffer overflow when compiling regular expressions with a repeated fixed string on 32-bit builds. Perl_study_chunk in regcomp_study.c checked the size of the joined substring buffer in characters rather than bytes. For a quantified fixed substring with a large minimum count, the byte length mincount * l could ov...
CVE-2026-85504	9.8	CRIT		0.004		FreeIPMI before 1.6.19 has a stack-based buffer overflow in _ipmi_sel_oem_fujitsu_get_sel_entry_long_text in libfreeipmi/sel/ipmi-sel-string-fujitsu-irmc-common.c via malformed Fujitsu SEL long-text responses.
CVE-2026-85508	9.8	CRIT		0.004		ipmi-oem in FreeIPMI before 1.6.19 has a stack-based buffer overflow in _output_dell_system_info_cmc_ipv6_info in ipmi-oem/ipmi-oem-dell.c (cmc-ipv6-info subcommand to dell get-system-info).
CVE-2026-85509	9.8	CRIT		0.004		FreeIPMI before 1.6.19 has a stack-based buffer overflow in _read_fru_data in libfreeipmi/fru/ipmi-fru.c when a BMC returns more bytes than requested.
CVE-2026-86219	9.8	CRIT		0.005		Authen::SASL::Perl::DIGEST_MD5 versions before 2.2100 for Perl accept replayed authentication responses via unverified nonce in server_step. server_start generates a fresh nonce and sends it in the challenge, and nothing later compares that value against the nonce the client returns. server_step derives the expected digest from the client's own parameters, so a response verifies whenever its digest matches the no...
CVE-2026-86304	9.8	CRIT		0.002		MojoX::Authentication versions before 0.006 for Perl allow SAML authentication bypass because parse_assertion builds Net::SAML2::Binding::POST without a trust anchor. parse_assertion in MojoX::Authentication::Model::SAML2 calls Net::SAML2::Binding::POST->new with no cacert, cert_text or anchors argument, then passes the returned XML to Net::SAML2::Protocol::Assertion->new_from_xml with the IdP signing certificate...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19274	9.6	CRIT		0.002		IBM Observability with Instana (Agent) Build 1.0.303 through 1.0.323 IBM Instana Agent Operator could allow an authenticated Kubernetes tenant to hijack or permanently destroy another tenant's cluster-level RBAC permissions, caused by cluster-scoped RBAC objects being keyed solely by the bare CR name with no namespace disambiguation, allowing a same-named `InstanaAgent` CR in an attacker-controlled namespace to si...
CVE-2026-53552	9.6	CRIT		0.002		Goploy is an open-source automation deployment system. In versions 1.17.5 and prior, Project.AddFile, Project.EditFile, Project.RemoveFile, and Project.Edit in cmd/server/api/project/handler.go accept a project or project-file row id from the JSON body and act on it without checking that the project belongs to the caller's namespace. The corresponding model.ProjectFile.GetData and model.Project.GetData queries fil...
CVE-2026-65669	9.6	CRIT		0.007		Improper neutralization of special elements in output used by a downstream component ('injection') in SQL Server allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-71319	9.6	CRIT		0.004		Nuxt is an open-source web development framework for Vue.js. Prior to 3.3.1, Nuxt DevTools (development mode only) exposes a bidirectional RPC channel over the Vite HMR WebSocket via the nuxt:devtools:rpc plugin. On affected versions the channel has no authentication: any client that can reach the Vite HMR endpoint (ws://<host>:<port>/, subprotocol vite-hmr) can call RPC methods, with no token, handshake, or origi...
CVE-2026-72737	9.6	CRIT		0.002		Dokploy is a free, self-hostable Platform as a Service (PaaS). In 0.29.8 and earlier, backup.create, backup.update, and backup.restoreBackupWithLogs in apps/dokploy/server/api/routers/backup.ts accept a client-controlled destinationId and use the referenced destination without verifying that destination.organizationId equals ctx.session.activeOrganizationId. An authenticated member with backup permissions for a se...
CVE-2026-72877	9.6	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the dockerImage field is interpolated without quoting into shell commands in buildRemoteDocker() in packages/server/src/utlis/providers/docker.ts and is validated only as an optional string. An authenticated user with application create or update permission can use shell command substitution in dockerImage to execute arbitrary command...
CVE-2026-72878	9.6	CRIT		0.003		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy's backup and restore pipeline constructs shell commands by directly interpolating user-controlled database fields into bash -c "..." and sh -c "..." strings, then executes them via child_process.exec(). An authenticated admin/owner can inject arbitrary OS commands that execute on the host machine running Dokploy (not just insi...
CVE-2026-73300	9.6	CRIT		0.005		Budibase is an open-source low-code platform. Prior to 3.40.0, the MySQL integration component in Budibase is configured with multipleStatements: true, enabling execution of multiple SQL statements in a single query. Attackers can inject malicious SQL commands through user input fields, leading to complete database compromise. This vulnerability is fixed in 3.40.0.
CVE-2026-73843	9.6	CRIT		0.003		OpenChoreo is a complete, open-source developer platform for Kubernetes. Prior to 1.0.2 and 1.1.2, internal/cluster-gateway/server.go served caller-facing management APIs on the externally reachable agent listener without authentication, allowing network-reachable attackers to invoke /api/proxy/ and /api/exec/ operations, proxy the data-plane Kubernetes API, and execute commands in workload pods in multi-cluster d...
CVE-2026-81376	9.6	CRIT		0.006	microsoft:visual_studio_code	Incomplete comparison with missing factors in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-84333	9.6	CRIT		0.003	google:android, google:chrome	Use after free in Dawn in Google Chrome on on Android prior to 152.0.7977.75 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84352	9.6	CRIT		0.003	google:android, google:chrome	Use after free in WebGL in Google Chrome on on Android prior to 152.0.7977.75 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-84353	9.6	CRIT		0.003	google:android, google:chrome	Use after free in Shared Tab Groups in Google Chrome on on Android prior to 152.0.7977.75 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-85042	9.6	CRIT		0.003	google:chrome	Use after free in DevTools in Google Chrome prior to 152.0.7977.82 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-85047	9.6	CRIT		0.003	apple:iphone_os, google:chrome	Improper input validation in Transactions Platform in Google Chrome on on iOS prior to 152.0.7977.82 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-85050	9.6	CRIT		0.003	google:android, google:chrome	Out of bounds write in WebGL in Google Chrome on on Android prior to 152.0.7977.82 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-85085	9.6	CRIT		0.002		The Canva Android App before 2.376.0 allowed an external origin to be loaded in a privileged WebView. A threat actor who controls the page loaded by the user is able to communicate with Canva using the user's session.
CVE-2025-70141	9.4	CRIT		0.007	oretnom23:customer_support_system	SourceCodester Customer Support System 1.0 contains an incorrect access control vulnerability in ajax.php. The AJAX dispatcher does not enforce authentication or authorization before invoking administrative methods in admin_class.php based on the action parameter. An unauthenticated remote attacker can perform sensitive operations such as creating customers and deleting users (including the admin account), as well...
CVE-2026-48088	9.4	CRIT		0.003		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.4, the route 'POST /api/tenants/{tenantId}/staff/{staffId}/crypto' accepts and stores attacker-controlled ML-KEM-768 public keys against any tenant on the platform without authentication. The handler logs an "Unauthorized crypto key storage attempt" warning when neither a session nor a r...
CVE-2026-52777	9.4	CRIT		0.002		YesWiki is a wiki system written in PHP. Prior to version 4.6.6, there is an authenticated PHP object injection vulnerability in BazarImportAction via unserialize. This issue has been patched in version 4.6.6.
CVE-2026-57580	9.4	CRIT		0.004		authentik is an open-source identity provider. Prior to 2026.2.6 and 2026.5.5, an inbound SAML Source configured with the non-default USERNAME_LINK or EMAIL_LINK user-matching mode interprets an XML comment in a NameID differently from the identity provider's signed assertion. An attacker with an account on the source identity provider who can set the account's NameID can inject an XML comment that truncates the v...
CVE-2026-6223	9.4	CRIT		0.004		Improper restriction of excessive authentication attempts vulnerability in Bahçelievler Municipality BiHayat App allows Authentication Bypass. This issue affects BiHayat App: from 2.1.7 through 07092026. NOTE: The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-63221	9.4	CRIT		0.004		CodeIgniter is a PHP full-stack web framework. From 4.3.0 through 4.7.3, Query Builder deleteBatch() substitutes bound values from where() conditions into generated SQL while ignoring their escape flags, allowing user-controlled condition values to be interpreted as SQL. This affects only the deleteBatch() code path. Regular delete() operations escape where() binds correctly. This issue is fixed in version 4.7.4.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67305	9.4	CRIT		0.005	freerdp:freerdp	FreeRDP Windows client before 3.29.0 contains a heap buffer overflow vulnerability in the clipboard virtual channel when processing CLIPRDR_FILE_CONTENTS_RESPONSE PDUs without validating the server-provided size against the destination buffer. A malicious RDP server can send a response with a data payload significantly larger than requested, causing arbitrary heap memory corruption that may enable remote code exec...
CVE-2026-67330	9.4	CRIT		0.004		@better-auth/scim (a better-auth plugin) versions >= 1.4.0-beta.27 through <= 1.6.21 and >= 1.7.0-beta.0 through <= 1.7.0-beta.9 contain an authorization bypass. SCIM token issuance did not reject provider IDs already used by existing SSO, SAML, OIDC, generic OAuth, or social account providers, and the same logical provider ID was used for both SCIM provider configuration and account ownership. An authenticated us...
CVE-2026-67336	9.4	CRIT		0.002		better-auth versions before 1.6.11 contain insecure cryptographic defaults in the oidcProvider and mcp plugins that advertise the none algorithm and accept plain PKCE by default. Attackers can exploit algorithm negotiation to accept unsigned tokens or intercept authorization codes when PKCE plain is used instead of the required S256 method.
CVE-2026-72879	9.4	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.8, the getRegistryCommands() function in packages/server/src/utis/cluster/upload.ts interpolates registry.password and registry.registryUrl directly into a shell command without escaping. An authenticated user with project access can configure malicious registry credentials and trigger a swarm deployment to execute arbitrary OS commands ...
CVE-2026-75925	9.4	CRIT		0.007		Improper neutralization of CRLF sequences in IXON VPN Client before version 1.4.7 allows an attacker to execute commands as root or SYSTEM. Configuration values accepted by the local service are written to a file later consumed by a privileged subprocess, without line-ending sequences being neutralized, which allows additional directives to be introduced into that file. The configuration interface accepts changes ...
CVE-2026-76969	9.4	CRIT		0.003		@sap/cds-mtxs NPM library does not perform sufficient checks on certain functionality used in multitenant CAP applications with extensibility enabled. An unauthenticated attacker could send specially crafted requests to obtain sensitive credentials and abuse them to replace or delete tenant data. Successful exploitation can result in a high impact on availability and integrity of the application. There may also be...
CVE-2026-82533	9.4	CRIT		0.006		DeepSeek Harness before 0.1.2-alpha.1 contains an authentication bypass vulnerability that grants unauthenticated access to its local HTTP agent-control API by accepting a client-supplied loopback Host header in place of validating the actual TCP connection origin. On the default configuration, a confined tool-executed process can reach the loopback API without any port exposure and use it to escape its own OS san...
CVE-2026-86123	9.4	CRIT		0.003		SQL Chat contains four unauthenticated API endpoints that accept client-supplied database connection parameters and execute arbitrary SQL queries against attacker-specified hosts. Attackers can connect to internal databases, execute SQL commands, enumerate schemas, and pivot into the server's network without authentication.
CVE-2026-86148	9.4	CRIT		0.025		A security flaw has been discovered in Tenda CP3 27.5.57.101. This vulnerability affects the function SystemAsh of the file Apis/system.c of the component Kylin. The manipulation of the argument AlarmVoiceURL results in os command injection. It is possible to launch the attack remotely.
CVE-2026-86149	9.4	CRIT		0.02		A weakness has been identified in Tenda CP3 27.5.57.101. This issue affects some unknown processing of the file Net/NetCheckPing.cpp. This manipulation of the argument interface_name/host causes os command injection. The attack can be initiated remotely.
CVE-2026-86153	9.4	CRIT		0.004		A vulnerability has been found in Tenda CP3 27.5.57.101. This affects the function CRedirServer::SetRedirectEnable of the file Functions/Redirect.cpp. The manipulation leads to improper privilege management. Remote exploitation of the attack is possible.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2023-54391	9.3	CRIT		0.017		Proxmox Virtual Environment (VE) 7.0 through 8.0 contains an authentication bypass vulnerability in libpve-access-control before 8.0.4 that allows unauthenticated attackers to authenticate as any existing enabled user without a configured second factor by supplying an arbitrary tfa-challenge value in the API login endpoint. Attackers can send a POST request to the access ticket API endpoint with any value in the t...
CVE-2024-58376	9.3	CRIT		0.017		Renovate versions 37.158.0 before 37.199.0 contain a command injection vulnerability in the helmv3 manager's registryAliases handling that allows attackers with commit access to execute arbitrary commands. Attackers can manipulate registryAliases keys with unquoted shell metacharacters to inject commands executed during helm repo add operations, gaining full access to Renovate's execution environment.
CVE-2025-71401	9.3	CRIT		0.003		better-auth (npm) before 1.4.2 allows an external request to configure baseURL when it is not otherwise defined (e.g., BETTER_AUTH_URL is unset). An attacker able to make the very first request to the server after startup can poison the router's base path, causing all routes to return 404 for all users (denial of service). The issue is not reachable when baseURL is explicitly configured or on typical managed hosti...
CVE-2026-15378	9.3	CRIT		0.005		A flaw was found in the `guardrails-detectors` component. This vulnerability allows a remote attacker to perform a blind Server-Side Request Forgery (SSRF) by submitting a specially crafted XML Schema Definition (XSD) string. This can lead to unauthorized access to sensitive information, including credentials from cloud metadata services, Kubernetes API, internal MinIO, and other internal network endpoints. Additi...
CVE-2026-16279	9.3	CRIT		0.003		An Improper Authorization vulnerability affecting 3DPassport in 3DSwymer from Release 3DEXPERIENCE R2023x through Release 3DEXPERIENCE R2026x could allow an attacker to gain access to some user accounts.
CVE-2026-45118	9.3	CRIT		0.004		MyBB is free and open source forum software. Prior to 1.8.40, the Contact module does not validate a redirect URL or protocol correctly, resulting in an open redirect and reflected JavaScript code injection. contact.php accepts the redirect target from the from HTTP parameter in \$mybb->input['from'] or the Referer HTTP header in \$_SERVER['HTTP_REFERER'] and passes it to redirect() without sufficient verification. ...
CVE-2026-48159	9.3	CRIT		0.005		use-reducer-async is a React useReducer with async actions. Between 2026-05-18 16:29:52 and 2026-05-19 15:26:07, the default branch contained malicious commits da72edbde5705efce6c62e0a3dcb73687b78dc8 through df07d5711458d8b46e11dd7afaaa21e88cafabfb that executed remote attacker-controlled code on developer machines during `npm install`. The commits were removed by force-push, but local clones, forks, and direct-S...
CVE-2026-55068	9.3	CRIT		0.004		free5GC is an open-source implementation of the 5G core network. In 4.2.2 and earlier, the NRF RegisterNFInstance handler at PUT /nnrf-nfm/v1/nf-instances/{nfInstanceId} accepts NF Profiles without enforcing UUID format, nfStatus enum values, heartBeatTimer ranges, mandatory profile fields, or nfServices.ipEndPoints address constraints. The invalid profiles are persisted in the MongoDB NfProfile collection and ret...
CVE-2026-56705	9.3	CRIT		0.005		Adminer before 5.4.3 fails to sanitize the server field before constructing a PDO DSN string, allowing unauthenticated attackers to inject ODBC parameters via semicolons. Attackers can inject TraceFile and TraceOn parameters to write PHP code to the web root, achieving remote code execution when the trace file is accessed.
CVE-2026-61516	9.3	CRIT		0.004		Netis NX10 firmware V4.0.1.5808 and V3.0.0.4142 contain an information disclosure vulnerability that allows unauthenticated attackers to retrieve the administrator password by sending a request to the sysinfo action in the web management interface without a valid session. Attackers can replay the exposed credential against the login handler to establish a fully authenticated administrator session on the device.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-62645	9.3	CRIT		0.003		A vulnerability has been identified in Reyrolle 7SR5 (All versions < V2.70). Information is exposed through the web interface that can be used to calculate the current and past session ID numbers. This could allow an attacker to bypass the authentication and gain unauthorized access to the device.
CVE-2026-62647	9.3	CRIT		0.003		A vulnerability has been identified in Reyrolle 7SR5 (All versions < V2.70). A random number generator is used to generate security-relevant values (such as session identifiers used for authentication purposes) that is not initialized with a True Random Number Generator (TRNG), resulting in a predictable sequence of generated values. This could allow an unauthenticated remote attacker to more easily predict the ge...
CVE-2026-62928	9.3	CRIT		0.012		XING CPTrans-ME-X contains an OS Command Injection (CWE-78). Unauthenticated OS command may be injected.
CVE-2026-66794	9.3	CRIT		0.004		A flaw was found in the `cluster-proxy-addon` component of Multicluster Engine for Kubernetes. This vulnerability allows an unauthenticated attacker, who can access the user-facing route, to bypass authentication and authorization checks. By manipulating URL path segments, the attacker can proxy requests to arbitrary services across any managed cluster. This enables unauthorized access to internal services that wo...
CVE-2026-67614	9.3	CRIT		0.006		CyberPanel before 3.0.0 contains a hard-coded JWT secret vulnerability in the WebTerminal FastAPI SSH service that allows unauthenticated remote attackers to forge valid authentication tokens and obtain an interactive root shell via WebSocket on port 8888. Attackers can craft a forged JWT signed with the hardcoded secret value, specifying ssh_user=root, to authenticate to the terminal service without any valid cre...
CVE-2026-68582	9.3	CRIT		0.003		Vikunja versions >= 0.24.0 and <= 2.3.0 contain a broken object level authorization (BOLA) vulnerability in the task-collection endpoint (GET /api/v1/projects/{project}/views/{view}/tasks). The endpoint loads the requested project view from the URL path without verifying the caller is authorized for it. For a link-share token holder, the task scope is pinned to the share's own project, but the view is taken from t...
CVE-2026-69356	9.3	CRIT		0.007		Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Exchange Server allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-69657	9.3	CRIT		0.003		XING CPTrans-ME-X contains a Use of Default Password (CWE-1393). Anyone with the knowledge of the credential may log in to the affected device.
CVE-2026-70403	9.3	CRIT		0.003		XING CPTrans-ME-X contains a Use of Hard-coded Password (CWE-259). Anyone with the knowledge of the credential may log in to the affected device.
CVE-2026-72839	9.3	CRIT		0.005		filebrowser through 2.63.16 fails to properly restrict scope and permissions when self-signup is enabled with default CreateUserDir setting. Unauthenticated attackers can register accounts that inherit the server root scope with full create, modify, delete, rename, share, and download permissions, allowing unrestricted access to all files.
CVE-2026-75827	9.3	CRIT		0.008		Grav before 2.0.15 contains an arbitrary file write vulnerability in the Blueprint dynamic-data bare-function validation that uses an incomplete denylist instead of a positive allowlist. Attackers with page-edit or blueprint-config access can invoke the error_log function through a data directive to append PHP payloads to web-accessible files, achieving remote code execution.
CVE-2026-75828	9.3	CRIT		0.003		Grav before 2.0.15 contains a stored cross-site scripting vulnerability in the detectXss() function where unpaired quotes in unquoted attribute values bypass event-handler detection. Authenticated editors can inject event handlers like onerror= that pass validation and execute in visitor browsers when page content is rendered.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75832	9.3	CRIT		0.002		The Grav API plugin (getgrav/grav-plugin-api, bundled with Grav 2.0) before version 1.0.14 (fixed in 1.0.15) contains a missing authorization vulnerability in BlueprintPathResolver::resolveUserScope(). The method gates the users/<name> scope on the account's raw super-admin ACL flag (access.api.super) instead of validating the presented API key's actual scope. An attacker holding an API key scoped only to api.medi...
CVE-2026-75835	9.3	CRIT		0.002		Grav API plugin (getgrav/grav-plugin-api) before 1.0.14 contains a missing authorization vulnerability in userPassesAuthorize() (AbstractApiController.php). The function fails to consult the calling request's API key scopes, relying instead on the account's raw super-admin flag and ACL grants. As a result, an authenticated attacker holding a scoped API key minted on a privileged account can bypass their declared s...
CVE-2026-75837	9.3	CRIT		0.003		Grav before 2.0.14 fails to guard the access field in the core group blueprint with the required security@: admin.super restriction. A delegated admin.users operator can save a group with access[admin][super]=true to escalate to super-admin, gaining scheduler and Twig evaluation capabilities.
CVE-2026-75854	9.3	CRIT		0.011		ArcadeDB versions before 26.8.1 contain a missing authentication vulnerability in the Redis wire-protocol plugin that allows unauthenticated attackers to read, write, and delete data. Attackers can connect to the Redis port and execute arbitrary commands against any database on the server without providing credentials, bypassing all security gates.
CVE-2026-76200	9.3	CRIT		0.005	adobe:commerce, adobe:commerce_b2b, adobe:magento	Adobe Commerce is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session. Scope is changed.
CVE-2026-76201	9.3	CRIT		0.005	adobe:commerce, adobe:commerce_b2b, adobe:magento	Adobe Commerce is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session. Scope is changed.
CVE-2026-77089	9.3	CRIT		0.003	commvault:commvault	Command Center API contained an authentication bypass issue affecting privilege management. Software customers upgrade to resolved maintenance release. Update Command Center.
CVE-2026-77642	9.3	CRIT		0.002	torproject:tor	tor before 0.4.9.9 was prone to an out-of-bounds write when parsing a consensus or detached signature with unexpected signature digest type. Impact is minor for most Tor roles, but potentially major for directory authorities. This is TROVE-2026-019.
CVE-2026-78012	9.3	CRIT		0.005		An issue in the NetStaX EtherNet/IP Stack prior to v5.6.1 could allow a large Class 3 explicit-message request to exceed the application-side receive buffer without generating an error or warning. The result could be memory corruption, a device crash, or a potential remote attack vector without the originating device receiving a CIP error indicating that the request could not be processed.
CVE-2026-78997	9.3	CRIT		0.003		UC Browser for Android (package com.UCMobile.intl, version 13.7.8.1314) contains a Universal Cross-Site Scripting vulnerability that allows an attacker to execute arbitrary JavaScript in the context of any origin. An attacker hosts a specially crafted URL on a UC-owned domain (via a reflected XSS) that leverages the browser's internal JavaScript bridge to register a deferred callback, navigate the tab to a victim ...
CVE-2026-82526	9.3	CRIT		0.004		R2R through 3.6.6 contains a stacked SQL injection vulnerability that allows unauthenticated attackers to execute arbitrary SQL statements by manipulating the index name parameter in the vector index creation endpoint. The index name is interpolated directly into a CREATE INDEX statement via string formatting without identifier quoting or allowlist validation, enabling arbitrary DDL and DML execution through semic...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84479	9.3	CRIT		0.003		WWBN AVideo (current e01e41ecc and earlier) makes three login-time security controls depend solely on the client-supplied User-Agent header. The isAVideoEncoder()/isAVideoMobileApp() checks match HTTP_USER_AGENT against a hardcoded literal ("AVideoEncoder"/"AVideoMobileApp") with no IP check or shared secret. An attacker who submits valid credentials and sets User-Agent: AVideoEncoder bypasses two-factor authentic...
CVE-2026-84480	9.3	CRIT		0.003		WWBN AVideo fails to validate password recovery token expiration in userRecoverPassSave.json.php, allowing attackers to use expired tokens to reset account passwords indefinitely. Attackers who obtain a recovery token can use it at any time to change the target account's password and gain full account access.
CVE-2026-84695	9.3	CRIT		0.003		BookStack before 26.05.4 contains a stored cross-site scripting vulnerability in the drawing upload endpoint that accepts unvalidated base64 content and stores it without content inspection. Attackers with editor permissions can upload SVG files containing scripts that execute in administrator browsers when accessed through the image gallery API without content-type validation or CSP headers.
CVE-2026-85146	9.3	CRIT		0.004		SmartIT Desktop Manager developed by Lightstar has a Use of Hard-coded Credentials vulnerability. Unauthenticated remote attackers can obtain the SSH service account credentials and passwords for the SmartIT Agent directly from the application source code.
CVE-2026-85148	9.3	CRIT		0.004		SmartIT Desktop Manager developed by Lightstar has a Use of Hard-coded Credentials vulnerability. Unauthenticated remote attackers can exploit a fixed password to remotely access user hosts.
CVE-2026-85154	9.3	CRIT		0.003		WWBN AVideo contains an authentication failure vulnerability where the video_id_hash credential is a non-expiring, non-revocable bearer token that grants full administrator session access to the video owner's account. Attackers who obtain a video_id_hash can replay it indefinitely to authenticate as the video owner with full privileges, and the credential remains valid even after the owner changes their password.
CVE-2026-85424	9.3	CRIT		0.005		MOOS core-moos through 10.4.0 lacks authentication in the wire protocol, allowing unauthenticated clients to connect with full publish, subscribe, and database clear privileges. Attackers can bypass the compile-time protocol string check and connect with arbitrary client names to execute privileged operations including DB_CLEAR which resets all variables and clears client mail queues.
CVE-2026-85425	9.3	CRIT		0.01		MOOS-IvP iSay through 24.8.1 contains a remote code execution vulnerability in the SAY_MOOS variable handler that passes unsanitized text to a shell command. Attackers can publish SAY_MOOS messages containing backticks or command substitution syntax to execute arbitrary commands as the iSay process user.
CVE-2026-85426	9.3	CRIT		0.006		MOOS-IvP uMemWatch through 24.8.1 constructs shell commands from attacker-chosen MOOS client names without sanitization. Attackers can inject shell metacharacters into client names to execute arbitrary commands as the uMemWatch process user through unquoted redirection targets in system calls.
CVE-2026-85434	9.3	CRIT		0.002		MOOS-IvP uFldShoreBroker through 24.8.1 fails to verify node ping authenticity before creating outbound bridge routes. Attackers can publish NODE_BROKER_PING messages with crafted HostRecord data to redirect bridged variables to attacker-controlled addresses.
CVE-2026-85435	9.3	CRIT		0.002		MOOS-IvP uFldNodeBroker through 24.8.1 fails to validate the source of TRY_SHORE_HOST messages on the vehicle bus, allowing any publisher to enroll attacker-controlled shore routes. Attackers can publish malicious shore route messages to receive bridged vehicle traffic including sensor data and control information.
CVE-2026-85437	9.3	CRIT		0.007		MOOS-IvP through 24.8.1 contains multiple buffer overflow vulnerabilities in IvP function string decoders that trust attacker-controlled length fields without validation. Attackers can craft malicious encoded strings with mismatched declared and actual field lengths to overflow heap and stack buffers, potentially achieving remote code execution through MOOS variables or alog files.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85440	9.3	CRIT		0.006		MOOS core-moos through 10.4.0 contains a pre-authentication heap overflow vulnerability in MOOSCommPkt packet handling that allows remote attackers to write arbitrary data by declaring a negative packet length. Attackers can exploit the signed integer check in InflateTo() and negative size conversion in recv() to overflow a four-byte heap buffer during the HandShake phase before authentication.
CVE-2026-85602	9.3	CRIT		0.003		The Grav Form plugin (getgrav/grav-plugin-form) versions 8.0.6 through 9.1.19 select the reCAPTCHA version to validate based solely on which response field key is present in the submitted payload. On a site configured for reCAPTCHA v3, an anonymous attacker can place their v3 token under the v2 field name (g-recaptcha-response instead of token), causing validation to use the v2 branch, which never applies the scor...
CVE-2026-85672	9.3	CRIT		0.015		zerox 1.1.20 contains an OS command injection vulnerability in the file download mechanism where the temporary file extension derived from document URLs is interpolated unsanitized into shell commands executed by poppler utilities. Attackers can craft document URLs with malicious file extensions containing command substitution syntax to execute arbitrary OS commands before document processing occurs.
CVE-2026-86121	9.3	CRIT		0.006		Cua computer-server versions before 0.3.42 skip authentication when the CONTAINER_NAME environment variable is unset and bind to all interfaces by default, allowing unauthenticated attackers to execute arbitrary commands. Attackers can reach TCP port 8000 to run shell commands via the run_command endpoint, read and write arbitrary files through file operation endpoints, and access interactive PTY shells without au...
CVE-2026-86184	9.3	CRIT		0.006		Lara Dashboard before 1.3.0 contains an authentication bypass vulnerability in the screenshot-login route that allows unauthenticated attackers to authenticate as any user by email when APP_ENV is not production. Attackers can request the GET /screenshot-login/{email} endpoint with a registered email address to receive a fully authenticated session, enabling access to user administration, settings, database conten...
CVE-2026-86189	9.3	CRIT		0.004		WWBN AVideo contains a path traversal vulnerability in notify.ffmpeg.json.php that allows unauthenticated attackers to write files to arbitrary locations by supplying a caller-chosen path in the avideoRelativePath parameter. Attackers can replay any previously issued ciphertext as a notifyCode token, which is decrypted but never validated, to bypass authentication and write files to the application root and subdir...
CVE-2026-86190	9.3	CRIT		0.003		WWBN AVideo contains a broken access control vulnerability in videoViewsInfo endpoints that returns complete user records including password hashes, recovery tokens, and live session identifiers to unauthenticated callers when a hash parameter is provided. Attackers can use the disclosed session identifier to hijack viewer sessions, including administrator accounts, and obtain sensitive personal data for all video...
CVE-2026-86296	9.3	CRIT		0.013		A vulnerability was determined in D-Link DIR-822A A_101. This vulnerability affects the function strcpy of the file udhpcd/serverpacket.c of the component udhpcd. This manipulation causes stack-based buffer overflow. The attack is possible to be carried out remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-86738	9.3	CRIT		0.003	snipeitapp:snipe-it	Snipe-IT versions before 8.7.0 contain a CSS injection vulnerability in the Custom CSS field due to incomplete sanitization that reverses HTML encoding on greater-than and double-quote characters. Superusers can plant malicious CSS payloads using @import and url() references to exfiltrate CSRF tokens from other superusers via attribute-selector rules, enabling account takeover.
CVE-2026-46713	9.2	CRIT		0.002		Misskey is an open source, federated social media platform. Versions 12.37.0 and later, but prior to 2026.5.4, contain a vulnerability in the JSON-LD signature validation and compaction process that allows spoofed activities to be accepted as valid. This issue has been fixed in version 2026.5.4.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-53790	9.2	CRIT		0.005		rsync before 3.5.0 contains multiple command and argument injection vulnerabilities that allow attackers to execute arbitrary commands by supplying malicious input through several code paths, including the RSYNC_CONNECT_PROG environment variable, daemon hooks, the rsync-ssl wrapper, and remote-shell command newline injection. Attackers can inject shell metacharacters or newline characters into unsanitized user-sup...
CVE-2026-66047	9.2	CRIT		0.005		ProfilePress (wp-user-avatar) WordPress plugin before 4.17.2 contains an unauthenticated remote code execution vulnerability that allows unauthenticated attackers to install and activate arbitrary plugins by brute-forcing a weak 32-bit connect token via the ppress_connect_process AJAX handler. Attackers can supply a caller-controlled URL through the file request parameter to trigger silent plugin installation and ...
CVE-2026-67367	9.2	CRIT		0.008		A vulnerability has been identified in SIMOVE Fleetmanager V3.1 (All versions < V3.1.13), SIMOVE Fleetmanager V3.2 (All versions < V3.2.4), SIMOVE Fleetmanager V3.3 (All versions < V3.3.2), SIMOVE Fleetmanager V4.0 (All versions < V4.0.1), SIPLANT V1.7 (All versions), SIPLANT V2.2 (All versions), SIPLANT V3.0 (All versions), SIPLANT V3.1 (All versions < V3.1.4). Affected devices do not properly validate and neutra...
CVE-2026-70460	9.2	CRIT		0.004		rsync 2.3.3 before 3.5.0 contains a path traversal vulnerability that allows a malicious sender to escape the module root by exploiting symlinks within the module file tree when using --partial-dir or --backup-dir options. Attackers with write access to place a symlink under the module root, or who can exploit a pre-existing trusted symlink, can direct file writes to locations outside the intended module root, ach...
CVE-2026-72836	9.2	CRIT		0.004		FileBrowser before 2.63.19 does not account for case-insensitive filesystems when checking home directory ownership during self-registration. When Signup and CreateUserDir are enabled and FileBrowser's root is on a case-insensitive filesystem (confirmed on Windows/NTFS), two self-registered usernames that differ only in letter case (e.g., CaseVictim and casevictim) are stored as distinct accounts but resolve to th...
CVE-2026-75856	9.2	CRIT		0.005		CodeWhale before 0.8.64 contains a server-side request forgery bypass vulnerability in DNS pinning logic that fails to prevent time-of-check-time-of-use attacks. Attackers can manipulate DNS responses to fail initial resolution checks and succeed on secondary requests, allowing requests to internal IP addresses and bypassing SSRF mitigations.
CVE-2026-82067	9.2	CRIT		0.003	mongodb:mongodb	Improper handling of case sensitivity in the configuration validation component of MongoDB Server may cause the authorization subsystem to remain in a default disabled state during server startup. An unauthenticated user with network access to a deployment where this condition occurs can perform arbitrary administrative operations, resulting in full impact of data confidentiality, integrity, and availability.
CVE-2026-84189	9.2	CRIT		0.003		LibreNMS through 26.4.0 renders JSON fields (name, ip, model, author, commit message) returned by the admin-configurable Oxidized integration URL (oxidized.url) into the device showconfig page without applying htmlspecialchars(). An administrator who points the Oxidized URL at an attacker-controlled server (SSRF) can cause it to return malicious JSON, resulting in stored/persistent cross-site scripting affecting a...
CVE-2026-84197	9.2	CRIT		0.002		In Eclipse Ditto's Node.js JavaScript client, all released versions of @eclipse-ditto/ditto-javascript-client-node from 2.0.0 to 3.9.0 and of its predecessor package @eclipse-ditto/ditto-javascript-client-node_1.0 from 1.0.0 to 2.1.0, the WebSocket transport hard-codes rejectUnauthorized: false when creating the underlying ws WebSocket. Certificate chain and hostname validation are therefore disabled for every wss...
CVE-2026-85427	9.2	CRIT		0.004		MOOS essential-moos pAntler through 10.0.1 contains a remote code execution vulnerability that allows unauthenticated attackers to execute arbitrary programs by publishing a crafted MISSION_FILE message to the MOOSDB. Attackers can publish a mission file containing malicious Run entries that pAntler parses and executes via execvp() without authentication validation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85614	9.2	CRIT		0.002		OpenPanel before 2.3.0 contains an unauthenticated server-side request forgery vulnerability in the GET /tools/site-checker endpoint that accepts a fully client-controlled URL parameter with no private IP filtering or DNS-rebinding protection. Attackers can make the OpenPanel server issue requests to internal services, localhost, and cloud metadata endpoints, reading internal HTTP response titles, headers, status ...
CVE-2026-86426	9.2	CRIT		0.014		LibreNMS before 26.8.0 contains an authentication bypass vulnerability in the REST API that allows unauthenticated attackers to access protected endpoints by sending numeric values instead of string tokens. Attackers can exploit MySQL type coercion by sending small integers like 0 through 9 to match token hashes, gaining access to API functionality including device credentials and administrative features that enab...
CVE-2026-9317	9.2	CRIT		0.007		Nango before 0.71.6 contains a missing authentication vulnerability in the runner tRPC server that allows unauthenticated attackers to execute arbitrary JavaScript code by invoking the exposed start procedure without credentials. Attackers with network access to the runner port can send requests to the unauthenticated start procedure, bypassing the unenforced RUNNER_SECRET_KEY environment variable, to achieve remo...
CVE-2022-4993	9.1	CRIT		0.005		HTML::FormHandler versions before 0.410000 for Perl allow attacker selected method dispatch and resource exhaustion because _apply_actions and add_error use error message text built from request data as a Locale::Maketext bracket notation template. add_error hands its first argument to the language handle as the Locale::Maketext message key, and the default handle's lexicon sets ` _AUTO`, so a string that is not a...
CVE-2025-70146	9.1	CRIT		0.006	projectworlds:online_time_table_generator	Missing authentication in multiple administrative action scripts under /admin/ in ProjectWorlds Online Time Table Generator 1.0 allows remote attackers to perform unauthorized administrative operations (e.g., adding records, deleting records) via direct HTTP requests to affected endpoints without a valid session.
CVE-2026-10059	9.1	CRIT		0.003		A flaw was found in the Multicluster Engine for Kubernetes ClusterCurator controller. A tenant administrator with namespace-scoped privileges can exploit this vulnerability by creating a namespaced ClusterCurator. This action inadvertently grants the tenant administrator the ability to mint a token for a ServiceAccount with cluster-wide administrative authority. This leads to a privilege escalation, allowing the t...
CVE-2026-13221	9.1	CRIT		0.004	perl:perl	Perl versions before 5.40.5-RC1, from 5.41.0 before 5.42.3-RC1, from 5.43.0 before 5.43.10 produce silently incorrect regular expression matches when an alternation of more than 65535 fixed string branches is compiled into a trie in Perl_study_chunk. When such branches are combined into a trie, the delta between the first branch and the shared tail is stored in a 16-bit field. A branch count above 65535 overflows...
CVE-2026-16503	9.1	CRIT		0.003		Deployment of the VPS.org one-click Supabase template deploys a PostgreSQL instance that is published on all interfaces (0.0.0.0:5432) with a default database password set to "postgres". Because Docker installs its own iptables rules, this exposure bypasses a standard host UFW configuration.
CVE-2026-17057	9.1	CRIT		0.004	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to cause a denial of service and affect data integrity due to missing authentication for critical functions.
CVE-2026-17207	9.1	CRIT		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to cause a denial of service and compromise integrity due to a buffer overflow.
CVE-2026-18412	9.1	CRIT		0.004		OpenCart extensions are uploaded as zip files with .ocmod.zip extensions. Upon installation, the OpenCart v4.2.0.0 extension installer extracts these zip files, but does not validate that the extracted paths stay inside the intended extraction directory. An attacker can craft a malicious extension containing file path traversal sequences, such as ../. With this vulnerability, an attacker can write files, such as a...
CVE-2026-18963	9.1	CRIT		0.032		A flaw was found in the reset-credentials flow of the keycloak-services component, which is the core engine for identity and access management in Red Hat Build of Keycloak. The issue allows an unauthenticated attacker to force the password reset process for any user without needing to click the required email verification link. This can result in the attacker gaining full control over target user accounts by direc...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19874	9.1	CRIT		0.007		A heap-based buffer overflow vulnerability exists in Konami's Metal Gear Online 3, originating from improper validation of lobby data fields related to kicked players. The affected function processes a list of kicked player identifiers using the lobby data key "kick_num" to determine the number of entries, and individual kicked player IDs supplied via keys in the format "kicked_id_%i". The function does not valida...
CVE-2026-27690	9.1	CRIT		0.007	sap:approuter	Due to an HTTP Request Smuggling vulnerability in SAP Approuter, an unauthenticated attacker could send a specially crafted HTTP request that leads to request-response desynchronization. This could result in the exposure of user responses and cause the system to become unavailable. This leads to a high impact on confidentiality and availability.
CVE-2026-43071	9.1	CRIT		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: dcache: Limit the minimal number of bucket to two There is an OOB read problem on dentry_hashtable when user sets 'dhash_entries=1': BUG: unable to handle page fault for address: ffff888b30b774b0 #PF: supervisor read access in kernel mode #PF: error_code(0x0000) - not-present page Oops: Oops: 0000 [#1] SMP PTI RIP: 0010: __d_lookup+0x56...
CVE-2026-45100	9.1	CRIT		0.007		OpenSIPS is a Session Initiation Protocol (SIP) server implementation. Versions 3.4.0-beta through 3.6.5 and 4.0.0-beta contain a buffer overflow in the {s.b64encode} string transformation. The size check for {s.b64encode} only verifies that the input fits within the 64 KB transformation buffer, but base64 encoding expands the data by roughly a third, so an input between about 49,153 and 65,535 bytes produces more...
CVE-2026-45537	9.1	CRIT		0.004		OpenSIPS is a Session Initiation Protocol (SIP) server implementation. In versions prior to 3.6.6 and 4.0.0-rc1, the construct_uri() function concatenates multiple URI components (protocol, username, domain, port, params) into a fixed 1024-byte global BSS buffer without any bounds checking. When a routing script calls construct_uri() with an attacker-controlled username, a combined component length exceeding 1024 ...
CVE-2026-50152	9.1	CRIT		0.002		Ceph is an open-source distributed storage platform providing object, block, and file storage. In versions prior to 20.2.4 and 19.2.6, the Monitor subscription handler fails to properly authorize access to the configuration-key store, allowing any CephX user with only `mon allow r` capabilities to read the entire store by sending a single crafted MMonSubscribe message. The config-key store holds sensitive secrets...
CVE-2026-52723	9.1	CRIT		0.002		ePA 3.x Integration implements the authorization workflow and writes Medical Information Objects to Germany's electronic patient record. Prior to 1.3.0, ePA 3.x Integration performs VAU server certificate validation in app/vau/VAUProtokoll.py without anchoring the signed_vau_server_pub_keys and AUT_VAU_CertData certificate path to independent trusted material. A network-positioned attacker between the DiGA backend...
CVE-2026-52999	9.1	CRIT		0.006	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nfnetlink_osf: fix out-of-bounds read on option matching In nf_osf_match(), the nf_osf_hdr_ctx structure is initialized once and passed by reference to nf_osf_match_one() for each fingerprint checked. During TCP option parsing, nf_osf_match_one() advances the shared ctx->optp pointer. If a fingerprint perfectly matches, the function ...
CVE-2026-53793	9.1	CRIT		0.004		rsync before 3.5.0 contains a path confinement bypass vulnerability that allows remote clients to escape the intended inner-module root confinement by constructing paths that resolve outside the chroot boundary when the module root contains a ../ boundary marker. Attackers can exploit improper handling of the ../ notation or forge delta-basis transfers referencing xname paths that cross the ../ boundary to gain un...
CVE-2026-55511	9.1	CRIT		0.007		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs allows a user with SystemPrivilege.ControlArchiving to create a double-quoted StreamSQL column name that is interpolated into generated Java source by Expression.fillCode_InputDefVars and Expression.sanitizeName. A sum aggregate reaches yamcs-core/src/main/java/org/yamcs/yarch/streamsql/CompilableAggregateExpression.java and yamcs-core/src/mai...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55953	9.1	CRIT		0.002	erlang:erlangVotp, erlang:erlangVssl	The Erlang/OTP ssl TLS 1.2 (and earlier) and DTLS client does not verify that the cipher suite selected by the server in ServerHello was among the suites offered by the client in ClientHello. The client-side tls_handshake:hello/5 handler validates the negotiated protocol version and the downgrade sentinel but hands the server-chosen suite directly to ssl_handshake:handle_server_hello_extensions/9, which installs i...
CVE-2026-62646	9.1	CRIT		0.003		A vulnerability has been identified in Reyrolle 7SR5 (All versions < V2.70). A session identifier is generated using an algorithm with insufficient randomness, resulting in a token with low entropy that can be predicted or brute-forced within a feasible number of attempts. This could allow an unauthenticated remote attacker to derive valid session identifiers and bypass authentication.
CVE-2026-69641	9.1	CRIT		0.008		Missing authorization in Microsoft Exchange Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-70452	9.1	CRIT		0.005		rsync 3.1.0 before 3.5.0 contains an access control bypass vulnerability that allows remote attackers to circumvent hosts deny rules by inducing DNS resolution failures during hostname-based access control evaluation. When a DNS lookup for a hostname-based deny rule fails, the daemon skips the rule rather than defaulting to a deny decision, enabling attackers who can trigger DNS failures to bypass module-level IP ...
CVE-2026-73309	9.1	CRIT		0.005	xenforo:xenforo	XenForo before 2.3.13 contains an authentication bypass vulnerability in the OAuth2 token endpoint that allows unauthenticated attackers to obtain valid token pairs by submitting empty values for client_secret and code_verifier parameters. Attackers can exploit PHP truthy evaluation logic, which treats empty strings as false and skips client secret validation and PKCE code verifier validation, to exchange a valid ...
CVE-2026-73311	9.1	CRIT		0.004	xenforo:xenforo	XenForo before 2.3.13 contains an OAuth2 authorization code reuse vulnerability that allows attackers to obtain unauthorized token pairs by submitting a previously used authorization code. Attackers can exploit the failure to invalidate or mark authorization codes as consumed after initial token issuance to receive an independent token pair for the same user and scopes, bypassing the single-use guarantee of the OA...
CVE-2026-73312	9.1	CRIT		0.004	xenforo:xenforo	XenForo before 2.3.13 contains a refresh token replay vulnerability that allows attackers to reuse a refresh token multiple times by exploiting the failure to mark tokens as consumed when the parent access token has expired. Attackers can repeatedly submit the same refresh token to generate additional independent token pairs, achieving persistent unauthorized access for the token's full lifetime.
CVE-2026-73475	9.1	CRIT		0.002	centarro:commerce_paypal	Incorrect Authorization vulnerability in Drupal Commerce PayPal allows Forceful Browsing. This issue affects Commerce PayPal versions: from 0.0.0 to 1.12.0, from 2.0.0 to 2.1.3.
CVE-2026-75156	9.1	CRIT		0.002		Apache Airflow FAB provider versions 3.7.3 through 3.8.0 do not validate the issuer or audience of Azure AD `id_token`s during OAuth login. Deployments are affected only when the FAB auth manager is configured with Azure AD as an OAuth provider. Because the signing keys are fetched from Microsoft's **multi-tenant** JWKS endpoint, an `id_token` minted in *any* Azure tenant — including one the attacker creates — pas...
CVE-2026-75160	9.1	CRIT		0.004		An issue in X-Serie Gateway Firmware V6_00_05 allows a remote attacker to escalate privileges via the endpoints /cgi-bin/wwwugw.cgi and /cgi-bin/ugwdownload.cgi.
CVE-2026-75431	9.1	CRIT		0.008		PowerJob Server version 5.1.2 (and likely earlier) uses a predictable JWT signing key for HS256-based authentication. This allows a remote attacker to execute arbitrary code.
CVE-2026-75746	9.1	CRIT		0.011		ColdFusion is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker with high privileges could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78327	9.1	CRIT		0.016		An Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in the SonicWall Network Security Manager (NSM) On-Prem Management interface allows an authenticated attacker with SuperAdmin privileges to inject arbitrary commands that are executed on the underlying host, resulting in remote code execution.
CVE-2026-78328	9.1	CRIT		0.005		A missing authorization vulnerability in the SonicWall Network Security Manager (NSM) On-Prem Management interface allows a lower-privileged Admin user to escalate privileges to SuperAdmin.
CVE-2026-79571	9.1	CRIT		0.003		Incorrect access control in the SellerAuthorizeAspect component of springboot-project v1.0.0 allows unauthenticated attackers to access all seller management interfaces and list all products/orders, put products on/off sale, finish/cancel orders, and modify categories without authentication.
CVE-2026-80181	9.1	CRIT		0.004		Apache Allura's webhooks are vulnerable to Server-Side Request Forgery (SSRF). This issue affects Apache Allura: through 1.20.0. Users are recommended to upgrade to version 1.21.0, which fixes the issue.
CVE-2026-81939	9.1	CRIT		0.007		A Zip Slip vulnerability in the SonicWall Network Security Manager (NSM) On-Prem file upload and archive processing functionality allows an attacker to extract files outside the intended destination directory using a specially crafted archive.
CVE-2026-85043	9.1	CRIT		0.003	google:chrome	Incomplete cleanup in Network in Google Chrome prior to 152.0.7977.82 allowed a remote attacker to bypass system access restrictions via crafted network traffic. (Chromium security severity: High)
CVE-2026-86729	9.1	CRIT		0.002		WWBN AVideo through commit e01e41ecc (no patched version available) exposes get_api_preauthorize in plugin/API/API.php as a second, undocumented login path. Unlike get_api_signIn, which enforces a rate limit of 10 attempts per 5 minutes via checkRateLimit(), get_api_preauthorize performs the same credential check with no throttling for any client, allowing unlimited remote password guessing against arbitrary accou...
CVE-2026-86840	9.1	CRIT		0.002		The `vtoken-minting` and `slpx` pallets in Bifrost contain an improper authorization vulnerability in channel commission attribution. A signed account can supply an arbitrary registered `channel_id` when minting tokens without verifying that the caller is authorized to mint on behalf of that channel. This allows an attacker to inflate a channel's recorded mint volume and cause protocol commission payments to be di...
CVE-2025-54603	9.0	CRIT		0.007		An incorrect OIDC authentication flow in Claroty Secure Access 3.3.0 through 4.0.2 can result in unauthorized user creation or impersonation of existing OIDC users.
CVE-2026-10090	9.0	CRIT		0.004		A flaw was found in the Application Subscription controller (multiclust-operators-subscription) of Red Hat Advanced Cluster Management for Kubernetes (ACM). A user with namespace-scoped "edit" privileges in an ACM hub namespace can create a Channel resource pointing to a Helm repository they control and a Subscription resource referencing it. The app-subscription controller fetches and applies the Helm chart con...
CVE-2026-53581	9.0	CRIT		0.003		OPNsense is a FreeBSD based firewall and routing platform. Prior to version 26.1.9 of opnsense/core and version 26.4_20 of BE/opnsense/core, a path traversal vulnerability in the NTP configuration module allows an attacker to overwrite arbitrary files on the system as the root user. By manipulating the GPS or PPS serial port parameter, an attacker with access to the NTP configuration can escape the intended direct...
CVE-2026-62988	9.0	CRIT		0.007		Froxlor is open source server administration software. From 2.3.7 until 2.3.8, the Customers.get, Customers.listing, Admins.get, Admins.listing, Ftps.get, and Ftps.listing API commands in lib/Froxlor/Api/Commands/Customer.php, lib/Froxlor/Api/Commands/Admins.php, and lib/Froxlor/Api/Commands/Ftps.php retrieve full database rows and return them without removing password and data_2fa fields. An authenticated API ca...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-66768	9.0	CRIT		0.003		SAP GUI for Java does not correctly enforce the trust level policy for certain functions invoked from a connected backend system. A low-privileged attacker could exploit this weakness by manipulating a connected backend system to trigger affected functionality. This could allow arbitrary command execution on the victim's machine, leading to a high impact on the confidentiality, integrity, and availability of the a...
CVE-2026-69854	9.0	CRIT		0.006		Improper authentication in Spring Cloud Azure allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-73302	9.0	CRIT		0.004		Budibase is an open-source low-code platform. Prior to 3.39.30, the OIDC flow in packages/backend-core/src/middleware/passport/sso/oidc.ts resolved an email without getEmailVerified or an email_verified requirement, and packages/backend-core/src/middleware/passport/sso/sso.ts then used users.getGlobalUserByEmail as a fallback account-linking key. An attacker who can authenticate through a configured identity provi...
CVE-2026-73407	9.0	CRIT		0.005		Budibase is an open-source low-code platform. Prior to 3.40.1, RestIntegration._req in packages/server/src/integrations/rest.ts attached credentials from getAuthHeaders and defaultHeaders without requiring the final request destination to match the datasource origin. An unauthenticated caller of a PUBLIC POST /api/v2/queries/:queryId query could supply an absolute or parameterized path to an attacker-controlled ho...
CVE-2026-73842	9.0	CRIT		0.002		OpenChoreo is a complete, open-source developer platform for Kubernetes. Prior to 1.0.3, 1.1.3, and 1.2.0-rc.2, internal/cluster-gateway/server.go exposed /api/proxy/, /api/exec/, and /api/wirelogs/ on an internal listener without requiring a client certificate or token, allowing any network-reachable caller to read tenant Kubernetes Secrets, mutate workloads, and execute commands across connected data planes. Thi...
CVE-2026-82021	9.0	CRIT		0.002		Hermes Agent 0.18.2 prior to 0.19.0 contains a supply chain vulnerability in its bundled MCP catalog that allows a remote attacker to execute arbitrary code by compromising a third-party upstream repository referenced via a mutable branch rather than a pinned commit SHA. An attacker who compromises the upstream repository can propagate malicious code to every host that installs the affected catalog entry, with no ...
CVE-2026-85982	9.0	CRIT		0.002		The Auth0 AD/LDAP Connector is vulnerable to stored Cross-Site Scripting (XSS) issues due to improper HTML encoding of data in search results and updater log content displayed in the admin panel. An authenticated user with privileges to modify directory attributes, or a low-privileged local user on the host where the connector is installed, could insert script content. This script content could then execute in an ...

Watchlist matches (other priorities)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-30156	8.9	HIGH		0.001		Ceph is an open-source distributed storage platform providing object, block, and file storage. In versions prior to 20.2.4 and 19.2.6, the CephX authentication protocol encrypts tickets with AES-128-CBC in an unauthenticated mode that uses a hard-coded initialization vector and no message authentication, allowing an attacker to forge credentials and gain cluster-wide access. Because the ciphertext is malleable and...
CVE-2026-16745	8.8	HIGH		0.005		A flaw was found in odh-dashboard, the web console component of Red Hat OpenShift AI (RHOAI). Due to incorrect network binding, a malicious actor within the cluster can bypass authentication and impersonate any user by providing an arbitrary access token. This allows an attacker to gain unauthorized access to the Kubernetes API, potentially leading to arbitrary code execution, privilege escalation, or information ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-18341	8.8	HIGH		0.002	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to corrupt memory due to an integer underflow.
CVE-2026-18617	8.8	HIGH		0.005		A flaw was found in the Data Science Pipelines Operator (DSPO). A namespace editor can exploit a vulnerability in the spec.database.customExtraParams field, which allows for the injection of dangerous parameters into the MySQL Data Source Name (DSN) string. By manipulating these parameters, an attacker can enable LOCAL INFILE functionality and exfiltrate sensitive files, such as the service account token, from the...
CVE-2026-28666	8.8	HIGH		0.003		In multiple functions of LocalImageResolver.java, there is a possible Remote Persistent Denial of Service due to a DNG image rendering check bypass. This could lead to remote escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-39944	8.8	HIGH		0.002		Ceph is an open-source distributed storage platform providing object, block, and file storage. In versions prior to 20.2.4 and 19.2.6, the RADOS Gateway (RGW) protects STS session tokens with an AES-128-CBC handler that provides no message authentication, allowing an attacker who holds any valid STS token to tamper with it undetected and escalate to full RGW administrative access. Because the ciphertext is unauth...
CVE-2026-51974	8.8	HIGH		0.004		An eval() injection vulnerability in the get_list function in modules/meta_parser.py in llyasviel Fooocus 2.1.854 through 2.5.5 allows remote attackers to execute arbitrary Python code via a crafted styles payload in the EXIF metadata of an uploaded image file.
CVE-2026-52691	8.8	HIGH		0.003		** UNSUPPORTED WHEN ASSIGNED ** Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Apache Griffin Hive Metastore Module. This issue affects Apache Griffin Hive Metastore Module: all versions. As this project is retired, we do not plan to release a version that fixes this issue. Users are recommended to find an alternative or restrict access to the instance ...
CVE-2026-53275	8.8	HIGH		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ipv6: mcast: Fix use-after-free when processing MLD queries When processing an MLD query, a pointer to the multicast group address is retrieved when initially parsing the packet. This pointer is later dereferenced without being reloaded despite the fact that the skb header might have been reallocated following the pskb_may_pull() calls, leading ...
CVE-2026-55521	8.8	HIGH		0.004		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs omits authorization checks in IndexesApi.listPacketIndex, IndexesApi.listEventIndex, Cop1Api.disable, Cop1Api.resume, Cop1Api.initialize, Cop1Api.updateConfig, and TimeApi.setTime. An authenticated low-privilege user can read packet and event index metadata without ObjectPrivilegeType.ReadPacket, alter COP-1 link state without SystemPrivilege....
CVE-2026-62706	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-62744	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-62895	8.8	HIGH		0.007		Permissive cross-domain policy with untrusted domains in Azure Arc allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-65772	8.8	HIGH		0.009		Deserialization of untrusted data in Microsoft Dynamics 365 allows an authorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-66814	8.8	HIGH		0.004	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Insufficient granularity of access control in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-66818	8.8	HIGH		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper privilege management in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-66819	8.8	HIGH		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper neutralization of special elements used in an sql command ('sql injection') in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-66820	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper neutralization of special elements used in an sql command ('sql injection') in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-67368	8.8	HIGH		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper link resolution before file access ('link following') in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-67370	8.8	HIGH		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper neutralization of special elements used in an sql command ('sql injection') in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-67373	8.8	HIGH		0.006	microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67380	8.8	HIGH		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67381	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-67384	8.8	HIGH		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Integer overflow or wraparound in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67385	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Use after free in SQL Server allows an authorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67388	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67631	8.8	HIGH		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67638	8.8	HIGH		0.007	microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67639	8.8	HIGH		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67642	8.8	HIGH		0.005	microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67643	8.8	HIGH		0.008	microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-68775	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-68786	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-69266	8.8	HIGH		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Integer overflow or wraparound in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-69268	8.8	HIGH		0.007	microsoft:sharepoint_server	Improper access control in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69273	8.8	HIGH		0.005	microsoft:sharepoint_server	Improper access control in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69282	8.8	HIGH		0.005	microsoft:sharepoint_server	Improper access control in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69285	8.8	HIGH		0.006	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69291	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-69334	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-69355	8.8	HIGH		0.008		External control of file name or path in Microsoft Exchange Server allows an authorized attacker to execute code over a network.
CVE-2026-69360	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69386	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-69434	8.8	HIGH		0.008		Heap-based buffer overflow in Windows URL Moniker allows an unauthorized attacker to execute code over a network.
CVE-2026-69439	8.8	HIGH		0.007		Heap-based buffer overflow in .NET and Visual Studio allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-69442	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-69461	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code over a network.
CVE-2026-69464	8.8	HIGH		0.009	microsoft:sharepoint_server	Execution with unnecessary privileges in Microsoft Office SharePoint allows an authorized attacker to elevate privileges over a network.
CVE-2026-69465	8.8	HIGH		0.008	microsoft:sharepoint_server	Missing authorization in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69494	8.8	HIGH		0.008		Out-of-bounds read in Windows Event Logging Service allows an unauthorized attacker to execute code over a network.
CVE-2026-69495	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Event Logging Service allows an unauthorized attacker to execute code over a network.
CVE-2026-69499	8.8	HIGH		0.008		Integer overflow or wraparound in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-69511	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69518	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Remote Desktop allows an unauthorized attacker to execute code over a network.
CVE-2026-69529	8.8	HIGH		0.005	microsoft:365_apps, microsoft:access, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:off	Heap-based buffer overflow in Microsoft Office Access allows an unauthorized attacker to execute code over a network.
CVE-2026-69547	8.8	HIGH		0.009		Heap-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code over a network.
CVE-2026-69551	8.8	HIGH		0.009		Use after free in Windows DNS allows an authorized attacker to execute code over a network.
CVE-2026-69556	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69598	8.8	HIGH		0.008		Incorrect calculation of buffer size in Windows iSCSI allows an unauthorized attacker to execute code over a network.
CVE-2026-69601	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-69603	8.8	HIGH		0.003		Heap-based buffer overflow in Windows Hyper-V allows an authorized attacker to execute code locally.
CVE-2026-69614	8.8	HIGH		0.009	microsoft:365_apps, microsoft:access, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Stack-based buffer overflow in Microsoft Office Access allows an unauthorized attacker to execute code over a network.
CVE-2026-69628	8.8	HIGH		0.009		Heap-based buffer overflow in Windows iSCSI allows an authorized attacker to execute code over a network.
CVE-2026-69629	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:outlook	Heap-based buffer overflow in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-69632	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Use after free in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-69649	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Raw Image Extension allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69669	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Kernel allows an unauthorized attacker to execute code over a network.
CVE-2026-69671	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69676	8.8	HIGH		0.012		Authentication bypass by capture-replay in Windows Kerberos allows an authorized attacker to execute code over a network.
CVE-2026-69678	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-69686	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69712	8.8	HIGH		0.009		Use after free in Windows Key Distribution Center allows an authorized attacker to execute code over a network.
CVE-2026-69716	8.8	HIGH		0.009	microsoft:sharepoint_server	Improper neutralization of special elements used in an sql command ('sql injection') in Microsoft Office SharePoint allows an authorized attacker to elevate privileges over a network.
CVE-2026-69722	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69724	8.8	HIGH		0.008	microsoft:sharepoint_server	Missing authorization in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69729	8.8	HIGH		0.009		Heap-based buffer overflow in Windows Credential Providers allows an authorized attacker to execute code over a network.
CVE-2026-69740	8.8	HIGH		0.003		Use after free in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69742	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:publisher	Integer overflow or wraparound in Microsoft Office Publisher allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69759	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69764	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsof	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69767	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-69772	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Network File System allows an unauthorized attacker to execute code over a network.
CVE-2026-69778	8.8	HIGH		0.008	microsoft:365_apps, microsoft:access, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:off	Heap-based buffer overflow in Microsoft Office Access allows an unauthorized attacker to execute code over a network.
CVE-2026-69784	8.8	HIGH		0.003		Use after free in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69797	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-69860	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-70178	8.8	HIGH		0.004	microsoft:fabric	Missing authorization in Microsoft Fabric allows an authorized attacker to elevate privileges over a network.
CVE-2026-70203	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Media Player allows an unauthorized attacker to execute code over a network.
CVE-2026-70351	8.8	HIGH		0.008		Integer overflow or wraparound in Microsoft WebP Image Extension allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70586	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Paint allows an unauthorized attacker to execute code over a network.
CVE-2026-71328	8.8	HIGH		0.006	microsoft:.net, microsoft:visual_studio_2022, microsoft:visual_studio_2026, microsoft:windows	Heap-based buffer overflow in Visual Studio allows an unauthorized attacker to execute code over a network.
CVE-2026-71336	8.8	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Integer overflow or wraparound in Windows Work Folder Service allows an authorized attacker to execute code over a network.
CVE-2026-71352	8.8	HIGH		0.007		Integer underflow (wrap or wraparound) in Windows Remote Access Connection Manager allows an authorized attacker to execute code over a network.
CVE-2026-72883	8.8	HIGH		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the WebSocket handlers in apps/dokploy/server/wss/terminal.ts, apps/dokploy/server/wss/docker-container-terminal.ts, apps/dokploy/server/wss/docker-container-logs.ts, and apps/dokploy/server/wss/docker-stats.ts validate organization membership but do not enforce checkServiceAccess, accessedServerIds, or accessedServices, allowing an a...
CVE-2026-72933	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft WDAC OLE DB provider for SQL allows an unauthorized attacker to execute code over a network.
CVE-2026-72940	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Schannel allows an unauthorized attacker to execute code over a network.
CVE-2026-72950	8.8	HIGH		0.009		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-72959	8.8	HIGH		0.009		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-72960	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Media Player allows an unauthorized attacker to execute code over a network.
CVE-2026-72972	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-72973	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73006	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-73012	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Management Services allows an authorized attacker to elevate privileges over a network.
CVE-2026-73013	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-73016	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-73023	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-73028	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper access control in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-73667	8.8	HIGH		0.006		OpenChoreo is a complete, open-source developer platform for Kubernetes. Prior to 1.0.4, 1.1.4, and 1.2.0-rc.2, OpenChoreo Workflow Plane templates under samples/getting-started/workflow-templates/ interpolated developer-controlled workflow parameters into shell program text executed through sh -c instead of passing the values through container.env, allowing arbitrary commands to run in workflow pods while affecte...
CVE-2026-73841	8.8	HIGH		0.005		OpenChoreo is a complete, open-source developer platform for Kubernetes. Prior to 1.1.6 and 1.2.3, internal/openchoreo-api/api/handlers/exec.go and internal/openchoreo-api/api/handlers/wirelogs.go authorize component:exec and wirelogs:view using the caller-supplied project query parameter instead of comp.Spec.Owner.ProjectName, allowing a user with a project-scoped grant to execute commands in and read wirelogs fr...
CVE-2026-77480	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Insufficient granularity of access control in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-77481	8.8	HIGH		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-77482	8.8	HIGH		0.008	microsoft:sql_server_2017, microsoft:sql_server_2019	Heap-based buffer overflow in SQL Server allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77483	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Weak authentication in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-77484	8.8	HIGH		0.011	microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Deserialization of untrusted data in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-77486	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019	Integer overflow or wraparound in SQL Server allows an unauthorized attacker to execute code over a network.
CVE-2026-77487	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper access control in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-77495	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-77504	8.8	HIGH		0.006		Double free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-77901	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Null pointer dereference in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-77906	8.8	HIGH		0.008	microsoft:visual_studio_2026	Heap-based buffer overflow in Visual Studio allows an unauthorized attacker to execute code over a network.
CVE-2026-77907	8.8	HIGH		0.005	microsoft:visual_studio_2026	Heap-based buffer overflow in Visual Studio allows an unauthorized attacker to execute code over a network.
CVE-2026-77908	8.8	HIGH		0.007		Improper control of generation of code ('code injection') in Microsoft Dynamics 365 allows an authorized attacker to execute code over a network.
CVE-2026-78439	8.8	HIGH		0.006		Stack-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-78442	8.8	HIGH		0.006		Heap-based buffer overflow in Windows OLE DB allows an unauthorized attacker to execute code over a network.
CVE-2026-78456	8.8	HIGH		0.009	microsoft:sql_server_2022	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-78462	8.8	HIGH		0.005	microsoft:visual_studio_code	Authorization bypass through user-controlled key in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78504	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78505	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-78507	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Use after free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78511	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78512	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Numeric truncation error in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78514	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78517	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78518	8.8	HIGH		0.009	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to execute code over a network.
CVE-2026-78519	8.8	HIGH		0.006	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:outlook	Use of uninitialized resource in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78521	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78524	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Out-of-bounds write in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-78525	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-78526	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-80080	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Double free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-80081	8.8	HIGH		0.005	microsoft:365_apps	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-80083	8.8	HIGH		0.002	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Untrusted pointer dereference in Windows Hyper-V allows an authorized attacker to execute code locally.
CVE-2026-80085	8.8	HIGH		0.005	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-80096	8.8	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Remote Desktop Services allows an authorized attacker to elevate privileges over a network.
CVE-2026-81352	8.8	HIGH		0.005		Heap-based buffer overflow in Microsoft Windows Codecs Library allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81385	8.8	HIGH		0.01	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:publisher	Deserialization of untrusted data in Microsoft Office Publisher allows an unauthorized attacker to execute code over a network.
CVE-2026-81952	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-81955	8.8	HIGH		0.006		Heap-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-81996	8.8	HIGH		0.001	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Incorrect Authorization vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-83941	8.8	HIGH		0.007	microsoft:entra_id	Missing authorization in Entra ID allows an authorized attacker to elevate privileges over a network.
CVE-2026-83992	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-83996	8.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-85877	8.8	HIGH		0.004	microsoft:windows_11_24h2	Heap-based buffer overflow in Windows Print Spooler Components allows an unauthorized attacker to execute code over a network.
CVE-2020-37267	8.7	HIGH		0.003		Renovate versions >=19.180.0 and <23.25.1, when used with Azure DevOps, may expose the bot's authorization token in server or pipeline logs because the git http.extraheader=AUTHORIZATION parameter is logged without redaction. Anyone with access to saved logs could obtain the bot credentials. Fixed in 23.25.1; Azure DevOps users should revoke and regenerate credentials if logs may have been exposed.
CVE-2022-50997	8.7	HIGH		0.005		Weaver (Fanwei) E-cology 8.0 and 9.0 contains a SQL injection vulnerability in the HrmCareerApplyPerView.jsp endpoint that allows unauthenticated remote attackers to extract arbitrary data from the backend database by manipulating the id GET parameter. Attackers can send a single crafted GET request with UNION-based injection payloads through the unsanitized id parameter to retrieve arbitrary data from the Microso...
CVE-2026-18608	8.7	HIGH		0.005		A flaw was found in the Data Science Pipelines Operator (DSPO). The operator's ClusterRole, which defines its permissions, includes extensive privileges beyond what is necessary for its operation. These excessive permissions, such as the ability to execute commands within pods and manage cluster-wide roles, could be exploited. If the DSPO pod were compromised, an attacker could leverage these privileges to gain fu...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-45115	8.7	HIGH		0.003		MyBB is free and open source forum software. Prior to 1.8.40, the Buddy/Ignore component does not sanitize usernames correctly, allowing attackers to perform JavaScript code injection through a specially crafted username. The User CP Buddy/Ignore list and the Select Buddies list in Private Messages pass usernames through htmlspecialchars_uni(), which may leave single quotes unescaped. The payload is triggered when...
CVE-2026-45116	8.7	HIGH		0.003		MyBB is free and open source forum software. Prior to 1.8.40, the user datahandler does not properly validate checkbox and multiselect profile field types, resulting in stored JavaScript code injection. UserDataHandler::verify_profile_fields() only performs the specialized validation when is_array(\$profile_fields[\$field]) is true. A non-array profile_fields[fidX] value instead of the expected profile_fields[fidX][...
CVE-2026-54347	8.7	HIGH		0.004		Froxlor is open source server administration software. Prior to 2.3.8, DNS TXT record content accepted by lib/Froxlor/Api/Commands/DomainZones.php can contain HTML special characters, lib/Froxlor/UI/Callbacks/Text.php returns the content from Text::wordwrap without HTML escaping, and templates/Froxlor/table/table.html.twig renders the callback result with the raw filter. An authenticated customer with DNS editor a...
CVE-2026-55250	8.7	HIGH		0.006		Marvel, a PHP framework oriented towards dependency injection, prior to version 10.74.0 has a high-severity Token Replay Vulnerability arising from a structural lifecycle mismatch between stateless token validation engines and high-performance relational caching layers. Any application with low cache memory that causes premature eviction to free up memory and applications running macropay-solutions/marvel-framew...
CVE-2026-68494	8.7	HIGH		0.004		The fix released in jackson-core 2.18.6 and 2.21.1 for CVE-2026-18401 (GHSA-72hv-8253-57qq, number length constraint bypass in the non-blocking parser) is incomplete. This record covers the remaining bypass. The earlier fix wired validateIntegerLength() into a new _setIntLength() helper and invoked it wherever the integer portion of a number is decided: a terminator byte arrives, a '.' or 'e'/'E' is seen, or inpu...
CVE-2026-72870	8.7	HIGH		0.003		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the buildRemoteDocker() function in packages/server/src/utis/providers/docker.ts interpolates the application-controlled dockerImage value directly into a docker pull shell command. An authenticated user with project access can set a crafted dockerImage through application.update and trigger application.deploy, causing execAsync() to...
CVE-2026-72884	8.7	HIGH		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, sanitizeCommand in packages/server/src/utis/builders/compose.ts only trims whitespace and strips surrounding quotes from compose.command before exportEnvCommand and docker command interpolation, allowing an authenticated user who can update a Compose service to inject shell metacharacters and execute arbitrary commands on the Dokploy...
CVE-2026-74787	8.7	HIGH		0.003		Scriban before 7.0.0 contains an uncontrolled recursion vulnerability in the object.to_json builtin function that lacks depth limits and circular reference detection. Attackers can craft templates with self-referencing objects to trigger unbounded recursion, causing a StackOverflowException that fatally terminates the hosting .NET process.
CVE-2026-75133	8.7	HIGH		0.003		Keep Backup Daily plugin for WordPress before 2.1.4 contains a sensitive information exposure vulnerability that allows unauthenticated attackers to trigger a full MySQL database dump by accessing the publicly exposed `kbd_cron_process` parameter without authentication. Attackers can predict the partially predictable dump filename based on the database name, a limited random range, and the current Unix timestamp t...
CVE-2026-75840	8.7	HIGH		0.004		ArcadeDB before 26.8.1 contains an arbitrary file read vulnerability in the GraalVM JavaScript sandbox allowlist enforcement, which uses unescaped regular expressions to validate package names. Attackers with trigger creation privileges can use Java.type() to access java.util.zip.ZipFile or java.util.jar.JarFile classes and read arbitrary files on the host system as the ArcadeDB server process.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75915	8.7	HIGH		0.006		CodeWhale versions before 0.8.64 contain an environment variable exposure vulnerability in the js_execution tool that fails to scrub parent process environment variables before spawning Node.js. Attackers can craft malicious JavaScript code executed by the tool to read process.env and leak API keys, cloud credentials, and authentication tokens back to the model context.
CVE-2026-76224	8.7	HIGH		0.006		ArcadeDB before 26.8.1 (arcadedb-gremlin, affected <= 26.7.3) contains a remote code execution vulnerability in its Gremlin query engine. Although the engine defaults to the documented-secure java (gremlin-lang) engine, ArcadeGremlin.executeStatement() silently falls back to the insecure Groovy engine whenever a request carries any query parameter and the query does not parse as gremlin-lang. An authenticated user...
CVE-2026-77101	8.7	HIGH		0.003	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a stack-based buffer overflow issue affecting service availability. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2026-77102	8.7	HIGH		0.003	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a heap-based buffer overflow issue affecting service availability. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2026-77103	8.7	HIGH		0.003	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained an authentication bypass issue affecting access authorization and information disclosure. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2026-77105	8.7	HIGH		0.002	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a cryptographic signature verification issue affecting privilege management. Software customers upgrade to resolved maintenance release. Update CommServe and Web Server.
CVE-2026-79707	8.7	HIGH		0.004		A Path Traversal vulnerability in the builder endpoint in Google Cloud Agent Development Kit (ADK) versions 1.9.0 through 1.21.0 on Python allows an unauthenticated remote attacker to read arbitrary files using a crafted file_path query parameter.
CVE-2026-82064	8.7	HIGH		0.003	mongodb:mongodb	A security issue in MongoDB Server allows an unauthenticated network user to cause a denial of service on a specific type of replica set member. The server contains an assertion in its read concern processing logic that can be reached without authentication, and the assertion's assumptions about internal state do not hold for all member configurations, causing the server process to terminate.
CVE-2026-82075	8.7	HIGH		0.003	mongodb:mongodb	An uncontrolled resource consumption weakness exists in the request-handling path of the MongoDB sharded-cluster router process. A client that has network access to a router port and has not authenticated can supply connection-monitoring parameters that cause the server to expend CPU resources without any rate limiting, degrading or denying service to legitimate clients. No authentication, elevated privileges, or ...
CVE-2026-83605	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.14 and 0.9.11, and in xmldom version 0.6.0 and earlier, Element.setAttribute() calls the private _createAttribute(name) path without validating the attribute name, while Document.createAttribute(name) validates against QName. XMLSerializer.serializeToString() emits attribut...
CVE-2026-83606	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.9.0-beta.9 until 0.9.11, the processing-instruction production in lib/grammar.js lets the greedy S+ separator and lazy Char*? data group repeatedly repartition a long whitespace tail when the required closing ?> is absent. Both parsePI and parseProcessingInstruction apply the expression to the entire re...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83607	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.14 and 0.9.11, and in xmldom version 0.6.0 and earlier, Document.createElement(tagName) stores an unvalidated element name and XMLSerializer.serializeToString() emits that name verbatim. The requireWellFormed: true path did not validate the element qualified name or synthes...
CVE-2026-83608	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom version 0.6.0 and earlier, the DOCUMENT_TYPE_NODE branch in lib/dom.js validates publicId, systemId, and internalSubset under requireWellFormed: true but emits DocumentType.name verbatim. A name containing > or whitespace can terminate the <!DOC...
CVE-2026-83609	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.9.0 until 0.9.12, the shared reg() builder in lib/grammar.js compiles the anchored QName_exact validator with the multiline flag, so ^ and \$ validate only one line instead of the complete name. createElementNS, createAttributeNS, createDocumentType, and createAttribute consequently accept a malformed XM...
CVE-2026-83612	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.9.0-beta.1 until 0.9.12, HTML-mode parsing through DOMParser.parseFromString() mishandles a mixed-case closing tag for the script, style, textarea, or title raw-text elements. parseHtmlSpecialContent, selected by isHTMLRawTextElement or isHTMLEscapableRawTextElement, uses a case-sensitive indexOf() and ...
CVE-2026-83613	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom version 0.6.0 and earlier, DOMHandler.startElement in lib/dom-parser.js inserts every parsed attribute through setAttributeNode, while NamedNodeMap.setNamedItem in lib/dom.js calls the linear getNamedItem or getNamedItemNS lookup for each insert...
CVE-2026-83614	8.7	HIGH		0.004		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom versions 0.3.0 through 0.6.0, two independent quadratic paths can cause denial of service. In lib/sax.js, parseElementStartPart repeatedly rescans a malformed tag name to the next > during single-character recovery; in lib/dom.js, normalize() re...
CVE-2026-83615	8.7	HIGH		0.004		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom versions 0.1.5 through 0.6.0, appendElement in lib/sax.js uses _copy to clone the complete currentNSMap for each nested element that declares a new namespace prefix. Keeping every ancestor map live on the parse stack creates quadratic peak names...
CVE-2026-83616	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom version 0.6.0 and earlier, Document.createProcessingInstruction(target, data) in lib/dom.js accepts an unvalidated target, while the requireWellFormed: true serializer checks only for a colon and the reserved case-insensitive xml name on 0.9.x a...
CVE-2026-83617	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.9.11 until 0.9.12, the requireWellFormed: true element and attribute name checks use the anchored QName_exact expression produced by reg() in lib/grammar.js, which inherits the multiline flag. A name with a valid first line followed by U+000A, U+000D, U+2028, or U+2029 and breakout markup therefore pass...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83618	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.9.10 until 0.9.12, the requireWellFormed: true serializer validates DocumentType.publicId and DocumentType.systemId with PubIdLiteral_match and SystemLiteral_match expressions produced by reg() in lib/grammar.js, which inherit the multiline flag. A complete valid literal on the first line can therefore ...
CVE-2026-83619	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.7.0 until 0.8.15, the release-0.8.x parser in lib/sax.js trims captured end-tag names with the unanchored global expression /[\t\n\r]+\$/g. For an end tag containing a long whitespace run followed by a non-whitespace character, the expression retries from each possible starting position and backtracks q...
CVE-2026-84202	8.7	HIGH		0.004		ModelScope uses PyYAML's unsafe yaml.Loader to parse model configuration files, allowing arbitrary code execution through Python object construction tags. Attackers can craft malicious model repositories with poisoned configuration files that execute code when loaded by users.
CVE-2026-85155	8.7	HIGH		0.003		WWBN AVideo contains a SQL injection vulnerability in the sort column parameter of the get.json.php endpoint with APIName=channels that allows unauthenticated attackers to order results by arbitrary database columns including users.password and users.recoverPass. Attackers can exploit this ordering oracle to infer password hash values and recovery tokens, and trigger SQL errors that disclose the full query stateme...
CVE-2026-85786	8.7	HIGH		0.003		Improper handling of highly compressed data in Amazon ion-java before 1.12.1 might allow remote attackers to cause a denial of service via a crafted compressed Ion document that expands to an arbitrarily large size upon decompression due to insufficient coverage of the GZIP auto-decompression opt-out introduced for CVE-2026-75936. To remediate this issue, users should upgrade to version 1.12.1.
CVE-2026-86076	8.7	HIGH		0.004	n8n:n8n	n8n is an open source workflow automation platform. Prior to 1.123.76, 2.37.7, and 2.38.2, the expression compiler sanitizer resolved through dynamically scoped this and did not reject reserved class member names. A class field named __sanitize could rebind the sanitizer and reach the Function constructor, enabling backend code execution and editor-preview JavaScript execution. The affected AST hook is PrototypeSa...
CVE-2026-67340	8.6	HIGH		0.006		ArcadeDB before 26.7.2 (arcadedb-engine) allows trigger scripts to look up host classes in java.lang.* (via Java.type) because ScriptTriggerExecutor adds java.lang.* to the allowed packages. An authenticated user with UPDATE_SCHEMA permission can create a JavaScript trigger that invokes java.lang.Runtime.getRuntime().exec() (or ProcessBuilder), achieving OS command execution when the trigger fires.
CVE-2026-74239	8.6	HIGH		0.007	xenforo:xenforo	XenForo before 2.3.13 contains a path traversal vulnerability in the style archive importer on Windows deployments that allows authenticated non-super administrators with style permissions to write arbitrary files outside the intended extraction directory by using backslash-based traversal sequences in ZIP member names. Attackers can craft a malicious ZIP archive with backslash path separators that bypass forward-...
CVE-2026-76199	8.6	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an Uncontrolled Search Path Element vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is changed.
CVE-2026-80097	8.6	HIGH		0.004		Improper authentication in Microsoft Authenticator allows an unauthorized attacker to elevate privileges locally.
CVE-2026-85388	8.6	HIGH		0.003		Worklenz through 3.0.0 fails to properly validate the sort-field query parameter in pagination helper functions, allowing authenticated users to inject arbitrary PostgreSQL expressions into ORDER BY clauses. Attackers can use time-based and boolean-based blind SQL injection techniques to extract sensitive database content including password hashes from other tenants. This is an incomplete fix for CVE-2026-25947.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86185	8.6	HIGH		0.001		Bilibili Desktop through 1.18.0 disables TLS certificate verification process-wide and executes unsigned remote JavaScript configuration without integrity checks. An attacker in an on-path network position can intercept configuration fetches, inject arbitrary JavaScript executed in the renderer with access to the privileged IPC bridge, and execute system commands or steal login credentials.
CVE-2026-86712	8.6	HIGH		0.004		SiYuan before 3.8.2 trusts the attacker-writable text/siyuan clipboard MIME type and skips sanitization in the paste handler, allowing code execution in the Node-enabled desktop renderer. Attackers can craft malicious web pages that write to the clipboard, and when pasted into SiYuan, injected scripts execute with full Node.js access through the Electron main process.
CVE-2026-86733	8.6	HIGH		0.003	snipeitapp:snipe-it	Snipe-IT before 8.7.0 streams the SQL entry from an uploaded backup archive directly into the MySQL/MariaDB command-line client ('mysql') without the --binary-mode flag, so the client interprets lines beginning with backslash commands such as '\!' as local shell commands. An authenticated superadministrator who uploads a crafted ZIP backup (POST /admin/backups/upload) and triggers a restore (POST /admin/backups/re...
CVE-2026-17107	8.5	HIGH		0.003		A flaw was found in the cluster-proxy service-proxy component used in Red Hat Advanced Cluster Management for Kubernetes (RHACM) and multicluster-engine (MCE). The service-proxy appends impersonation group headers to proxied requests without first removing caller-supplied values, and the spoke ServiceAccount holds unrestricted impersonation permissions. An authenticated hub principal can inject an Impersonate-Grou...
CVE-2026-45221	8.5	HIGH		0.001		Konga before 2.1.0 contains a privilege escalation vulnerability that allows low-privileged local attackers to execute arbitrary code by planting attacker-controlled OpenSSL configuration or library files in a hardcoded filesystem path absent from default installations. On Windows, the missing directory resides in a location writable by any authenticated local user, enabling attackers to create the directory and p...
CVE-2026-58113	8.5	HIGH		0.002		A vulnerability has been identified in Teamcenter V2412 (All versions < V2412.0013), Teamcenter V2506 (All versions < V2506.0010), Teamcenter V2512 (All versions < V2512.2607), Teamcenter V2606 (All versions < V2606.2607). Affected applications do not properly encode user-supplied input reflected into HTML attribute contexts within the authentication redirect flow (/auth/ endpoint). This could allow an unauthenti...
CVE-2026-62246	8.5	HIGH		0.003		Kamaji is the Hosted Control Plane Manager for Kubernetes. Prior to 26.7.4-edge, Kamaji derives a TenantControlPlane datastore schema, database user, and etcd key prefix from a lossy namespace-and-name normalization in GetDefaultDatastoreSchema() and GetDefaultDatastoreUsername(), allowing distinct tenants with colliding normalized identifiers to share control-plane state and read, modify, or destroy another tenan...
CVE-2026-65986	8.5	HIGH		0.002		CVAT is an open source interactive video and image annotation tool for computer vision. Versions 2.5.0 through 2.66.0 contain a XSS vulnerability that can be accessed through annotation guide assets. When CVAT serves the files attached to an annotation guide, it labels them with a media type (Content-Type) that the attacker can influence, so instead of treating an uploaded file as plain data, the victim's browse...
CVE-2026-67378	8.5	HIGH		0.005	microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Untrusted pointer dereference in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67379	8.5	HIGH		0.006	microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Stack-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67636	8.5	HIGH		0.005	microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-74860	8.5	HIGH		0.004		A flaw was found in libxml2 with Python bindings enabled. A remote attacker could exploit this vulnerability by providing a specially crafted XML document containing a Document Type Definition (DTD) with enumerated attribute values. This triggers a double-free error in the SAX attributeDecl callback handler, where a string is freed twice. This flaw can lead to a denial of service (DoS) due to a reproducible crash ...
CVE-2026-75858	8.5	HIGH		0.003		CodeWhale (packages codewhale / codewhale-tui) versions >= 0.8.41 and < 0.8.64 contain a remote code execution vulnerability in the rlm_eval tool. The tool's approval_requirement() returns ApprovalRequirement::Auto, which the engine treats as 'never prompt,' causing arbitrary model-supplied Python code to run in a python3 interpreter without consulting the user's configured --approval-policy and without any approv...
CVE-2026-76958	8.5	HIGH		0.002		SAP Integration Suite does not sufficiently validate XML documents accepted from untrusted sources in certain internal components. An attacker with low privileges could submit specially crafted XML payloads containing malicious external entity declarations. Successful exploitation could allow the attacker to read sensitive file contents from the server and expose them through monitoring or logging output, resultin...
CVE-2026-80112	8.5	HIGH		0.001		PassMark PerformanceTest before 11.1 build 1012, BurnInTest before 11.1 build 1000, and OSForensics before 11.1 build 1016 contain an improper access control vulnerability in the DirectIo64.sys kernel driver that allows unprivileged local users to perform privileged hardware operations by opening a handle to the device object created without a security descriptor. Attackers can issue IOCTLs through the permissive ...
CVE-2026-84226	8.5	HIGH		0.001		OpenVPN version 2.5.0 through 2.6.22 and 2.7_alpha1 through 2.7.6 on Windows allows local authenticated users to perform a binary planting attack during network configuration steps
CVE-2026-85656	8.5	HIGH		0.011		An OS command injection issue in the log4j-cve-2021-44228-hotpatch package in Amazon Linux before 1.3-9 might allow a local user to execute arbitrary commands with root privileges via a Java process whose executable path contains embedded newline characters.
CVE-2026-86095	8.5	HIGH		0.001		Unidata netcdf-c through 4.10.1 contains an out-of-bounds write vulnerability in NC4_HDF5_inq_attname() that copies HDF5 attribute names into a fixed 256-byte buffer without length validation. Attackers can craft HDF5 files with oversized attribute names to overflow the destination buffer, causing memory corruption and crashes when applications enumerate attribute names.
CVE-2026-47764	8.4	HIGH		0.001		pdm is a Python package and dependency manager supporting the latest PEP standards. Versions prior to 2.27.0 are vulnerable to path traversal through write_to_fs. InstallDestination.write_to_fs() in src/pdm/installers/installers.py overrides the base class to add symlink/hardlink support but replaces the safe _path_with_destdir() (which validates via Path.resolve() + is_relative_to()) with a bare os.path.join() th...
CVE-2026-47781	8.4	HIGH		0.001		PDM is a Python package and dependency manager. In versions up to and including 2.26.9, PDM automatically loads project-local plugins from a .pdm-plugins directory during initialization, allowing an attacker-controlled file in an untrusted repository checkout to execute arbitrary Python code before any command is parsed. This happens because load_plugins() runs during Core.init() and adds .pdm-plugins via site.add...
CVE-2026-64552	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: virtio-net: fix len check in receive_big() receive_big() bounds the device-announced length by (big_packets_num_skbfrags + 1) * PAGE_SIZE. That is still too loose: add_recvbuf_big() sets sg[1] to start at offset sizeof(struct padded_vnet_hdr) into the first page, so the chain actually carries hdr_len + (PAGE_SIZE - sizeof(padded_vnet_hdr)) + bi...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-64657	8.4	HIGH		0.003		Budibase is an open-source low-code platform. Prior to 3.39.19, the PostgreSQL datasource connector in packages/server/src/integrations/postgres.ts interpolates the user-controlled schema configuration field into a SET search_path statement without escaping embedded double quotes, allowing an authenticated administrator who saves or tests the datasource to execute arbitrary SQL through the simple query protocol. T...
CVE-2026-67986	8.4	HIGH		0.002		amazing-print/amazing_print at commit dc890dfafdf07088ea901df53c19c2710e5c5234 contains a Ruby code injection condition in AwesomeMethodArray#grep. A specially named method containing Ruby interpolation syntax can be interpolated into a dynamically constructed eval string when grep is called with a block, resulting in Ruby code execution in the host process. Exploitation requires an application path that allows an...
CVE-2026-69479	8.4	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code locally.
CVE-2026-69638	8.4	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code locally.
CVE-2026-77827	8.4	HIGH		0.002		Maono Link 3.8.13 MaonoAiServices Windows service allows local privilege escalation for a standard user account via improper write privileges in 'C:\ProgramData\Maono'. Fixed in 4.0.80.
CVE-2026-52769	8.3	HIGH		0.003		YesWiki is a wiki system written in PHP. From version 4.6.2 to before version 4.6.6, the POST /api/forms/{formId}/actor/inbox route - exposed publicly with acl:"public" - accepts an HTTP Signature header whose keyId parameter is a URL. HttpSignatureService::verifySignature() parses the header and immediately makes a server-side HTTP GET to that URL, before any cryptographic verification or URL validation. An unaut...
CVE-2026-69646	8.3	HIGH		0.002	microsoft:skype_for_business_server, microsoft:skype_for_business_server_subscription_edition	Improper verification of cryptographic signature in Skype for Business allows an unauthorized attacker to perform spoofing over an adjacent network.
CVE-2026-77104	8.3	HIGH		0.004	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a path traversal issue affecting information disclosure. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2025-47809	8.2	HIGH		0.002		Wibu CodeMeter before 8.30a sometimes allows privilege escalation immediately after installation (before a logoff or reboot). For exploitation, there must have been an unprivileged installation with UAC, and the CodeMeter Control Center component must be installed, and the CodeMeter Control Center component must not have been restarted. In this scenario, the local user can navigate from Import License to a privile...
CVE-2026-46037	8.2	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ipv4: icmp: validate reply type before using icmp_pointers Extended echo replies use ICMP_EXT_ECHOREPLY as the outbound reply type. That value is outside the range covered by icmp_pointers[], which only describes the traditional ICMP types up to NR_ICMP_TYPES. Avoid consulting icmp_pointers[] for reply types outside that range, and use array_in...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-46303	8.2	HIGH		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: isofs: validate Rock Ridge CE continuation extent against volume size rock_continue() reads rs->cont_extent verbatim from the Rock Ridge CE record and passes it to sb_bread() without checking that the block number is within the mounted ISO 9660 volume. commit e595447e177b ("[PATCH] rock.c: handle corrupted directories") added cont_offset and co...
CVE-2026-4740	8.2	HIGH		0.001	redhat:advanced_cluster_management_for_kubernetes	A flaw was found in Open Cluster Management (OCM), the technology underlying Red Hat Advanced Cluster Management (ACM). Improper validation of Kubernetes client certificate renewal allows a managed cluster administrator to forge a client certificate that can be approved by the OCM controller. This enables cross-cluster privilege escalation and may allow an attacker to gain control over other managed clusters, incl...
CVE-2026-52767	8.2	HIGH		0.002		YesWiki is a wiki system written in PHP. From version 4.6.2 to before version 4.6.6, HttpSignatureService::verifySignature() checks the result of PHP's openssl_verify() with a loose boolean negation - if (!openssl_verify(...)) { throw ... }. PHP's openssl_verify has four possible return values: 1, 0, -1, and "false". The -1 row is the bypass: PHP's truthiness rules make -1 a truthy value, so !(-1) === false, the t...
CVE-2026-53268	8.2	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: conntrack_irc: fix possible out-of-bounds read When parsing fails after we've matched the command string we should bail out instead of trying to match a different command. This helper should be deprecated, given prevalence of TLS I doubt it has any relevance in 2026.
CVE-2026-53501	8.2	HIGH		0.002		Thumbor is an open-source photo thumbnail service by globo.com. Prior to 7.8.0, Thumbor's HMAC validation can be bypassed due to the use of Python's .replace() when removing the signature from the URL before validation. Since .replace() removes all occurrences of the substring, an attacker can insert the same signature multiple times in the URL and manipulate the final URL used for validation. This allows crafting...
CVE-2026-64380	8.2	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: smb: client: harden POSIX SID length parsing posix_info_sid_size() reads sid[1] to obtain the subauthority count, but its existing boundary check still accepts buffers with only one remaining byte. Require two bytes before reading sid[1] so all client paths that reuse the helper reject truncated POSIX SIDs safely.
CVE-2026-69846	8.2	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-69906	8.2	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-72958	8.2	HIGH		0.003		Double free in Windows Credential Guard allows an authorized attacker to elevate privileges locally.
CVE-2026-72961	8.2	HIGH		0.003		Out-of-bounds read in Windows Hyper-V allows an authorized attacker to elevate privileges locally.
CVE-2026-72962	8.2	HIGH		0.003		Heap-based buffer overflow in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73658	8.2	HIGH		0.004		Trigger.dev is a platform for building and deploying fully managed AI agents and workflows. From 4.4.2 until 4.5.0-rc.5, Aws4FetchClient.buildUrl() and Aws4FetchClient.presign() in apps/webapp/app/v3/objectStoreClient.server.ts assign user-controlled packet keys to URL.pathname, while apps/webapp/app/routes/api.v1.packets.\$ts accepts params["*"] without rejecting dot segments and uses findResource: async () => 1 ...
CVE-2026-73666	8.2	HIGH		0.005		OpenChoreo is a developer platform for Kubernetes. Prior to 1.0.4, 1.1.4, and 1.2.1, the OpenChoreo Backstage backend hardcoded backend.auth.dangerouslyDisableDefaultAuthPolicy and auth.providers.guest.dangerouslyAllowOutsideDevelopment to true, exposing /api/* without authentication and allowing unauthenticated catalog reads, scaffolder log reads, and catalog location creation or deletion. This issue is fixed in ...
CVE-2026-75594	8.2	HIGH		0.005		Kirby is an open-source content management system. Prior to 4.9.5 and 5.5.2, depending on the release line, Kirby's media handler in src/Cms/Media.php allowed Kirby\Cms\Media::thumb() to append a path-bearing filename to a validated parent media directory. On nginx, PHP's built-in server, or Apache with AllowEncodedSlashes enabled, a remote attacker could submit encoded slash characters such as %2f in the filename...
CVE-2026-76191	8.2	HIGH		0.003	adobe:animate, apple:macos, microsoft:windows	Animate is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is changed.
CVE-2026-81354	8.2	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Heap-based buffer overflow in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-81356	8.2	HIGH		0.003	microsoft:visual_studio_code	Inconsistent interpretation of http requests ('http request/response smuggling') in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-81357	8.2	HIGH		0.003	microsoft:visual_studio_code	Server-side request forgery (ssrf) in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-81378	8.2	HIGH		0.003	microsoft:visual_studio_code	Interpretation conflict in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-81379	8.2	HIGH		0.003	microsoft:visual_studio_code	Not failing securely ('failing open') in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-82586	8.2	HIGH		0.003		Improper Protection of Alternate Path vulnerability in ash-project ash_lua allows a user-supplied Lua script to read attributes that are not on the exposed-field allow-list. AshLua exposes Ash resources to Lua scripts, gated by a manifest declaring which fields are exposed. The read action's operation aggregate path in AshLua.Runtime took the field name straight from the Lua call and resolved it with only String....
CVE-2026-83939	8.2	HIGH		0.003	microsoft:windows_11_26h1	Untrusted pointer dereference in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-86600	8.2	HIGH		0.003		In affected Snowflake drivers, WORKLOAD_IDENTITY authentication requests a cloud workload-identity token and attaches it to the login request without verifying that the configured host is a Snowflake endpoint. An attacker who can modify the connection configuration can cause the driver to mint a fresh attestation and send it to a host they control. The captured token can be replayed to Snowflake for its remaining ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description						
CVE-2026-19594	8.1	HIGH		0.004		Insufficient input sanitization in Snowflake Python API (`snowflake.core`) versions prior to 1.13.0 allowed confused-deputy privilege escalation through two related weaknesses: path traversal (CWE-22) via unencoded `..` identifier path segments, and HTTP parameter pollution (CWE-141) via unencoded `&`/`#`/`'`=` characters in query string values. An attacker with access to a downstream application built on snowflake....						
CVE-2026-44745	8.1	HIGH		0.005	sap:approuter	SAP Approuter does not properly validate incoming request headers during the OAuth2 login flow under certain configurations. This allows an unauthenticated remote attacker to craft a malicious link which, when clicked by a victim, could lead to unauthorized access. Successful exploitation results in a high impact to the confidentiality and integrity with no impact on the availability of the application.						
CVE-2026-48081	8.1	HIGH		0.001		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.2, a TENANT_ADMIN can store `javascript:` URLs in the tenant `links` configuration (`website`, `imprint`, `privacyStatement`). These values are returned to the patient-facing landing page via `/api/public`, hydrated into the SvelteKit Button component, and rendered as ` <a #"="" href="javascrip...</td></tr><tr><td>CVE-2026-54330	8.1	HIGH		0.002		Ceph is an open-source distributed storage platform providing object, block, and file storage. In versions prior to 20.2.4 and 19.2.6, the Ceph Object Gateway (RGW) SigV4 handler does not reject requests that carry x-amz-* headers absent from the signed header set, allowing anyone holding a presigned URL to attach arbitrary unsigned x-amz-* headers that RGW will honor. AWS S3 requires every x-amz-* header on a Sig...
CVE-2026-55007	8.1	HIGH		0.007		Double free in Microsoft Exchange Server allows an unauthorized attacker to execute code over a network.						
CVE-2026-69325	8.1	HIGH		0.006		Heap-based buffer overflow in Microsoft JScript allows an unauthorized attacker to execute code over a network.						
CVE-2026-69380	8.1	HIGH		0.007		Missing authorization in Microsoft Exchange Server allows an authorized attacker to elevate privileges over a network.						
CVE-2026-69438	8.1	HIGH		0.007		Incorrect conversion between numeric types in Microsoft JScript allows an unauthorized attacker to execute code over a network.						
CVE-2026-69510	8.1	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Stack-based buffer overflow in Windows DHCP Server allows an unauthorized attacker to execute code over a network.						
CVE-2026-69524	8.1	HIGH		0.007		Use after free in Active Directory Domain Services allows an unauthorized attacker to execute code over a network.						
CVE-2026-69546	8.1	HIGH		0.007		Use after free in Active Directory Domain Services allows an unauthorized attacker to execute code over a network.						
CVE-2026-69620	8.1	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Stack-based buffer overflow in Windows DHCP Server allows an unauthorized attacker to execute code over a network.						
CVE-2026-69680	8.1	HIGH		0.003		Origin validation error in Windows DNS allows an unauthorized attacker to perform spoofing over a network.						
CVE-2026-69732	8.1	HIGH		0.007		Heap-based buffer overflow in Windows Link Layer Topology Discovery Protocol allows an unauthorized attacker to execute code over a network.						

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69786	8.1	HIGH		0.007		Heap-based buffer overflow in Windows Text Shaping allows an unauthorized attacker to execute code over a network.
CVE-2026-69813	8.1	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-69858	8.1	HIGH		0.007	microsoft:windows_server_2022, microsoft:windows_server_2025	Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-69989	8.1	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in DNS Server allows an unauthorized attacker to execute code over a network.
CVE-2026-70342	8.1	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Ancillary Function Driver for WinSock allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-70465	8.1	HIGH		0.007	fortinet:forticlient	A buffer copy without checking size of input ('classic buffer overflow') vulnerability in Fortinet FortiClientWindows 7.4.0 through 7.4.3, FortiClientWindows 7.2.0 through 7.2.11 may allow an unauthenticated attacker in a position to alter or craft DNS responses to the targeted host to execute arbitrary code via malicious packets.
CVE-2026-70468	8.1	HIGH		0.007	fortinet:fortimanager, fortinet:fortimanager_cloud	A authentication bypass using an alternate path or channel vulnerability in Fortinet FortiManager 7.6.1, FortiManager 7.4.3 through 7.4.5, FortiManager 7.2.5 through 7.2.9, FortiManager Cloud 7.6.1, FortiManager Cloud 7.4.3 through 7.4.5, FortiManager Cloud 7.2.5 through 7.2.9 may allow attacker to improper access control via <insert attack vector here>
CVE-2026-70563	8.1	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper link resolution before file access ('link following') in Windows Shell allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-71407	8.1	HIGH		0.005	fortinet:fortios	A Stack-based Buffer Overflow vulnerability [CWE-121] vulnerability in Fortinet FortiOS 7.6.1 through 7.6.6 may allow an unauthenticated attacker who can bypass stack protection and ASLR to execute arbitrary code or commands in the context of the WAD daemon via crafted sockets, only if the explicit proxy is configured with Kerberos authentication and SOCKS enabled.
CVE-2026-72936	8.1	HIGH		0.006		Use after free in Windows SMB Client allows an unauthorized attacker to execute code over a network.
CVE-2026-72987	8.1	HIGH		0.006		Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-75021	8.1	HIGH		0.004		fastify-cli starts the Node.js Inspector when a debug flag is used, but it ignores the explicit bind address the user supplies and binds the Inspector to a broadly reachable address instead of the intended loopback. As a result the debugging interface can be exposed beyond the local machine, and because the Inspector protocol allows arbitrary code evaluation, a remote party that reaches it can achieve remote code ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78444	8.1	HIGH		0.005	microsoft:windows_10_1809, microsoft:windows_server_2019, microsoft:windows_server_2022, microsoft:windows_server_2025	Untrusted pointer dereference in Windows Failover Cluster allows an unauthorized attacker to execute code over a network.
CVE-2026-78450	8.1	HIGH		0.005	microsoft:windows_10_1809, microsoft:windows_server_2019, microsoft:windows_server_2022, microsoft:windows_server_2025	Use after free in Reliable Multicast Transport Driver (RMCAST) allows an unauthorized attacker to execute code over a network.
CVE-2026-78583	8.1	HIGH		0.002	elastic:kibana	Incorrect Authorization (CWE-863) in Kibana can lead to privilege escalation via Input Data Manipulation (CAPEC-153). Elasticsearch cluster privilege declarations originating from integration packages were not validated before being used to mint credentials for enrolled Elastic Agents. A user holding Fleet management privileges could therefore cause every Elastic Agent on a targeted policy to receive a credential ...
CVE-2026-78626	8.1	HIGH		0.002		The Okta Access Gateway improperly handles input sanitization and regular expression evaluation within its Protected Rule authorization check, resulting in an authorization bypass when an administrator has explicitly configured a Protected Rule policy on one or more application resources.
CVE-2026-83997	8.1	HIGH		0.005	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Use after free in Windows Message Queuing allows an unauthorized attacker to execute code over a network.
CVE-2026-84393	8.1	HIGH		0.002		A improper validation of certificate with host mismatch vulnerability in Fortinet FortiOS 7.6.1 through 7.6.6, FortiProxy 7.6.2 through 7.6.6 may allow attacker to information disclosure via <insert attack vector here>
CVE-2026-47858	8.0	HIGH		0.002	broadcom:spring_tools	Starting Spring Boot applications in the Spring Tools with the live information mode enabled makes the running application vulnerable against JMX-based remote code execution. Affected Spring Products and Versions: Spring Tools for Eclipse: 5.2.0 and earlier Spring Tools for VSCode / Cursor / Theia: 2.2.0 and earlier
CVE-2026-48080	8.0	HIGH		0.003		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.2, the `GET /api/tenants/{id}` endpoint returns the full tenant record to any authenticated `TENANT_ADMIN` of that tenant, including the `databaseUri` field. This field contains the live PostgreSQL connection string the application uses to connect to that tenant's database. In the tested...
CVE-2026-68827	8.0	HIGH		0.004		Integer underflow (wrap or wraparound) in Windows GDI+ allows an authorized attacker to elevate privileges over a network.
CVE-2026-68834	8.0	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-68838	8.0	HIGH		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68876	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-68878	8.0	HIGH		0.005		Stack-based buffer overflow in Windows Fast FAT Driver allows an authorized attacker to elevate privileges over a network.
CVE-2026-68880	8.0	HIGH		0.004		Heap-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-68894	8.0	HIGH		0.006		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges over a network.
CVE-2026-69271	8.0	HIGH		0.007		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69301	8.0	HIGH		0.008		Stack-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69322	8.0	HIGH		0.007		Double free in Microsoft Windows Search Component allows an authorized attacker to elevate privileges over a network.
CVE-2026-69332	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69346	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges over a network.
CVE-2026-69365	8.0	HIGH		0.007		Out-of-bounds read in Microsoft Local Security Authority Server (lsasrv) allows an authorized attacker to elevate privileges over a network.
CVE-2026-69371	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Overlay Filter allows an authorized attacker to elevate privileges over a network.
CVE-2026-69412	8.0	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Stack-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code over an adjacent network.
CVE-2026-69423	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows USB Video Driver allows an authorized attacker to elevate privileges over a network.
CVE-2026-69427	8.0	HIGH		0.007		Out-of-bounds read in Windows VOLSnap.SYS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69458	8.0	HIGH		0.007		Out-of-bounds read in Windows BitLocker allows an authorized attacker to elevate privileges over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69462	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges over a network.
CVE-2026-69481	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Enterprise App Management allows an authorized attacker to elevate privileges over a network.
CVE-2026-69503	8.0	HIGH		0.008	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Stack-based buffer overflow in Windows USB Driver allows an authorized attacker to elevate privileges over a network.
CVE-2026-69505	8.0	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69512	8.0	HIGH		0.008		Heap-based buffer overflow in Windows Spaceport.sys allows an authorized attacker to elevate privileges over a network.
CVE-2026-69619	8.0	HIGH		0.008		Out-of-bounds read in Windows exFAT File System allows an authorized attacker to elevate privileges over a network.
CVE-2026-69623	8.0	HIGH		0.009		Heap-based buffer overflow in Windows HTTP Print Provider allows an authorized attacker to execute code over a network.
CVE-2026-69625	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Connected User Experiences and Telemetry allows an authorized attacker to elevate privileges over a network.
CVE-2026-69643	8.0	HIGH		0.008		Heap-based buffer overflow in Windows Spaceport.sys allows an authorized attacker to elevate privileges over a network.
CVE-2026-69689	8.0	HIGH		0.008		Out-of-bounds read in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69714	8.0	HIGH		0.008		Stack-based buffer overflow in Windows Device Association Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69717	8.0	HIGH		0.007		Untrusted pointer dereference in Windows Group Policy allows an authorized attacker to elevate privileges over a network.
CVE-2026-69727	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69762	8.0	HIGH		0.007		Stack-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69773	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69777	8.0	HIGH		0.005	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1	Heap-based buffer overflow in Windows DHCP Client allows an authorized attacker to elevate privileges over an adjacent network.
CVE-2026-69807	8.0	HIGH		0.009		Improper limitation of a pathname to a restricted directory ('path traversal') in Windows PowerShell allows an authorized attacker to elevate privileges over a network.
CVE-2026-69826	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69847	8.0	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code over an adjacent network.
CVE-2026-69875	8.0	HIGH		0.008	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69876	8.0	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows DHCP Server allows an authorized attacker to execute code over an adjacent network.
CVE-2026-83948	8.0	HIGH		0.004	microsoft:vm_repair	Improper neutralization of special elements used in a command ('command injection') in Microsoft Azure CLI allows an authorized attacker to execute code over a network.
CVE-2026-84935	8.0	HIGH		0.002		The HT Menu WordPress plugin before 1.2.7 does not perform any capability or object-ownership check when saving navigation menu-item settings, and does not escape those stored settings when the menu is rendered, allowing users with minimal permissions such as Subscribers to store JavaScript that executes in the browser of any visitor, administrators included, who views the affected menu.
CVE-2025-21863	7.8	HIGH		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: io_uring: prevent opcode speculation sqe->opcode is used for different tables, make sure we sanitise it against speculations.
CVE-2026-0065	7.8	HIGH		0.001	google:android	In areBackgroundActivityStartsAllowed of BackgroundLaunchProcessController.java, there is a possible unintended way to launch activities in the background due to a logic error in the code. This could lead to local escalation of privilege with User execution privileges needed. User interaction is not needed for exploitation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-0084	7.8	HIGH		0.001	google:android	In multiple functions of HostEmulationManager.java, there is a possible background activity launch due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-12410	7.8	HIGH		0.001		Link following vulnerability in the Uninstaller component in CCleaner prior to 7.10.1464 on Windows allows a local, low-privileged attacker to escalate privileges to SYSTEM via a symlink/junction created during application uninstallation, which CCleaner follows when deleting the application's data folder with elevated integrity.
CVE-2026-28593	7.8	HIGH		0.001	google:android	In getItemList of SettingsFragment.java, there is a possible user interaction bypass due to misleading or insufficient UI. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28599	7.8	HIGH		0.001	google:android	In addCreatorToken of ActivityManagerService.java, there is a possible Intent Redirection Bypass due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28600	7.8	HIGH		0.001	google:android	In onCreate of PaymentDefaultDialog.java, there is a possible way to change default payment app due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28602	7.8	HIGH		0.001	google:android	In setClipboardAccessNotificationsEnabledForUser of ClipboardService.java, there is a possible multi-user isolation due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28603	7.8	HIGH		0.001	google:android	In assertSafeToStartCustomActivity of AppRestrictionsFragment.java, there is a possible read/write access to private files due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28611	7.8	HIGH		0.001	google:android	In multiple functions of NfcService.java, there is a possible silent payment session hijacking enablement due to a missing permission check. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28612	7.8	HIGH		0.001	google:android	In resolveActivity of ActivityStarter.java, there is a possible way to perform Intent Redirection attacks due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28614	7.8	HIGH		0.001	google:android	In onCreate of SlicePermissionActivity.java, there is a possible permission bypass due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28631	7.8	HIGH		0.001	google:android	In buildMiniResolver of IntentForwarderActivity.java, there is a possible consent bypass due to a tapjacking/overlay attack. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28634	7.8	HIGH		0.001	google:android	In handleUssdRequest of PhoneInterfaceManager.java, there is a possible way to send a USSD request without permission due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28636	7.8	HIGH		0.001	google:android	In setupLayout of PickActivity.java, there is a possible bypass of the "Install unknown apps" security restriction due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-28642	7.8	HIGH		0.001	google:android	In executeRequest of ActivityStarter.java, there is a possible background activity launch due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28644	7.8	HIGH		0.001	google:android	In startNextMatchingActivity of ActivityTaskManagerService.java, there is a possible permission bypass due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28650	7.8	HIGH		0.001	google:android	In setHiddenWhileSuspended of WindowState.java, there is a possible overlay bypass due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28655	7.8	HIGH		0.001	google:android	In multiple functions of RemoteViews.java, there is a possible background activity launch bypass due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28657	7.8	HIGH		0.001	google:android	In onActivityResult of AppWidgetConfigActivityProxy.java, there is a possible unauthorized URI permission grant due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28658	7.8	HIGH		0.001	google:android	In findMetaAuthUid of AccountsDb.java, there is a possible frp bypass due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28663	7.8	HIGH		0.001		In buildIntentSenderForUser of LauncherAppsService.java, there is a possible way to launch an activity from the background due to BAL Bypass. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-31449	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ext4: validate p_idx bounds in ext4_ext_correct_indexes ext4_ext_correct_indexes() walks up the extent tree correcting index entries when the first extent in a leaf is modified. Before accessing path[k].p_idx->ei_block, there is no validation that p_idx falls within the valid range of index entries for that level. If the on-disk extent header c...
CVE-2026-31700	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net/packet: fix TOCTOU race on mmap'd vnet_hdr in tpacket_snd() In tpacket_snd(), when PACKET_VNET_HDR is enabled, vnet_hdr points directly into the mmap'd TX ring buffer shared with userspace. The kernel validates the header via __packet_snd_vnet_parse() but then re-reads all fields later in virtio_net_hdr_to_skb(). A concurrent userspace threa...
CVE-2026-43116	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: ctnetlink: ensure safe access to master conntrack Holding reference on the expectation is not sufficient, the master conntrack object can just go away, making exp->master invalid. To access exp->master safely: - Grab the nf_conntrack_expect_lock, this gets serialized with clean_from_lists() which also holds this lock when the mast...
CVE-2026-43303	7.8	HIGH		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: mm/page_alloc: clear page->private in free_pages_prepare() Several subsystems (slub, shmem, ttm, etc.) use page->private but don't clear it before freeing pages. When these pages are later allocated as high-order pages and split via split_page(), tail pages retain stale page->private values. This causes a use-after-free in the swap subsystem. ...
CVE-2026-43499	7.8	HIGH		0.008	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: rtmutex: Use waiter::task instead of current in remove_waiter() remove_waiter() is used by the slowlock paths, but it is also used for proxy-lock rollback in rt_mutex_start_proxy_lock() when invoked from futex_queue(). In the latter case waiter::task is not current, but remove_waiter() operates on current for the dequeue operation. That resul...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-45520	7.8	HIGH		0.001		In onAttach of BiometricsSettingsBase.java, there is a possible authentication bypass due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-46015	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: tcp: call sk_data_ready() after listener migration When inet_csk_listen_stop() migrates an established child socket from a closing listener to another socket in the same SO_REUSEPORT group, the target listener gets a new accept-queue entry via inet_csk_reqsk_queue_add(), but that path never notifies the target listener's waiters. A nonblocking a...
CVE-2026-46173	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: exit: prevent preemption of oopsing TASK_DEAD task When an already-exiting task oopses, make_task_dead() currently calls do_task_dead() with preemption enabled. That is forbidden: do_task_dead() calls __schedule(), which has a comment saying "WARNING: must be called with preemption disabled!". If an oopsing task is preempted in do_task_dead(),...
CVE-2026-46300	7.8	HIGH		0.093	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: skbuff: preserve shared-frag marker during coalescing skb_try_coalesce() can attach paged frags from @from to @to. If @from has SKBFL_SHARED_FRAG set, the resulting @to skb can contain the same externally-owned or page-cache-backed frags, but the shared-frag marker is currently lost. That breaks the invariant relied on by later in-place w...
CVE-2026-46323	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: gro: don't merge zcopy skbs skb_gro_receive() can currently copy frags between the source and GRO skb, without checking the zerocopy status, and in particular the SKBFL_MANAGED_FRAG_REFS flag. When SKBFL_MANAGED_FRAG_REFS is set, the skb doesn't hold a reference on the pages in shinfo->frags. Appending those frags to another skb's frags wi...
CVE-2026-49881	7.8	HIGH		0.001		In serviceClassExists of InCallController.java, there is a possible arbitrary code execution due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-49932	7.8	HIGH		0.001		In parseParts of PduParser.java, there is a possible out of bounds read due to a heap buffer overflow. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-52910	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: bpf: Free reuseport cBPF prog after RCU grace period. Eulgyu Kim reported the splat below with a repro. [0] The repro sets up a UDP reuseport group with a cBPF prog and replaces it with a new one while another thread is sending a UDP packet to the group. The reuseport prog is freed by sk_reuseport_prog_free(). bpf_prog_put() is called for "e"B...
CVE-2026-52912	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nf_queue: hold bridge skb->dev while queued br_pass_frame_up() rewrites skb->dev from the ingress port to the bridge master before queueing bridge LOCAL_IN packets. NFQUEUE only holds references on state.in/out and bridge physdevs, so a queued bridge packet can retain a freed bridge master in skb->dev until reinjection. When the verd...
CVE-2026-52933	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: io_uring/poll: fix signed comparison in io_poll_get_ownership() io_poll_get_ownership() uses a signed comparison to check whether poll_refs has reached the threshold for the slowpath: if (unlikely(atomic_read(&req->poll_refs) >= IO_POLL_REF_BIAS)) atomic_read() returns int (signed). When IO_POLL_CANCEL_FLAG (BIT(31)) is set in poll_refs, t...
CVE-2026-52943	7.8	HIGH		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: skbuff: fix missing zerocopy reference in pskb_carve helpers pskb_carve_inside_header() and pskb_carve_inside_nonlinear() both copy the old skb_shared_info header into a new buffer via memcpy(), which includes the destructor_arg pointer (uarg) for MSG_ZEROCOPY skbs. Neither function calls net_zcopy_get() for the new shinfo, creating an unac...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-53050	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: quota: Fix race of dquot_scan_active() with quota deactivation dquot_scan_active() can race with quota deactivation in quota_release_workfn() like: CPU0 (quota_release_workfn) CPU1 (dquot_scan_active) ===== ===== spin_lock(&dq_list_lock); list_replace_init(&releasing_dq...
CVE-2026-53239	7.8	HIGH		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: xfrm: policy: fix use-after-free on inexact bin in xfrm_policy_bysel_ctx() Fix the race by pruning the bin while still holding xfrm_policy_lock, before dropping it. Use __xfrm_policy_inexact_prune_bin() directly since the lock is already held. The wrapper xfrm_policy_inexact_prune_bin() becomes unused and is removed. Race: CPU0 (XFRM_MSG_DEL...
CVE-2026-53400	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: i2c: core: fix adapter registration race Adapters can be looked up based on their id using i2c_get_adapter() which takes a reference to the embedded struct device. Make sure that the adapter (including its struct device) has been initialised before adding it to the IDR to avoid accessing uninitialised data which could, for example, lead to NULL...
CVE-2026-55522	7.8	HIGH		0.002		PraisonAI is a multi-agent teams system. In versions 3.9.26 through 4.6.57 of praiseonai and 0.12.12 through 1.6.57 of praiseonaiagents, the workflow "include" feature is vulnerable to code execution. Workflow._execute_include() implicitly imports and runs an included recipe's tools.py via a raw importlib.util.spec_from_file_location() and spec.loader.exec_module() call, without honoring the PRAISONAI_ALLOW_TEMPLA...
CVE-2026-56172	7.8	HIGH		0.003		Use after free in Windows VHD miniport driver allows an authorized attacker to elevate privileges locally.
CVE-2026-56177	7.8	HIGH		0.003		Use after free in Windows Server allows an authorized attacker to elevate privileges locally.
CVE-2026-56198	7.8	HIGH		0.002		Out-of-bounds read in Microsoft Trace Data Helper allows an authorized attacker to elevate privileges locally.
CVE-2026-58599	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Codecs Library allows an unauthorized attacker to execute code locally.
CVE-2026-58600	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Codecs Library allows an unauthorized attacker to elevate privileges locally.
CVE-2026-58611	7.8	HIGH		0.002	microsoft:xbox_gaming_services	Improper authorization in Xbox Gaming Services allows an authorized attacker to elevate privileges locally.
CVE-2026-58874	7.8	HIGH		0.001		In multiple functions of SmsController.java, there is a possible escalation of privilege due to a missing permission check. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-62697	7.8	HIGH		0.003		Use after free in Windows Push Notifications allows an authorized attacker to elevate privileges locally.
CVE-2026-62804	7.8	HIGH		0.003	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	External control of file name or path in Microsoft Office Word allows an unauthorized attacker to execute code locally.
CVE-2026-62810	7.8	HIGH		0.002		Heap-based buffer overflow in Active Directory Certificate Services (AD CS) allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-62886	7.8	HIGH		0.004	microsoft:.net, microsoft:visual_studio_2022, microsoft:visual_studio_2026, microsoft:windows	Integer overflow or wraparound in .NET allows an unauthorized attacker to elevate privileges locally.
CVE-2026-64279	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: i2c: core: fix adapter deregistration race Adapters can be looked up by their id using i2c_get_adapter() which takes a reference to the embedded struct device. Remove the adapter from the IDR before tearing it down during deregistration (and on registration failure) to make sure its resources are not accessed after having been freed (e.g. the d...
CVE-2026-64372	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: cpufreq: pcc: fix use-after-free and double free in _OSC evaluation pcc_cpufreq_do_osc() calls acpi_evaluate_object() twice for the two-phase _OSC negotiation. Between the two calls it freed output.pointer but left output.length unchanged. Since acpi_evaluate_object() treats a non-zero length with a non-NULL pointer as an existing buffer to writ...
CVE-2026-64375	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: proc: protect ptrace_may_access() with exec_update_lock (FD links) proc_pid_get_link() and proc_pid_readlink() currently look up the task from the pid once, then do the ptrace access check on that task, then look up the task from the pid a second time to do the actual access. That's racy in several ways. To fix it, pass the task to the ->proc_g...
CVE-2026-64377	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: cpufreq: qcom-cpufreq-hw: Fix possible double free qcom_cpufreq.data is allocated with devm_kzalloc() in probe() as an array of per-domain data. qcom_cpufreq_hw_cpu_init() stores a pointer to one element of this array in policy->driver_data. qcom_cpufreq_hw_cpu_exit() currently calls kfree() on policy->driver_data. This is not valid because the...
CVE-2026-64378	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: writeback: fix race between cgroup_writeback_umount() and inode_switch_wbs() When a container exits, the following BUG_ON() is occasionally triggered: ===== VFS: Busy inodes after unmount of sdb (ext4) -----[cut here]----- kernel BUG at fs/super.c:695! CPU: 3 PID: ...
CVE-2026-64381	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: smb: client: Fix next buffer leak in receive_encrypted_standard() receive_encrypted_standard() allocates next_buffer before checking whether the number of compound PDUs already reached MAX_COMPOUND. If the limit check fails, the function returns immediately and the newly allocated next_buffer is not assigned to server->smallbuf/server->bigbuf, m...
CVE-2026-64423	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ipv4: igmp: remove multicast group from hash table on device destruction When a device is destroyed under RTNL, ip_mc_destroy_dev() iterates through the multicast list and calls ip_ma_put() on each membership, scheduling them for RCU reclamation. However, they are not unlinked from the device's multicast hash table (mc_hash). Since the device r...
CVE-2026-64560	7.8	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: posix-cpu-timers: Prevent UAF caused by non-leader exec() race Wongi and Jungwoo decoded and reported a non-leader exec() related race which can result in an UAF: sys_timer_delete() exec() posix_cpu_timer_del() // Observes old leader p = pid_task(pid, pid_type); de_thread() switch_leader(); release_task(old_leader)...
CVE-2026-68787	7.8	HIGH		0.002	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68832	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-68841	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-68844	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Storage Spaces Controller allows an authorized attacker to execute code locally.
CVE-2026-68845	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges locally.
CVE-2026-68848	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-68850	7.8	HIGH		0.002		Heap-based buffer overflow in Microsoft Account allows an authorized attacker to elevate privileges locally.
CVE-2026-68875	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Buffer over-read in Windows NTFS allows an authorized attacker to execute code locally.
CVE-2026-68877	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Storage Spaces Controller allows an authorized attacker to execute code locally.
CVE-2026-68885	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-68888	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-68890	7.8	HIGH		0.002		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-68892	7.8	HIGH		0.002		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-68896	7.8	HIGH		0.004		Absolute path traversal in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69265	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69269	7.8	HIGH		0.003		Integer underflow (wrap or wraparound) in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-69270	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69277	7.8	HIGH		0.003		Stack-based buffer overflow in Microsoft Local Security Authority Server (lsasrv) allows an authorized attacker to elevate privileges locally.
CVE-2026-69283	7.8	HIGH		0.002		Heap-based buffer overflow in Windows CD-ROM Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69284	7.8	HIGH		0.002		Heap-based buffer overflow in Windows DCOM Server allows an authorized attacker to elevate privileges locally.
CVE-2026-69289	7.8	HIGH		0.004		Improper link resolution before file access ('link following') in Windows Setup Files Cleanup allows an authorized attacker to elevate privileges locally.
CVE-2026-69290	7.8	HIGH		0.002		Stack-based buffer overflow in Windows Storage Spaces Controller allows an authorized attacker to elevate privileges locally.
CVE-2026-69293	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69295	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows USB Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69298	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69307	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69312	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69323	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69324	7.8	HIGH		0.003		Access of resource using incompatible type ('type confusion') in Windows Performance Monitor allows an authorized attacker to elevate privileges locally.
CVE-2026-69328	7.8	HIGH		0.003		Untrusted search path in Windows Storage allows an authorized attacker to elevate privileges locally.
CVE-2026-69348	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69352	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69359	7.8	HIGH		0.003		Heap-based buffer overflow in Active Directory Domain Services allows an authorized attacker to elevate privileges locally.
CVE-2026-69368	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Overlay Filter allows an authorized attacker to elevate privileges locally.
CVE-2026-69377	7.8	HIGH		0.003		Missing authorization in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-69389	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Storage Management Provider allows an authorized attacker to elevate privileges locally.
CVE-2026-69391	7.8	HIGH		0.003		Stack-based buffer overflow in Windows Broker Infrastructure Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69392	7.8	HIGH		0.003		Use after free in Windows Shell allows an authorized attacker to elevate privileges locally.
CVE-2026-69420	7.8	HIGH		0.003		Heap-based buffer overflow in Windows VOLSnap.SYS allows an authorized attacker to elevate privileges locally.
CVE-2026-69421	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer underflow (wrap or wraparound) in Windows Kernel Mode Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69424	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Distributed File System (DFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69426	7.8	HIGH		0.003		Heap-based buffer overflow in Windows VOLSnap.SYS allows an authorized attacker to execute code locally.
CVE-2026-69433	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69436	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69444	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Speech allows an authorized attacker to elevate privileges locally.
CVE-2026-69445	7.8	HIGH		0.004		Improper limitation of a pathname to a restricted directory ('path traversal') in Windows Compressed Folder allows an authorized attacker to elevate privileges locally.
CVE-2026-69447	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69450	7.8	HIGH		0.003		Out-of-bounds read in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69455	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-69456	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Speech allows an authorized attacker to elevate privileges locally.
CVE-2026-69459	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Power Dependency Coordinator allows an authorized attacker to elevate privileges locally.
CVE-2026-69467	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Stack-based buffer overflow in Microsoft Graphics Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69475	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Untrusted pointer dereference in Windows Remote Desktop Services allows an authorized attacker to elevate privileges locally.
CVE-2026-69476	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69478	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69480	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Partition Management Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69489	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69508	7.8	HIGH		0.003		Stack-based buffer overflow in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-69509	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Fax Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69513	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69528	7.8	HIGH		0.003		Missing authentication for critical function in Windows Shell allows an authorized attacker to elevate privileges locally.
CVE-2026-69532	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69534	7.8	HIGH		0.006		Improper neutralization of special elements used in a command ('command injection') in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69535	7.8	HIGH		0.002		Numeric truncation error in Windows Spaceport.sys allows an authorized attacker to elevate privileges locally.
CVE-2026-69538	7.8	HIGH		0.002		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to execute code locally.
CVE-2026-69542	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Camera Frame Server Monitor allows an authorized attacker to elevate privileges locally.
CVE-2026-69544	7.8	HIGH		0.003		Heap-based buffer overflow in Windows SMB Client allows an authorized attacker to elevate privileges locally.
CVE-2026-69561	7.8	HIGH		0.003		Out-of-bounds read in Windows CD-ROM Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69571	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69580	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69582	7.8	HIGH		0.003		Buffer over-read in Windows Volume Manager Extension Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69583	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69584	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69585	7.8	HIGH		0.004		Incorrect type conversion or cast in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69589	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69592	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Universal Disk Format File System Driver (UDFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69593	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69594	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Local Security Authority Server (lsasrv) allows an authorized attacker to elevate privileges locally.
CVE-2026-69604	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69608	7.8	HIGH		0.003		Integer overflow or wraparound in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69612	7.8	HIGH		0.004		Absolute path traversal in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69685	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Kerberos allows an authorized attacker to elevate privileges locally.
CVE-2026-69687	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer underflow (wrap or wraparound) in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69691	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Spaceport.sys allows an authorized attacker to elevate privileges locally.
CVE-2026-69707	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69709	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to execute code locally.
CVE-2026-69720	7.8	HIGH		0.003		Heap-based buffer overflow in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-69725	7.8	HIGH		0.003		Double free in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69738	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69758	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Universal Disk Format File System Driver (UDFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69785	7.8	HIGH		0.003		Untrusted search path in Windows Smart Card allows an authorized attacker to elevate privileges locally.
CVE-2026-69787	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69790	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Credential Providers allows an authorized attacker to elevate privileges locally.
CVE-2026-69799	7.8	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69801	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69821	7.8	HIGH		0.003		Improper encoding or escaping of output in Active Directory Certificate Services (AD CS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69822	7.8	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Numeric truncation error in Windows Kerberos allows an authorized attacker to elevate privileges locally.
CVE-2026-69841	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Encrypting File System (EFS) allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69844	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69864	7.8	HIGH		0.002	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Use after free in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69900	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Untrusted pointer dereference in Kernel Streaming WOW Thunk Service Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69907	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper handling of insufficient permissions or privileges in Windows Enterprise App Management allows an authorized attacker to elevate privileges locally.
CVE-2026-69921	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-70289	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Win32 Kernel Subsystem allows an authorized attacker to elevate privileges locally.
CVE-2026-70334	7.8	HIGH		0.004	microsoft:visual_studio_code	Incomplete list of disallowed inputs in Visual Studio Code allows an unauthorized attacker to bypass a security feature locally.
CVE-2026-70564	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-70569	7.8	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70572	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70581	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70583	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Core Messaging allows an authorized attacker to elevate privileges locally.
CVE-2026-70584	7.8	HIGH		0.003		Access of resource using incompatible type ('type confusion') in Windows Core Messaging allows an authorized attacker to elevate privileges locally.
CVE-2026-71334	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NFS Portmapper allows an authorized attacker to elevate privileges locally.
CVE-2026-71337	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Stack-based buffer overflow in Windows Storage Management Provider allows an authorized attacker to elevate privileges locally.
CVE-2026-71343	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Remote Access Connection Manager allows an authorized attacker to execute code locally.
CVE-2026-71345	7.8	HIGH		0.003		Out-of-bounds write in Windows Spaceport.sys allows an authorized attacker to execute code locally.
CVE-2026-72929	7.8	HIGH		0.002		Improper validation of integrity check value in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-72941	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72944	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Fax Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72953	7.8	HIGH		0.003		Heap-based buffer overflow in Windows USB Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-72957	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Deployment Services allows an authorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72965	7.8	HIGH		0.003		Use after free in Windows WebClient Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72967	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Network Connection Broker allows an authorized attacker to elevate privileges locally.
CVE-2026-72988	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72990	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72991	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72992	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72993	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72994	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72995	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72996	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72997	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73000	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73001	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73002	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73007	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73011	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73015	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73020	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73021	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73024	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Services for NFS ONCRPC XDR Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-73026	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-75631	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-75771	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an Integer Overflow or Wraparound vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-75862	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an Integer Overflow or Wraparound vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-75863	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an Integer Overflow or Wraparound vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-76967	7.8	HIGH		0.002		SAP NetWeaver Business Client does not perform sufficient validation when processing certain locally stored data during application startup. An attacker with low privileges on the local system could replace this data with specially crafted content. When the application is next launched, the crafted content is processed and could lead to arbitrary code execution in the context of the user. This results in a high im...
CVE-2026-77489	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Null pointer dereference in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-77500	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Release of invalid pointer or reference in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-77503	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an unauthorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77904	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-78447	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-78448	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-79907	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Double Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-79908	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-79909	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-80075	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:wi	Heap-based buffer overflow in Windows Work Folders allows an authorized attacker to elevate privileges locally.
CVE-2026-80161	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Access of Resource Using Incompatible Type ('Type Confusion') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81353	7.8	HIGH		0.004		Heap-based buffer overflow in Microsoft Windows Codecs Library allows an unauthorized attacker to execute code locally.
CVE-2026-81386	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81388	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Stack-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81396	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Stack-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81397	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81398	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81947	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81948	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81949	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Integer overflow or wraparound in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81950	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Double free in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81951	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81953	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Stack-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81954	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Use after free in Microsoft Office Excel allows an unauthorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81956	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81957	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81959	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81960	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81973	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81975	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81976	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81979	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81980	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81981	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81983	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81985	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81986	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81987	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Integer Overflow or Wraparound vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81988	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81989	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81990	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81992	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Heap-based Buffer Overflow vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-82005	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-82006	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by a Heap-based Buffer Overflow vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-82007	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an Integer Overflow or Wraparound vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-83498	7.8	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Untrusted pointer dereference in Windows Virtualization-Based Security (VBS) Enclave allows an authorized attacker to elevate privileges locally.
CVE-2026-83942	7.8	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Missing authorization in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-83952	7.8	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Heap-based buffer overflow in Windows Resilient File System (ReFS) allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83954	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83955	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83967	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83968	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83969	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83970	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83971	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83972	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83973	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83974	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83975	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83976	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83977	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83978	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83979	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83980	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83981	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83982	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83983	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83985	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83986	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83987	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83988	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83990	7.8	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Stack-based buffer overflow in Microsoft Graphics Component allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83995	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-84000	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Microsoft Graphics Component allows an authorized attacker to execute code locally.
CVE-2026-19304	7.7	HIGH		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to obtain sensitive information from internal services due to a URL parser discrepancy.
CVE-2026-19306	7.7	HIGH		0.004	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 allows an authenticated attacker to read arbitrary files from the server filesystem — including server secret material (secret_key, JWT signing keys, the application database, /proc/self/environ, and other tenants' upload directories) — by supplying absolute paths or traversal sequences in the files parameter of an authenticated build request. The file contents were embedded a...
CVE-2026-66767	7.7	HIGH		0.003		SAP NetWeaver Application Server for ABAP and ABAP Platform allows an unauthenticated user to send a specially crafted packet that triggers reprocessing of a previously buffered user request, potentially hijacking another user's session under narrow timing conditions. Successful exploitation could result in high impact on confidentiality and integrity, with low impact on availability of the application.
CVE-2026-69683	7.7	HIGH		0.008	microsoft:sharepoint_server	Server-side request forgery (ssrf) in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.
CVE-2026-70479	7.7	HIGH		0.003		Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. From 0.9.6 until 0.11.0, with WEB_LOADER_ENGINE=playwright, the Playwright web loader validates only the top-level page request and lets sub-resource requests pass unvalidated. A page supplied by an authenticated user can use JavaScript to reach blocked internal addresses, and returned DOM can include data read from those address...
CVE-2026-77909	7.7	HIGH		0.006		Insufficiently protected credentials in Azure CycleCloud allows an authorized attacker to disclose information over a network.
CVE-2026-78623	7.7	HIGH		0.002		The Okta Access Gateway does not sanitize SAML assertion values before interpolating them into database queries in the advanced mode datastore configuration. The unsanitized values are substituted directly into the query string prior to preparation, resulting in unintended SQL execution against the configured backend database.
CVE-2026-81832	7.7	HIGH		0.003	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 SAP Adapter is vulnerable to an XML external entity (XXE) attack.
CVE-2026-84256	7.7	HIGH		0.004		An argument parsing issue in OpenVPN 2.1_rc10 through 2.6.22 and 2.7_alpha1 through 2.7.6 on Windows allows remote authenticated users to execute arbitrary commands via a crafted certificate subject
CVE-2026-9165	7.7	HIGH		0.005		A flaw was found in Red Hat Advanced Cluster Security for Kubernetes (RHACS). Central does not limit the depth of GraphQL queries served on the authenticated GraphQL API. An authenticated user with a valid API token can send deeply nested queries that cause excessive resource consumption in Central, resulting in a denial of service for the management plane.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70454	7.6	HIGH		0.002		rsync 3.2.0 through 3.2.3 (openssl mode) and rsync-ssl through 3.4.4 (stunnel mode) contain a TLS certificate validation vulnerability that allows on-path attackers to intercept encrypted sessions by presenting self-signed or otherwise invalid certificates. Attackers can exploit the failure to validate server TLS certificates against a trusted CA or verify certificate hostname matching to decrypt or tamper with rs...
CVE-2026-73408	7.6	HIGH		0.003		Budibase is an open-source low-code platform. Prior to 3.39.18, packages/server/src/integrations/mysql.ts enabled multipleStatements and inserted an unescaped tableName into a DESCRIBE statement. An attacker able to create a MySQL table with a backtick and stacked statement in its name could wait for a Budibase administrator to run schema discovery, causing the second statement to execute. The fix applies quoteMyS...
CVE-2026-82053	7.6	HIGH		0.002	mongodb:mongodb	A security issue exists in MongoDB's LDAP authorization integration where pooled LDAP connections can retain stale authentication identities after user authentication under certain configurations. Subsequent authorization queries may execute under an unintended LDAP identity rather than the expected one. This can result in incorrect role assignments based on the LDAP directory's access control configuration, poten...
CVE-2026-13297	7.5	HIGH		0.002		IBM Verify Identity Access Advanced Access Control may be vulnerable to an information disclosure attack.
CVE-2026-19300	7.5	HIGH		0.004	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote attacker to obtain sensitive information due to incomplete scrubbing of sensitive credential fields.
CVE-2026-19305	7.5	HIGH		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote attacker to obtain sensitive information due to server-side request forgery.
CVE-2026-26456	7.5	HIGH		0.003		A null pointer dereference vulnerability exists in the server-side session management logic of ccoap 77f55c4b466e99327c24ace8a2913d3ba7e2ccd5. The issue is caused by a race condition between the request dispatch thread and the session cleanup thread when accessing shared session list nodes without proper synchronization.
CVE-2026-46306	7.5	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: flow_dissector: do not dissect PPPoE PFC frames RFC 2516 Section 7 states that Protocol Field Compression (PFC) is NOT RECOMMENDED for PPPoE. In practice, pppd does not support negotiating PFC for PPPoE sessions, and the flow dissector driver has assumed an uncompressed frame until the blamed commit. During the review process of that commit [1]...
CVE-2026-52946	7.5	HIGH		0.006	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: fs/fcntl: fix SOFTIRQ-unsafe lock order in fasync signaling A SOFTIRQ-safe to SOFTIRQ-unsafe lock order deadlock can occur in send_sigio() and send_sigurg() when a process group receives a signal. When FASYNC is configured for a process group (PIDTYPE_PGID), both functions use read_lock(&tasklist_lock) to traverse the task list. However, they a...
CVE-2026-52998	7.5	HIGH		0.006	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nfnetlink_osf: fix potential NULL dereference in ttl check The nf_osf_ttl() function accessed skb->dev to perform a local interface address lookup without verifying that the device pointer was valid. Additionally, the implementation utilized an in_dev_for_each_ifa_rcu loop to match the packet source address against local interface ad...
CVE-2026-55215	7.5	HIGH		0.004		MariaDB Connector/Node.js is used to connect applications developed on Node.js to MariaDB and MySQL databases. Prior to versions 3.3.3, 3.4.6, and 3.5.3, when ssl is enabled without a pinned CA or server certificate, MariaDB Connector/Node.js sends credentials before completing certificate fingerprint validation. In lib/cmd/handshake/auth/handshake.js, a server that selects mysql_clear_password as the initial auth...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55552	7.5	HIGH		0.004		Yamcs is a mission control framework. Prior to 5.11.13, Yamcs StaticFileHandler.locateFile resolves an unauthenticated request path without using Path.normalize and Path.toAbsolutePath to confirm that the absolute path remains within the configured staticRoots. A path containing traversal segments can escape the intended web root and return an arbitrary readable host file. The flaw is in yamcs-core/src/main/java/o...
CVE-2026-56671	7.5	HIGH		0.007		ComfyUI is a modular diffusion model GUI, api and backend with a graph/nodes interface. Prior to 0.28.0, get_model_preview in app/model_manager.py joins an unrestricted filename route capture to a selected model directory without a containment check, allowing an unauthenticated remote attacker to use traversal, encoded traversal, absolute paths, or an unbounded path_index to read image-decodable files and enumerat...
CVE-2026-57098	7.5	HIGH		0.006	microsoft:remote_desktop_client	Improper verification of cryptographic signature in Windows RDP Client allows an unauthorized attacker to disclose information over a network.
CVE-2026-57099	7.5	HIGH		0.008		Allocation of resources without limits or throttling in ASP.NET Core allows an unauthorized attacker to deny service over a network.
CVE-2026-62759	7.5	HIGH		0.003		Authentication bypass by spoofing in Windows Netlogon allows an unauthorized attacker to perform spoofing over an adjacent network.
CVE-2026-62813	7.5	HIGH		0.006		Use after free in Active Directory Domain Services allows an authorized attacker to execute code over a network.
CVE-2026-64374	7.5	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: sched/rt: Have RT_PUSH_IPI be default off for non PREEMPT_RT RT migration is done aggressively. When a CPU schedules out a high priority RT task for a lower priority task, it will look to see if there's any RT tasks that are waiting to run on another CPU that is of higher priority than the task this CPU is about to run. If it finds one, it will ...
CVE-2026-64545	7.5	HIGH		0.005		In the Linux kernel, the following vulnerability has been resolved: net, bpf: check master for NULL in xdp_master_redirect() xdp_master_redirect() dereferences the result of netdev_master_upper_dev_get_rcu() without a NULL check, but that helper returns NULL when the receiving device has no upper-master adjacency. The reach guard only checks netif_is_bond_slave(). On bond slave release bond_upper_dev_unlink() d...
CVE-2026-66304	7.5	HIGH		0.007	microsoft:skype_for_business_server, microsoft:skype_for_business_server_subscription_edition	Server-side request forgery (ssrf) in Skype for Business allows an unauthorized attacker to disclose information over a network.
CVE-2026-66307	7.5	HIGH		0.006	microsoft:skype_for_business_server, microsoft:skype_for_business_server_subscription_edition	Integer underflow (wrap or wraparound) in Skype for Business allows an unauthorized attacker to deny service over a network.
CVE-2026-67376	7.5	HIGH		0.008	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Integer overflow or wraparound in SQL Server allows an unauthorized attacker to deny service over a network.
CVE-2026-68887	7.5	HIGH		0.008		Out-of-bounds read in Windows Message Queuing Queue Manager allows an unauthorized attacker to deny service over a network.
CVE-2026-69342	7.5	HIGH		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69378	7.5	HIGH		0.011		Uncontrolled recursion in Microsoft Exchange Server allows an unauthorized attacker to deny service over a network.
CVE-2026-69397	7.5	HIGH		0.006		Use after free in OpenSSH for Windows allows an unauthorized attacker to execute code over a network.
CVE-2026-69428	7.5	HIGH		0.011		Out-of-bounds read in Windows LDAP - Lightweight Directory Access Protocol allows an unauthorized attacker to deny service over a network.
CVE-2026-69429	7.5	HIGH		0.006		Heap-based buffer overflow in Windows IKE Extension allows an authorized attacker to execute code over a network.
CVE-2026-69443	7.5	HIGH		0.01		Out-of-bounds read in Windows Device Health Attestation (DHA) allows an unauthorized attacker to disclose information over a network.
CVE-2026-69514	7.5	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-69539	7.5	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-69587	7.5	HIGH		0.012		Null pointer dereference in Windows IKE Extension allows an unauthorized attacker to deny service over a network.
CVE-2026-69588	7.5	HIGH		0.012		Missing release of memory after effective lifetime in Windows TCP/IP allows an unauthorized attacker to deny service over a network.
CVE-2026-69599	7.5	HIGH		0.007	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-69607	7.5	HIGH		0.006		Use after free in Windows Deployment Services allows an unauthorized attacker to execute code over a network.
CVE-2026-69631	7.5	HIGH		0.012		Integer overflow or wraparound in Windows DNS allows an unauthorized attacker to deny service over a network.
CVE-2026-69710	7.5	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69739	7.5	HIGH		0.009	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-69744	7.5	HIGH		0.011		Null pointer dereference in Windows Kerberos allows an unauthorized attacker to deny service over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69760	7.5	HIGH		0.011		Out-of-bounds read in Windows Kerberos allows an unauthorized attacker to deny service over a network.
CVE-2026-69793	7.5	HIGH		0.008		Improper validation of consistency within input in Windows TCP/IP allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-69803	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-69804	7.5	HIGH		0.005	microsoft:sharepoint_server	Time-of-check time-of-use (toctou) race condition in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69805	7.5	HIGH		0.005		External control of file name or path in .NET allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-69809	7.5	HIGH		0.011		Missing release of memory after effective lifetime in Active Directory Domain Services allows an unauthorized attacker to deny service over a network.
CVE-2026-69852	7.5	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-69881	7.5	HIGH		0.012	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Null pointer dereference in Windows IKE Extension allows an unauthorized attacker to deny service over a network.
CVE-2026-69890	7.5	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Virtual Trusted Platform Module allows an authorized attacker to elevate privileges locally.
CVE-2026-69929	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-69930	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70065	7.5	HIGH		0.012	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing release of memory after effective lifetime in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-70124	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-70570	7.5	HIGH		0.004		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-70579	7.5	HIGH		0.01		Out-of-bounds read in Windows Mobile Broadband allows an unauthorized attacker to disclose information over a network.
CVE-2026-70587	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper null termination in Windows Remote Desktop Protocol allows an unauthorized attacker to disclose information over a network.
CVE-2026-70601	7.5	HIGH		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.9, 40.9.2, 41.2.2, and 42.0.0-beta.5, apps that expose Promise-returning functions to web content via contextBridge may be vulnerable to a context isolation bypass. Untrusted web content could obtain access to the isolated preload world and, through it, every capability the preload script has. In r...
CVE-2026-71330	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of sensitive system information to an unauthorized control sphere in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to disclose information over a network.
CVE-2026-72923	7.5	HIGH		0.012		In Microsoft.OpenApi.YamlReader from 2.0.0-preview.11 until 2.12.0 and from 3.0.0 until 3.10.0, and in Microsoft.OpenApi.Readers prior to 1.6.30, a small YAML OpenAPI document containing nested anchors and aliases can cause uncontrolled resource consumption when parsed through the public YAML reader APIs. YAML is parsed through SharpYaml, which represents aliases as shared nodes in a directed acyclic graph, so the...
CVE-2026-72928	7.5	HIGH		0.006	microsoft:windows_server_2025	Use after free in Windows DNS allows an authorized attacker to execute code over a network.
CVE-2026-72932	7.5	HIGH		0.01		Buffer over-read in Windows Message Queuing Queue Manager allows an unauthorized attacker to disclose information over a network.
CVE-2026-72943	7.5	HIGH		0.006		Use after free in Windows Deployment Services allows an authorized attacker to execute code over a network.
CVE-2026-72949	7.5	HIGH		0.011		Null pointer dereference in Windows SMB Server Network Transport Driver (srvnet.sys) allows an unauthorized attacker to deny service over a network.
CVE-2026-72954	7.5	HIGH		0.006		Use after free in Windows Deployment Services allows an authorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72989	7.5	HIGH		0.008		Use of uninitialized resource in Windows Failover Cluster allows an unauthorized attacker to disclose information over a network.
CVE-2026-73017	7.5	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Heap-based buffer overflow in Windows Graphics Kernel allows an authorized attacker to execute code locally.
CVE-2026-77494	7.5	HIGH		0.012	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77498	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77499	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77501	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77502	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77886	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77888	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77889	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77890	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77893	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77895	7.5	HIGH		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77898	7.5	HIGH		0.005	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-78523	7.5	HIGH		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows DNS allows an unauthorized attacker to deny service over a network.
CVE-2026-78574	7.5	HIGH		0.001		The Okta Hyperdrive Integration plugin resolves a required assembly using a registry path within the current user's hive without integrity verification. The referenced path is loaded via Assembly.LoadFrom without signature validation, resulting in an unverified assembly executing within the context of the host process or elevated installer.
CVE-2026-81270	7.5	HIGH		0.004		Apache Allura: exposure of non-public information via search. This issue affects Apache Allura: through 1.20.0. Users are recommended to upgrade to version 1.21.0, which fixes the issue.
CVE-2026-81381	7.5	HIGH		0.006	microsoft:visual_studio_code	Insufficiently protected credentials in GitHub Copilot and Visual Studio Code allows an unauthorized attacker to disclose information over a network.
CVE-2026-83989	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to deny service over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84001	7.5	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Key Distribution Center allows an unauthorized attacker to deny service over a network.
CVE-2026-84219	7.5	HIGH		0.002		The Kirki WordPress plugin before 6.3.0 does not hold back every spelling of the HTML entities it decodes when rendering, allowing unauthenticated users to store JavaScript in a comment which then runs in the session of anyone viewing a page that displays it, including an administrator, and on every page of the site when its header or footer is built to show comments.
CVE-2026-19651	7.4	HIGH		0.003		IBM Enterprise Build of Quarkus 3.27.1 through 3.27.5, and 3.33.1 through 3.33.3 could allow an attacker to bypass authorization by manipulating URL query parameters due to incorrect mapping of values to untrusted query string input.
CVE-2026-48084	7.4	HIGH		0.004		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Versions prior to 1.0.2 don't throttle failed passphrase login attempts. An attacker can submit unlimited wrong passphrase guesses against any known email address, capped only by the Argon2 verification cost (about 100 milliseconds per attempt on the tested host, giving 10 attempts per second sustained). The...
CVE-2026-62906	7.4	HIGH		0.007		Improper neutralization of special elements in data query logic in Microsoft Discovery Studio allows an unauthorized attacker to disclose information over a network.
CVE-2026-69347	7.4	HIGH		0.003		Heap-based buffer overflow in Windows Fast FAT Driver allows an unauthorized attacker to execute code locally.
CVE-2026-70604	7.4	HIGH		0.003		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.10, 40.9.3, 41.4.0, and 42.0.0, a custom scheme registered with supportFetchAPI: true but without corsEnabled: true was not subject to CORS enforcement. A page loaded from a remote origin could therefore fetch() or XMLHttpRequest that scheme cross-origin and read the full response body, rather than...
CVE-2026-78461	7.4	HIGH		0.01	microsoft:visual_studio_code	Improper limitation of a pathname to a restricted directory ('path traversal') in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-81383	7.4	HIGH		0.007	microsoft:visual_studio_code	Use of incorrectly-resolved name or reference in Visual Studio Code allows an unauthorized attacker to disclose information over a network.
CVE-2026-84003	7.4	HIGH		0.004	microsoft:azureVmsal-node	Authentication bypass by capture-replay in Microsoft Authentication Library (MSAL) for Node.js allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-13201	7.3	HIGH		0.002	kubevirt:kubevirt, redhat:openshift_virtualization	A flaw was found in KubeVirt's safepath package used by virt-handler. The OpenAtNoFollow function uses O_PATH O_NOFOLLOW to obtain a file descriptor to a path leaf, but downstream operations resolve the path via /proc/self/fd/N using link-following syscalls. When the leaf is a symlink, the kernel dereferences it, defeating the intended no-follow protection. An attacker with access to a virt-launcher pod can exploi...
CVE-2026-28613	7.3	HIGH		0.001	google:android	In initAppLinkTypeAndIntent of ChannellImpl.java, there is a possible launch an arbitrary intent due to improper input validation. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is needed for exploitation.
CVE-2026-28626	7.3	HIGH		0.001	google:android	In onCreate of SetupPassthroughActivity.java, there is a possible way to launch arbitrary activity due to Intent redirection . This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is needed for exploitation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-28656	7.3	HIGH		0.001	google:android	In multiple functions of DeviceAdminAdd.java, there is a possible way to an overlay due to a tapjacking/overlay attack. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is needed for exploitation.
CVE-2026-45528	7.3	HIGH		0.001		In getManageSpaceActivityResult of StorageManagerService.java, there is a possible LaunchAnyWhere chain due to an unsafe PendingIntent. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is needed for exploitation.
CVE-2026-69477	7.3	HIGH		0.004	microsoft:365_apps, microsoft:access, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office Access allows an authorized attacker to execute code locally.
CVE-2026-75857	7.3	HIGH		0.002		CodeWhale versions >= 0.8.41 and < 0.8.64 contain a vulnerability in the exec_shell_interact (alias exec_interact) tool, whose approval_requirement returns ApprovalRequirement::Auto. This overrides the default Required approval for code-executing tools, so LLM-controlled stdin is written into an already-approved long-running interactive shell (e.g., a python3 -i REPL, mysql, ssh, or sudo -i session) without any ap...
CVE-2026-78627	7.3	HIGH		0.001		The Okta Hyperdrive Integration installer does not mask the OAuth client secret when passed as an MSI property. The credential is recorded in plaintext in the installer log, the Application Event Log, and the process command line, all of which are readable by an authenticated local user on the workstation.
CVE-2026-85028	7.3	HIGH		0.001		Creation of a temporary file in a directory with insecure permissions in the FPGA management tool installation component in AWS FPGA Development Kit (aws-fpga) before 2.3.4 might allow local users to execute arbitrary code with root privileges via crafted shell content placed at a predictable path in a world-writable temporary directory, which the installation step reads after elevating its own privileges. To r...
CVE-2026-19769	7.2	HIGH		0.002		The Ninja Forms – The Contact Form Builder That Grows With You plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Repeater Child 'type' Confusion via Unmatched Array Key in all versions up to, and including, 3.15.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a ...
CVE-2026-70608	7.2	HIGH		0.003		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.10, 41.10.3, and 42.0.1, a sandboxed iframe without the allow-popups keyword could still open a new window or trigger setWindowOpenHandler with no user interaction because new-window navigations taking the OpenURL path did not apply the iframe sandbox popup restriction. Apps that embed untrusted co...
CVE-2026-81349	7.2	HIGH		0.007		Improper neutralization of special elements used in an os command ('os command injection') in Azure HDInsights allows an authorized attacker to elevate privileges over a network.
CVE-2026-82061	7.2	HIGH		0.003	mongodb:mongodb	A use-after-free security issue exists in the server's query execution memory tracking subsystem. An authenticated user with read privileges can trigger a write to freed heap memory through a sequence of standard database commands, leading to server process crash or potential memory corruption. No user interaction is required.
CVE-2026-82071	7.2	HIGH		0.003	mongodb:mongodb	Insufficient validation of storage engine configuration options in MongoDB Server allows an authenticated user with write privileges to supply crafted parameters during collection creation that override internal storage metadata. This results in an out-of-bounds memory write in the server process, causing a denial of service via server crash, with potential for further impact including arbitrary code execution.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84387	7.2	HIGH		0.009		A improper neutralization of special elements used in a command ('command injection') vulnerability in Fortinet FortiSandbox 5.2.0, FortiSandbox 5.0.0 through 5.0.6, FortiSandbox 4.4.0 through 4.4.9 may allow attacker to execute unauthorized code or commands via <insert attack vector here>
CVE-2026-19671	7.1	HIGH		0.004		Malcolm's upload-processing pipeline (scripts/safe-extract.py) enforces entry-count, nesting-depth, and total-uncompressed-byte limits when extracting container archives (zip/tar/rar/7z via libarchive), but those limits are not applied when the uploaded file is a single-stream compressed format (.gz, .bz2, .xz, .lzma, .lz) that isn't a .tar.*-style archive. Any authenticated user permitted to upload PCAP/log files...
CVE-2026-20293	7.1	HIGH		0.001		A vulnerability in the Unified Extensible Firmware Interface (UEFI) Shell implementation of Cisco UCS Servers and UCS-based appliances could allow an authenticated attacker with valid credentials for a user account with the role of user or admin or an unauthenticated attacker with physical access to an affected device to bypass UEFI Secure Boot validation checks and execute unauthorized software. This vuln...
CVE-2026-46033	7.1	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: crypto: authencsn - reject short ahash digests during instance creation authencsn requires either a zero authsize or an authsize of at least 4 bytes because the ESN encrypt/decrypt paths always move 4 bytes of high-order sequence number data at the end of the authenticated data. While crypto_authenc_esn_setauthsize() already rejects explicit ...
CVE-2026-52942	7.1	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nf_log: validate MAC header was set before dumping it The fallback path of dump_mac_header() guards the MAC header access only with "skb->mac_header != skb->network_header", without checking skb_mac_header_was_set(). When the MAC header is unset, mac_header is 0xffff, so the test passes and skb_mac_header(skb) returns skb->head + 0xff...
CVE-2026-53223	7.1	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: guard timestamp cmsgs to real error queue skbs skb_is_err_queue() treats PACKET_OUTGOING as the sole marker for an skb from sk_error_queue. That assumption is not true for AF_PACKET sockets: outgoing packet taps are also delivered to packet sockets with skb->pkt_type == PACKET_OUTGOING, but their skb->cb is owned by AF_PACKET instead of str...
CVE-2026-64317	7.1	HIGH		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: isofs: bound Rock Ridge symlink components to the SL record get_symlink_chunk() and the SL handling in parse_rock_ridge_inode_internal() walk the variable-length components of a Rock Ridge "SL" (symbolic link) record. Each component is a two-byte header (flags, len) followed by len bytes of text, so it occupies slp->len + 2 bytes. Both loops r...
CVE-2026-64379	7.1	HIGH		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: smb: client: mask server-provided mode to 07777 in modefromsid When modefromsid is active, parse_dacl() applies the server-provided sub_auth[2] value from the NFS mode SID to cf_mode without masking to 07777. Apply the correct masking, same as in the read path.
CVE-2026-64411	7.1	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: ebttables: terminate table name before find_table_lock() update_counters() and compat_update_counters() forward a user-supplied 32-byte table name to find_table_lock() without NUL-terminating it. On a lookup miss, find_inlist_lock() calls try_then_request_module(..., "%s%s", "ebtable_", name), and vsnprintf() reads past the name field ...
CVE-2026-64412	7.1	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: ebttables: module names must be null-terminated We need to explicitly check the length, else we may pass non-null terminated string to request_module().
CVE-2026-64422	7.1	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: ipv4: bound TCP reordering sysctl writes and MTU probe sizes Reject invalid `net.ipv4.tcp_reordering` values before they reach TCP socket state. The sysctl is stored as an `int` but copied into the `u32` `tp->reordering` field for new sockets, so negative writes wrap to large values. With `tcp_mtu_probing=2`, the wrapped value can overflow...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-66305	7.1	HIGH		0.003	microsoft:skype_for_business_server, microsoft:skype_for_business_server_subscription_edition	Use of client-side authentication in Skype for Business allows an authorized attacker to perform spoofing over a network.
CVE-2026-68835	7.1	HIGH		0.005		Use after free in Windows Print Spooler Components allows an authorized attacker to elevate privileges over a network.
CVE-2026-68846	7.1	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges over a network.
CVE-2026-68889	7.1	HIGH		0.004		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-68893	7.1	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows Remote Desktop Licensing Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69272	7.1	HIGH		0.004		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69274	7.1	HIGH		0.004		Use after free in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69296	7.1	HIGH		0.005		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69305	7.1	HIGH		0.006		Use after free in Microsoft Windows Search Component allows an authorized attacker to elevate privileges over a network.
CVE-2026-69313	7.1	HIGH		0.005		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69314	7.1	HIGH		0.005		Use after free in Windows Device Association Broker service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69336	7.1	HIGH		0.005		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69337	7.1	HIGH		0.007		Double free in Windows Registry allows an authorized attacker to elevate privileges over a network.
CVE-2026-69340	7.1	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69357	7.1	HIGH		0.004		Use after free in Windows NDIS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69364	7.1	HIGH		0.005		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Print Spooler Components allows an authorized attacker to elevate privileges over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69366	7.1	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges over a network.
CVE-2026-69396	7.1	HIGH		0.005		Use after free in Windows NDIS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69451	7.1	HIGH		0.007		Use after free in Windows Management Instrumentation allows an authorized attacker to elevate privileges over a network.
CVE-2026-69460	7.1	HIGH		0.005		Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges over a network.
CVE-2026-69482	7.1	HIGH		0.003		Creation of temporary file in directory with insecure permissions in Windows Error Reporting allows an authorized attacker to perform tampering locally.
CVE-2026-69536	7.1	HIGH		0.004	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-69553	7.1	HIGH		0.005		Missing authorization in Windows Hyper-V allows an authorized attacker to elevate privileges over a network.
CVE-2026-69597	7.1	HIGH		0.006		Use after free in Windows HTTP.sys allows an authorized attacker to elevate privileges over a network.
CVE-2026-69602	7.1	HIGH		0.006		Use after free in Windows PrintWorkflowUserSvc allows an authorized attacker to elevate privileges over a network.
CVE-2026-69688	7.1	HIGH		0.006		Heap-based buffer overflow in Windows Encrypting File System (EFS) allows an authorized attacker to elevate privileges over a network.
CVE-2026-69706	7.1	HIGH		0.004		Use after free in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69757	7.1	HIGH		0.007		Use after free in Windows TCP/IP allows an authorized attacker to elevate privileges over a network.
CVE-2026-69761	7.1	HIGH		0.005		Use after free in Windows TCP/IP allows an authorized attacker to elevate privileges over a network.
CVE-2026-69775	7.1	HIGH		0.005		Use after free in Windows DWM Core Library allows an authorized attacker to elevate privileges over a network.
CVE-2026-75132	7.1	HIGH		0.003		WAPT Server versions 2.6.1.17834 and earlier contains a SQL injection vulnerability in the `columns` parameter of the GET `/api/v3/hosts` endpoint. A remote authenticated user with read-only privileges can inject arbitrary PostgreSQL expressions into the SQL query constructed by WAPT. By exploiting the injection point, an attacker can inject additional PostgreSQL statements, bypass the host scope restrictions appl...
CVE-2026-76223	7.1	HIGH		0.002		ArcadeDB (com.arcadedb) versions 26.7.3 and earlier fail to enforce the UPDATE_SCHEMA permission check when a DEFINE FUNCTION statement targets an already-existing function library. A user with only database access can add or overwrite SQL or Cypher functions in an existing library and persist the change, enabling tampering with admin-defined function logic. The issue is fixed in 26.8.1. (JavaScript functions stil...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82052	7.1	HIGH		0.004	mongodb:mongodb	The \$regexFindAll expression can be used by an authenticated user who can run aggregation pipeline stages to crash a MongoDB server (mongod). Under certain specific conditions the regex match can start in the middle of a multi-code-unit character, triggering an assertion during query execution.
CVE-2026-82054	7.1	HIGH		0.003	mongodb:mongodb	A security issue exists in MongoDB server's JSON Pointer parser used during \$jsonSchema query filter processing. When a find command includes a specially crafted \$jsonSchema filter field, the parser processes the input without enforcing adequate limits on iteration count or total allocation size, resulting in significant memory amplification. Under concurrent request load, the cumulative memory consumption can ex...
CVE-2026-82055	7.1	HIGH		0.003	mongodb:mongodb	A security issue exists in MongoDB's 2dsphere index key generation that can cause a server crash due to a null pointer dereference. When a specially crafted GeoJSON document is inserted into a collection with a 2dsphere index, an inconsistency in geometry parsing can leave an internal object in an invalid, partially initialized state. During subsequent index key generation, access to this improperly initialized ob...
CVE-2026-82057	7.1	HIGH		0.003	mongodb:mongodb	A security issue was discovered in MongoDB where an authenticated user with readWrite privileges could crash the mongod server process. By specifying a custom WiredTiger storage configuration option with an incompatible value during collection creation, a user could cause a type confusion in the storage engine layer. When documents were subsequently read from the misconfigured collection, the resulting mismatch in...
CVE-2026-82058	7.1	HIGH		0.003	mongodb:mongodb	A flaw in MongoDB's JSON Schema validation error generation code allows an authenticated user with readWrite privileges to crash the mongod server. When a BSON document containing an array with a malformed numeric field name fails a \$jsonSchema items type constraint, the error generation path performs unsafe numeric conversion on the user-controlled field name without proper exception handling, resulting in an unc...
CVE-2026-82065	7.1	HIGH		0.003	mongodb:mongodb	A security issue in the MongoDB Server's storage engine integration layer allows an authenticated user with collection creation privileges to cause a persistent denial of service. Insufficient validation of user-supplied storage configuration options permits values that, once persisted to durable metadata, trigger a fatal assertion failure when the metadata is subsequently read by diagnostic operations. The corrup...
CVE-2026-82068	7.1	HIGH		0.003	mongodb:mongodb	A security issue in MongoDB Server allows an authenticated user with write privileges to trigger a persistent fatal assertion crash by sending specially crafted retryable write commands. The crash state is durably persisted, causing the server process to repeatedly crash on restart and potentially propagating to additional nodes in a sharded cluster. Manual intervention is required to restore service availability.
CVE-2026-82070	7.1	HIGH		0.002	mongodb:mongodb	A security issue in MongoDB Server's diagnostic reporting interface allows an authenticated user with monitoring privileges to access insufficiently protected credentials from concurrent administrative operations. The same credentials are properly redacted in server log output, but the diagnostic interface omits equivalent redaction. Successful exploitation requires a valid authenticated session with monitoring-le...
CVE-2026-82073	7.1	HIGH		0.003	mongodb:mongodb	A security issue in the MongoDB Server aggregation framework allows an authenticated user with limited read privileges to bypass view-level authorization checks and access data from unauthorized collections when Atlas Search features are in use. The issue stems from insufficient validation of an internal command parameter that can be set by external clients, causing a security check to be improperly skipped.
CVE-2026-82074	7.1	HIGH		0.002	mongodb:mongodb	MongoDB Server contains an incorrect authorization vulnerability in the aggregation framework. An authenticated user with minimal privileges can craft a specially formatted aggregation request that causes the server's authorization subsystem to evaluate a different operation than what is actually executed, resulting in unauthorized read access to collection data within the target database.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82076	7.1	HIGH		0.003	mongodb:mongodb	An integer overflow in the query planning component of MongoDB Server can allow an authenticated user with ordinary database-level read/write privileges to bypass an internal resource limit. Submitting a specially crafted query causes the server to consume memory without bound during query planning, and the resulting exhaustion terminates the server process. This may result in a denial of service affecting all dat...
CVE-2026-84192	7.1	HIGH		0.002		LibreNMS before 26.3.1 contains a stored cross-site scripting vulnerability in legacy PHP templates that output SNMP-sourced and syslog-sourced data without escaping. An attacker who controls a monitored network device can inject arbitrary JavaScript through SNMP interface descriptions or syslog program fields that executes when authenticated users view affected pages.
CVE-2026-85654	7.1	HIGH		0.001		Improper neutralization of special elements used in a template engine in the CDK generator in Amazon awslabs.dynamodb-mcp-server before 2.1.6 might allow a context-dependent actor to execute arbitrary code on the host that deploys the generated application via crafted table, index, or attribute names in a data model file.
CVE-2026-85689	7.1	HIGH		0.003		Ilmware 0.4.6 contains an SQL injection vulnerability in the collection-database layer (Ilmware/resources.py) where filter and lookup values are directly string-interpolated into SQL WHERE clauses without parameterization or escaping, in both the SQLite and PostgreSQL backends. The filter validator only checks keys against an allow-list and never sanitizes values. Attacker-controlled filter values reaching the pub...
CVE-2026-85787	7.1	HIGH		0.002		An incomplete list of disallowed inputs in the SQL validation component in Amazon awslabs postgres-mcp-server before version 1.1.7 might allow an unauthenticated actor to modify data beyond the read-only scope by placing crafted SQL into the content that is submitted when an authenticated user interacts with the MCP server. To remediate this issue, users should upgrade to version 1.1.7 or above.
CVE-2026-50349	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Ancillary Function Driver for WinSock allows an authorized attacker to elevate privileges locally.
CVE-2026-58230	7.0	HIGH		0.002	sap:approuter	SAP Approuter does not sufficiently validate certain token content under specific configurations. An unauthenticated attacker could send a specially crafted token to cause sensitive credential material to be sent to an attacker-controlled destination. The attack complexity is high due to non-default preconditions required in the target environment. This results in a high impact on confidentiality and a low impact ...
CVE-2026-62694	7.0	HIGH		0.003		Use after free in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-62727	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Telephony Service allows an authorized attacker to elevate privileges locally.
CVE-2026-64413	7.0	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: ebtables: zero chainstack array sashiko reports: looking at ebtables table translation, could a sparse cpu_possible_mask lead to an uninitialized pointer free? If cpu_possible_mask is sparse (for example, CPU 0 and CPU 2 are possible, but CPU 1 is not), the allocation loop skips CPU 1. If vmalloc_node() fails at CPU 2, the clea...
CVE-2026-68824	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Connected User Experiences and Telemetry allows an authorized attacker to elevate privileges locally.
CVE-2026-68825	7.0	HIGH		0.003		Use after free in Windows Bind Filter Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-68837	7.0	HIGH		0.002		Use after free in Windows File History Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68840	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Concurrent execution using shared resource with improper synchronization ('race condition') in Windows USB Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-68847	7.0	HIGH		0.002		Use after free in Windows Connected User Experiences and Telemetry allows an authorized attacker to elevate privileges locally.
CVE-2026-68884	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-68897	7.0	HIGH		0.002		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-69279	7.0	HIGH		0.003		Use after free in Windows Cloud Files Mini Filter Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69280	7.0	HIGH		0.002		Use after free in Windows Push Notifications allows an authorized attacker to elevate privileges locally.
CVE-2026-69281	7.0	HIGH		0.003		Use after free in Windows License Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-69287	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to elevate privileges locally.
CVE-2026-69299	7.0	HIGH		0.002		Use after free in Microsoft COM for Windows allows an authorized attacker to elevate privileges locally.
CVE-2026-69300	7.0	HIGH		0.002		Use after free in Windows Push Notifications allows an authorized attacker to elevate privileges locally.
CVE-2026-69309	7.0	HIGH		0.003		Double free in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-69310	7.0	HIGH		0.003		Use after free in Windows DNS allows an authorized attacker to elevate privileges locally.
CVE-2026-69311	7.0	HIGH		0.003		Use after free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69319	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Concurrent execution using shared resource with improper synchronization ('race condition') in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69331	7.0	HIGH		0.002		Use after free in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-69333	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69335	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69341	7.0	HIGH		0.003		Use after free in Windows Image Acquisition allows an authorized attacker to elevate privileges locally.
CVE-2026-69362	7.0	HIGH		0.003		Use after free in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69379	7.0	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Improper link resolution before file access ('link following') in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69383	7.0	HIGH		0.002		External control of file name or path in Windows Shell allows an authorized attacker to elevate privileges locally.
CVE-2026-69385	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows TCP/IP allows an authorized attacker to elevate privileges locally.
CVE-2026-69388	7.0	HIGH		0.003		Use after free in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69394	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69398	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69404	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows TCP/IP allows an authorized attacker to elevate privileges locally.
CVE-2026-69410	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69413	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69422	7.0	HIGH		0.003	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Use after free in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69430	7.0	HIGH		0.003		Use after free in Windows Embedded Mode Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69440	7.0	HIGH		0.002		Time-of-check time-of-use (toctou) race condition in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-69441	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-69448	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69466	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Time-of-check time-of-use (toctou) race condition in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-69468	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69470	7.0	HIGH		0.003		Use after free in Windows Connected User Experiences and Telemetry allows an authorized attacker to elevate privileges locally.
CVE-2026-69472	7.0	HIGH		0.003		Use after free in Windows Devices Human Interface allows an authorized attacker to elevate privileges locally.
CVE-2026-69473	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-69488	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69492	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Partition Management Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69498	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69500	7.0	HIGH		0.003		Use after free in Windows Image Acquisition allows an authorized attacker to elevate privileges locally.
CVE-2026-69501	7.0	HIGH		0.002	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Untrusted pointer dereference in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-69517	7.0	HIGH		0.003		Use after free in Windows Wireless Networking allows an authorized attacker to elevate privileges locally.
CVE-2026-69540	7.0	HIGH		0.003		Use after free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69560	7.0	HIGH		0.003		Use after free in Windows Work Folder Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69563	7.0	HIGH		0.002		Heap-based buffer overflow in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69564	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Online Certificate Status Protocol (OCSP) allows an authorized attacker to elevate privileges locally.
CVE-2026-69567	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows NTFS allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69573	7.0	HIGH		0.003		Use after free in Windows Universal Disk Format File System Driver (UDFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69574	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69575	7.0	HIGH		0.003		Use after free in Windows Storage Spaces Controller allows an authorized attacker to elevate privileges locally.
CVE-2026-69578	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Numeric truncation error in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-69581	7.0	HIGH		0.002		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69600	7.0	HIGH		0.003		Use after free in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69605	7.0	HIGH		0.003		Use after free in Microsoft Install Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69606	7.0	HIGH		0.003		Use after free in Windows Shell allows an authorized attacker to elevate privileges locally.
CVE-2026-69610	7.0	HIGH		0.003		Buffer over-read in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69613	7.0	HIGH		0.003		Use after free in Windows Image Acquisition allows an authorized attacker to elevate privileges locally.
CVE-2026-69617	7.0	HIGH		0.003		Out-of-bounds read in Windows Resilient File System (ReFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69621	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Fax Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69630	7.0	HIGH		0.003		Out-of-bounds read in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69645	7.0	HIGH		0.003		Use after free in Windows Message Queuing allows an authorized attacker to elevate privileges locally.
CVE-2026-69648	7.0	HIGH		0.003		Use after free in Windows Notification allows an authorized attacker to elevate privileges locally.
CVE-2026-69652	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69654	7.0	HIGH		0.003		Use after free in Windows Accounts Control allows an authorized attacker to elevate privileges locally.
CVE-2026-69682	7.0	HIGH		0.002		Use after free in Windows Host Guardian Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69692	7.0	HIGH		0.003		Use after free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69693	7.0	HIGH		0.003		Use after free in Windows Device Association Broker service allows an authorized attacker to elevate privileges locally.
CVE-2026-69694	7.0	HIGH		0.017		Deserialization of untrusted data in Windows IP Address Management (IPAM) Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69708	7.0	HIGH		0.003		Use after free in Windows Web Platform Storage allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69711	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69735	7.0	HIGH		0.003		Use after free in Windows Broadcast DVR User Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69779	7.0	HIGH		0.002		Time-of-check time-of-use (toctou) race condition in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69791	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69806	7.0	HIGH		0.018		Exposure of sensitive information to an unauthorized actor in .NET allows an authorized attacker to elevate privileges locally.
CVE-2026-69814	7.0	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Use after free in Windows Credential Providers allows an authorized attacker to elevate privileges locally.
CVE-2026-69816	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Accounts Control allows an authorized attacker to elevate privileges locally.
CVE-2026-69817	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Bluetooth Port Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69818	7.0	HIGH		0.003	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69834	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows ALPC allows an authorized attacker to elevate privileges locally.
CVE-2026-69838	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69859	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Time-of-check time-of-use (toctou) race condition in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69866	7.0	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69889	7.0	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69891	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Media allows an authorized attacker to elevate privileges locally.
CVE-2026-69896	7.0	HIGH		0.003	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Use after free in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69911	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-70283	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Incorrect authorization in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-70562	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Double free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70565	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows AF_UNIX Socket Provider allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70567	7.0	HIGH		0.003	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Double free in Windows Display Enhancement Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70568	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Defender Firewall Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70573	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70577	7.0	HIGH		0.003		Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-70578	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Credential Guard allows an authorized attacker to elevate privileges locally.
CVE-2026-70585	7.0	HIGH		0.003		Use after free in Windows Services for NFS ONCRPC XDR Driver allows an authorized attacker to execute code locally.
CVE-2026-71332	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Secure Socket Tunneling Protocol (SSTP) allows an authorized attacker to elevate privileges locally.
CVE-2026-71333	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-71340	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows File History Service allows an authorized attacker to elevate privileges locally.
CVE-2026-71342	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-71351	7.0	HIGH		0.003		Double free in Windows Routing and Remote Access Service (RRAS) allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-71353	7.0	HIGH		0.002		Double free in Windows Routing and Remote Access Service (RRAS) allows an authorized attacker to elevate privileges locally.
CVE-2026-72926	7.0	HIGH		0.003		Use after free in Windows Internet Connection Sharing (ICS) allows an authorized attacker to elevate privileges locally.
CVE-2026-72930	7.0	HIGH		0.003		Use after free in Windows Secure Socket Tunneling Protocol (SSTP) allows an authorized attacker to execute code locally.
CVE-2026-72952	7.0	HIGH		0.003		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to execute code locally.
CVE-2026-72963	7.0	HIGH		0.003		Use after free in Windows Modern Execution Server allows an authorized attacker to elevate privileges locally.
CVE-2026-73003	7.0	HIGH		0.002		Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-73005	7.0	HIGH		0.002		Use after free in Windows Authentication Methods allows an authorized attacker to elevate privileges locally.
CVE-2026-73022	7.0	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-77485	7.0	HIGH		0.002	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Use after free in SQL Server allows an authorized attacker to elevate privileges locally.
CVE-2026-77894	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-77899	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2012	Use after free in Windows Security Center allows an authorized attacker to elevate privileges locally.
CVE-2026-77905	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Management Instrumentation allows an authorized attacker to elevate privileges locally.
CVE-2026-78457	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2022, microsof	Use after free in Windows Security Health Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78464	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1	Time-of-check time-of-use (toctou) race condition in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-80093	7.0	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Cloud Files Mini Filter Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-81192	7.0	HIGH		0.001		`OpenTelemetry.Resources.Host` NuGet package, which provides OpenTelemetry resource detectors for host, is affected by an untrusted search path vulnerability on macOS. Prior to version 1.16.0-beta.2, the `host.id` resource attribute detector launches the `sh` and `ioreg` executables by bare name rather than by absolute path, so both are resolved through the `PATH` environment variable. A local attacker who is less...
CVE-2026-81389	7.0	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-82062	7.0	HIGH		0.004	mongodb:mongodb	A security issue in MongoDB Server allows an authenticated user with elevated internal privileges to bypass a disabled feature gate in the applyOps command by specifying an internal replication mode value that was not intended to be client-selectable. This bypass enables execution of container operations that are disabled by default in production configurations, allowing direct storage-engine writes to arbitrary i...
CVE-2026-83940	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83999	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Improper link resolution before file access ('link following') in Windows Resilient File System (ReFS) Deduplication Service allows an authorized attacker to elevate privileges locally.
CVE-2026-85360	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-15933	6.9	MEDI		0.004		OptimiDoc Server (On-Premise) stores credentials for external services in cleartext. An authenticated administrator can view previously configured service passwords, including SMTP, FTP (for scan delivery), Active Directory (for user list import), and SharePoint credentials, in cleartext via the web administration panel page source, allowing exposure of sensitive third-party authentication data. This issue was f...
CVE-2026-18401	6.9	MEDI		0.003		The non-blocking (asynchronous) JSON parser in jackson-core does not enforce the maxLength constraint defined in StreamReadConstraints (default: 1000 characters). An attacker able to submit JSON to an application that uses the async parser API can supply a number token of arbitrary length, leading to excessive memory allocation and potential CPU exhaustion, resulting in a denial of service. The synchronou...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70611	6.9	MEDI		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.9, 40.9.2, 41.2.1, and 42.0.0-beta.3, the DevTools reveal in file manager action could launch the target file rather than reveal it. An attacker with a separate means of running script inside the DevTools frontend, such as a malicious DevTools extension, could use showItemInFolder handling to execu...
CVE-2026-73848	6.9	MEDI		0.003		Emlog is an open source website building system. In versions 2.6.29 and prior, tag names in emlog are not HTML-encoded when rendered in the article editor. An attacker can create a tag containing ');alert(document.domain);//. The addslashes() function does not escape HTML entities, so ' is stored as-is. When the browser renders the page, it decodes ' back to a literal single quote before evaluating the JavaScript,...
CVE-2026-75135	6.9	MEDI		0.001		UpSignOn for Windows before 7.19.0 contains a sensitive data exposure vulnerability that allows local attackers to recover the master password and decrypt vault contents by reading a retained backup key from the process memory of UpSignOn.exe, even after the vault has been re-locked. Attackers can extract the backup key from process memory to decrypt the encrypted master password backup stored in v6-vault1.DATA.tx...
CVE-2026-75136	6.9	MEDI		0.001		UpSignOn for Windows before 7.19.0 contains an insecure credential storage vulnerability that allows local attackers to retrieve the biometric unlock key stored in the Windows PasswordVault API without triggering any authentication prompt. Attackers can access the stored biometric key from a standard local process within the same Windows session to decrypt the protected vault files and export the entire password m...
CVE-2026-75137	6.9	MEDI		0.001		UpSignOn for Windows before 7.19.0 contains a sensitive data exposure vulnerability that allows local attackers to recover cleartext vault data from process memory even after the application has been locked. Attackers can use the PROCESS_VM_READ permission to read the memory space of UpSignOn.exe and extract sensitive fields including entry names, URLs, usernames, passwords, TOTP secrets, and notes.
CVE-2026-83611	6.9	MEDI		0.004		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom version 0.6.0 and earlier, DOMParser.parseFromString() can silently accept an end tag such as </a!junk>, close the element, and discard the trailing content. On 0.9.x, the lib/sax.js end-tag validator inherits the multiline flag from reg(), all...
CVE-2026-86188	6.9	MEDI		0.003		AVideo with YPTSocket plugin enabled contains a cross-site scripting vulnerability allowing unauthenticated attackers to execute arbitrary JavaScript in other users' browsers via the websocket callback mechanism. Attackers can send crafted socket messages with callback names resolving to global functions like avideoConfirmHTML that accept untrusted data and assign it to innerHTML, achieving script execution in the...
CVE-2026-47763	6.8	MEDI		0.002		pdm is a Python package and dependency manager supporting the latest PEP standards. In versions prior to 2.27.0, pdm writes several project-local state or configuration files without symlink protection. If a malicious repository places those files as symlinks, local PDM operations can overwrite the symlink targets. This creates an arbitrary file clobber primitive relative to the privileges of the invoking user. Co...
CVE-2026-65812	6.8	MEDI		0.005		Insertion of sensitive information into sent data in Microsoft Teams for Android allows an authorized attacker to disclose information over a network.
CVE-2026-67352	6.8	MEDI		0.002		luci-app-https-dns-proxy contains a stored cross-site scripting vulnerability in the resolver_url parameter that allows authenticated users to inject active HTML. When an administrator views the HTTPS DNS Proxy status page, the resolver URL is rendered as raw HTML and executes JavaScript in the administrator's browser origin.
CVE-2026-68833	6.8	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code with a physical attack.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69415	6.8	MEDI		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing authentication for critical function in Windows DHCP Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-69490	6.8	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows USB Mass Storage Class Driver allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-69566	6.8	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-71329	6.8	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-71348	6.8	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Spaceport.sys allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-71349	6.8	MEDI		0.004		Heap-based buffer overflow in Windows Spaceport.sys allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-71350	6.8	MEDI		0.004		Heap-based buffer overflow in Windows Spaceport.sys allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-72985	6.8	MEDI		0.003		Heap-based buffer overflow in Windows Volume Shadow Copy allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-72999	6.8	MEDI		0.003		Out-of-bounds read in Windows USB Hub Driver allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-76227	6.8	MEDI		0.001		Renovate versions from 42.68.1 before 42.96.3 (and from 42.68.1 before 43.4.4), including corresponding Docker images (renovate/renovate, mend/renovate-ce, renovate-ee-server, renovate-ee-worker >=13.3.0 <13.6.0), fail to restrict environment variables to an allowlist when spawning child processes. As a result, child processes (e.g. npm install, postUpgradeTasks, postUpdateOptions) gain full access to all environm...
CVE-2026-77892	6.8	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	No cwe for this issue in Windows Boot Manager allows an unauthorized attacker to elevate privileges with a physical attack.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78451	6.8	MEDI		0.004	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Untrusted pointer dereference in Microsoft Windows SCSI Class System File allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-78579	6.8	MEDI		0.002		The Okta Access Gateway does not sanitize SAML assertion attribute values before interpolating them into LDAP search filters in the LDAP datastore configuration. The raw values are substituted directly into the filter string and passed to the LDAP search operation, resulting in modification of the intended query logic.
CVE-2026-84896	6.8	MEDI		0.002		The King Addons for Elementor WordPress plugin before 51.1.77 does not escape a widget display-style setting before outputting it in an HTML attribute, allowing users with Contributor-level access and above to store JavaScript that executes in the browser of any visitor to the affected page, including logged-in administrators.
CVE-2026-84899	6.8	MEDI		0.002		The VikWidgetsLoader WordPress plugin before 1.12.0 does not sanitise or escape a block attribute before outputting it inside an inline script, allowing users with the Contributor role to store arbitrary JavaScript that executes in the browser of any user viewing the affected post, including the administrator who reviews the pending submission.
CVE-2026-84931	6.8	MEDI		0.002		The Joli Table Of Contents WordPress plugin before 3.0.3 does not sanitise or escape a shortcode attribute value before outputting it inside an HTML element's attribute, allowing users with the Author role and above to inject arbitrary HTML attributes and JavaScript that execute in the browser of any user who views the post, including higher-privileged users such as administrators. This crosses a privilege boundar...
CVE-2026-85456	6.8	MEDI		0.001		MOOS-IvP through 24.8.1 fails to properly validate variable names extracted from alog files in the SplitHandler, allowing attackers to write files outside the split directory. Attackers can supply crafted alog files with backslash sequences in variable names to escape the output directory and append to arbitrary files on Windows systems.
CVE-2026-5522	6.7	MEDI		0.001		IBM QRadar 7.5.0 through 7.5.0 UP15 Interim Fix 005 contains hard-coded credentials, such as a password or cryptographic key, which it uses for its own inbound authentication, outbound communication to external components, or encryption of internal data.
CVE-2026-69350	6.7	MEDI		0.003		Heap-based buffer overflow in Windows Overlay Filter allows an authorized attacker to elevate privileges locally.
CVE-2026-69373	6.7	MEDI		0.003		Integer overflow or wraparound in Windows Overlay Filter allows an authorized attacker to elevate privileges locally.
CVE-2026-69449	6.7	MEDI		0.004		Heap-based buffer overflow in Windows BitLocker allows an authorized attacker to execute code locally.
CVE-2026-69820	6.7	MEDI		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Heap-based buffer overflow in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-70594	6.7	MEDI		0.002		Ghost is a Node.js content management system. From 2.2.0 until 6.54.1, Ghost Admin did not invalidate existing sessions on login which could have allowed for session fixation attacks. Successful exploitation would have required another vulnerability on the same domain where Ghost Admin was hosted. This issue is fixed in version 6.54.1.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-71339	6.7	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-72935	6.7	MEDI		0.003		Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-72948	6.7	MEDI		0.004		Relative path traversal in Windows DNS allows an authorized attacker to elevate privileges locally.
CVE-2026-78625	6.7	MEDI		0.002		The Okta Access Gateway does not sanitize dashboard label values before writing them into generated PHP configuration files. The generated file is automatically included during authentication requests, resulting in execution with the privileges of the web server process.
CVE-2026-78630	6.7	MEDI		0.002		The Okta Access Gateway does not neutralize shell metacharacters in SNMP configuration values before a privileged script uses them to construct OS commands. An authenticated local user with access to the management interface can supply crafted values, resulting in the execution of arbitrary OS commands with root privileges.
CVE-2026-85981	6.7	MEDI		0.001		The administrative panel of the Auth0 AD/LDAP Connector (versions 6.5.0 and earlier) listens on the local loopback interface without requiring authentication. This allows a local, low-privileged user or process on the host system to access the panel's management endpoints without credentials. Through these endpoints, a local user can read configuration details, including plaintext Active Directory service account ...
CVE-2026-69469	6.6	MEDI		0.004	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Integer overflow or wraparound in Windows USB Audio Class driver (usbaudio.sys) allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-70593	6.6	MEDI		0.003		Ghost is a Node.js content management system. From 0.10.0 until 6.54.1, a vulnerability in custom themes allowed a staff user to write files outside of the uploads directory. This could be used to alter the behavior of the installation through custom theme upload path traversal in LocalStorageBase and theme storage name handling. This issue is fixed in version 6.54.1.
CVE-2026-70602	6.6	MEDI		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, extension tab and scripting APIs were not scoped to the extension's own session. A malicious or compromised extension loaded into one session could navigate, script, and read from windows belonging to a different session. Apps are only affected if they load Chr...
CVE-2026-78545	6.6	MEDI		0.004		The Okta Access Gateway does not sanitize the application label field before including it in the generated nginx configuration file. The unsanitized value is interpolated into an nginx server block directive, resulting in execution of injected directives.
CVE-2026-78550	6.6	MEDI		0.004		The Okta Access Gateway management console passes user-supplied input to eval() without sanitization during an authenticated administrator SSH session. As a result, the unsanitized input is executed directly, leading to code execution with the privileges of the management console.
CVE-2026-15154	6.5	MEDI		0.005	redhat:openshift_ai	A flaw was found in `guardrails-detectors`, a component of Red Hat OpenShift AI. This vulnerability, known as Regular Expression Denial of Service (ReDoS), allows a remote attacker to provide specially crafted regular expressions to the public detection API. This can cause catastrophic backtracking, leading to a worker process consuming 100% CPU indefinitely and resulting in a denial of service for the entire guar...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-17259	6.5	MEDI		0.004	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to cause a denial of service due to a stack-based buffer overflow.
CVE-2026-18078	6.5	MEDI		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to cause a denial of service due to an integer overflow.
CVE-2026-18887	6.5	MEDI		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow an authenticated attacker to obtain sensitive information in PASE. An attacker could exploit this vulnerability to access information about process they shouldn't be permitted to access.
CVE-2026-19299	6.5	MEDI		0.005	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to obtain sensitive information due to path traversal.
CVE-2026-19301	6.5	MEDI		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to obtain sensitive information due to server-side request forgery.
CVE-2026-19302	6.5	MEDI		0.005	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to obtain sensitive information due to improper validation of symbolic links.
CVE-2026-44766	6.5	MEDI		0.002		SAP S/4HANA (Intercompany Matching and Reconciliation) allows a low-privileged authenticated user to inject malicious input into certain functions, which may be processed by the database without proper validation. This could allow the user to access sensitive information, resulting in high impact on confidentiality, with no impact on integrity and availability of the application.
CVE-2026-49466	6.5	MEDI		0.002		Draft List is a WordPress plugin to manage and promote unpublished content. Versions 2.6.3 and below are vulnerable to stored Cross-Site Scripting (XSS) in the `[drafts]` shortcode and Draft List widget when the documented custom `template` option places the `{{draft}}` placeholder inside an HTML attribute. The vulnerable code inserts the raw draft `post_title` into `{{draft}}` when the current viewer cannot edit ...
CVE-2026-55545	6.5	MEDI		0.003		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs WebSocket subscription handlers fail to enforce the privileges required by equivalent REST endpoints. PacketsApi.subscribePackets exposes the packets WebSocket topic without ObjectPrivilegeType.ReadPacket, ProcessingApi.subscribeAlgorithmStatus exposes the algorithm-status WebSocket topic without ObjectPrivilegeType.ReadAlgorithm, and MdbOverr...
CVE-2026-55549	6.5	MEDI		0.004		Yamcs is a mission control framework. Prior to 5.9.4, Yamcs reflects an attacker-controlled redirect_uri parameter from GET /auth/authorize into yamcs-core/src/main/resources/auth/templates/authorize.html without adequate HTML escaping by yamcs-core/src/main/java/org/yamcs/http/auth/AuthHandler.java and yamcs-core/src/main/java/org/yamcs/http/HandlerContext.java. A crafted authorization URL can execute JavaScript ...
CVE-2026-55855	6.5	MEDI		0.003		MariaDB Connector/Node.js is used to connect applications developed on Node.js to MariaDB and MySQL databases. Prior to 3.2.4, 3.3.3, 3.4.6, and 3.5.3, MariaDB Connector/Node.js permits SQL injection when attacker-controlled Buffer parameters are escaped client-side under the big5, gbk, sjis, cp932, or gb18030 client character sets. PacketOutputStream.writeBufferEscape in lib/io/packet-output-stream.js escaped byt...
CVE-2026-58649	6.5	MEDI		0.003		Origin validation error in .NET allows an unauthorized attacker to disclose information over a network.
CVE-2026-62762	6.5	MEDI		0.008		Null pointer dereference in Active Directory Domain Services allows an authorized attacker to deny service over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-62801	6.5	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper limitation of a pathname to a restricted directory ('path traversal') in Windows PowerShell allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-64918	6.5	MEDI		0.005	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Insufficiently protected credentials in Microsoft Office allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-66303	6.5	MEDI		0.008	microsoft:skype_for_business_server, microsoft:skype_for_business_server_subscription_edition	Null pointer dereference in Skype for Business allows an authorized attacker to deny service over a network.
CVE-2026-66306	6.5	MEDI		0.005	microsoft:skype_for_business_server, microsoft:skype_for_business_server_subscription_edition	Generation of error message containing sensitive information in Skype for Business allows an unauthorized attacker to disclose information over a network.
CVE-2026-66308	6.5	MEDI		0.006	microsoft:skype_for_business_server, microsoft:skype_for_business_server_subscription_edition	Out-of-bounds read in Skype for Business allows an authorized attacker to deny service over a network.
CVE-2026-66816	6.5	MEDI		0.007	microsoft:sql_server_2022, microsoft:sql_server_2025	Insufficient logging in SQL Server allows an authorized attacker to bypass a security feature over a network.
CVE-2026-67369	6.5	MEDI		0.007	microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67383	6.5	MEDI		0.01	microsoft:sql_server_2025	Generation of error message containing sensitive information in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67386	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Use of uninitialized resource in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67389	6.5	MEDI		0.007	microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67390	6.5	MEDI		0.01	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Buffer over-read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67393	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Buffer over-read in SQL Server allows an authorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67633	6.5	MEDI		0.008	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to deny service over a network.
CVE-2026-67641	6.5	MEDI		0.006	microsoft:sql_server_2022, microsoft:sql_server_2025	Integer overflow or wraparound in SQL Server allows an authorized attacker to deny service over a network.
CVE-2026-67645	6.5	MEDI		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67648	6.5	MEDI		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Use of uninitialized resource in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68776	6.5	MEDI		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Use of uninitialized resource in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68777	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68778	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68779	6.5	MEDI		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68780	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68781	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68784	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68898	6.5	MEDI		0.006		Out-of-bounds read in Windows iSCSI allows an unauthorized attacker to deny service over a network.
CVE-2026-69267	6.5	MEDI		0.003		Insufficient granularity of access control in Windows Connected User Experiences and Telemetry allows an authorized attacker to disclose information locally.
CVE-2026-69297	6.5	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Storing passwords in a recoverable format in Windows DHCP Server allows an authorized attacker to disclose information over a network.
CVE-2026-69361	6.5	MEDI		0.008		Server-side request forgery (ssrf) in Microsoft Exchange Server allows an authorized attacker to perform spoofing over a network.
CVE-2026-69374	6.5	MEDI		0.011		Allocation of resources without limits or throttling in Windows SMB Server allows an authorized attacker to deny service over a network.
CVE-2026-69375	6.5	MEDI		0.006		Authorization bypass through user-controlled key in Microsoft Exchange Server allows an authorized attacker to perform tampering over a network.
CVE-2026-69395	6.5	MEDI		0.009		Use of externally-controlled format string in Active Directory Certificate Services (AD CS) allows an authorized attacker to disclose information over a network.
CVE-2026-69409	6.5	MEDI		0.01	microsoft:sharepoint_server	Execution with unnecessary privileges in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.
CVE-2026-69497	6.5	MEDI		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing release of memory after effective lifetime in Windows DHCP Server allows an authorized attacker to deny service over a network.
CVE-2026-69624	6.5	MEDI		0.007		Incomplete list of disallowed inputs in Active Directory Certificate Services (AD CS) allows an authorized attacker to perform tampering over a network.
CVE-2026-69626	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Buffer over-read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-69636	6.5	MEDI		0.01	microsoft:sharepoint_server	Improper neutralization of special elements used in an sql command ('sql injection') in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.
CVE-2026-69719	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Buffer over-read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69734	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Integer overflow or wraparound in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-69781	6.5	MEDI		0.005	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Missing release of memory after effective lifetime in Windows DHCP Client allows an unauthorized attacker to deny service over an adjacent network.
CVE-2026-69839	6.5	MEDI		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Uncaught exception in Windows iSCSI Target Service allows an authorized attacker to deny service over a network.
CVE-2026-69855	6.5	MEDI		0.005	microsoft:azure_copilot	Server-side request forgery (ssrf) in Microsoft Copilot in Azure allows an authorized attacker to disclose information over a network.
CVE-2026-70019	6.5	MEDI		0.011	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Windows hard link in Windows Compressed Folder allows an unauthorized attacker to disclose information over a network.
CVE-2026-70429	6.5	MEDI		0.002	jenkins:jenkins	Jenkins 2.575 and earlier, LTS 2.568.1 and earlier handles case-insensitivity in user names and group names inconsistently, allowing attackers able to create new users or groups with names that case-insensitively match other characters to impersonate other users or be granted their permissions in some circumstances.
CVE-2026-70491	6.5	MEDI		0.003		Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. In 0.10.2 and earlier, the GET /api/v1/tools/, GET /api/v1/tools/list, and GET /api/v1/tools/id/{id} endpoints in backend/open_webui/routers/tools.py returned full Python tool source to authenticated non-admin read-only users. ToolResponse deliberately omitted source and specs, but ToolUserResponse permitted extra fields and hand...
CVE-2026-70493	6.5	MEDI		0.003		Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. From 0.9.6 until 0.11.0, the built-in knowledge search path in backend/open_webui/tools/knowledge_fs.py and backend/open_webui/tools/builtin.py let a chat participant choose a pattern used to grep knowledge files. Patterns containing regex metacharacters were compiled with Python's backtracking re engine and run against every lin...
CVE-2026-71437	6.5	MEDI		0.004		Mermaid is a JavaScript tool that uses Markdown-inspired text to create and modify diagrams and charts. From version 11.5.0 until 11.16.1, Mermaid Architecture Diagrams are vulnerable to prototype pollution when a diagram defines a group with an id of __proto__. Because the group id is used directly as an object property key without validation, an attacker who can supply diagram text can pollute Object.prototype, ...
CVE-2026-72739	6.5	MEDI		0.006		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the createCommand() function constructs shell commands by interpolating compose service names and configuration into bash command strings. When a compose with a maliciously crafted name or service definition is deployed, the shell metacharacters are interpreted as command separators, allowing arbitrary command execution on the Docker ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72938	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Access of resource using incompatible type ('type confusion') in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-72939	6.5	MEDI		0.011		Null pointer dereference in Windows Routing and Remote Access Service (RRAS) allows an authorized attacker to deny service over a network.
CVE-2026-72942	6.5	MEDI		0.009		Out-of-bounds read in Windows Spaceport.sys allows an unauthorized attacker to disclose information over a network.
CVE-2026-72956	6.5	MEDI		0.009	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Untrusted pointer dereference in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-72974	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Buffer over-read in Microsoft Office Excel allows an unauthorized attacker to disclose information over a network.
CVE-2026-72975	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-72977	6.5	MEDI		0.01	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-73029	6.5	MEDI		0.007	microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Buffer over-read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-76968	6.5	MEDI		0.002		SAP Web Dispatcher, Internet Communication Manager and SAP Content Server allows an authenticated low-privileged attacker to access certain administrative functionality or interface and obtain sensitive information about the system state, resulting in information disclosure. This disclosed information could potentially be used to facilitate further attacks. This vulnerability has a high impact on the confidentiality...
CVE-2026-76971	6.5	MEDI		0.001		Due to a Server-Side Request Forgery (SSRF) vulnerability in SAP Manufacturing Integration and Intelligence, an attacker could cause the server to initiate arbitrary outbound requests. If processed by the application, this behavior could be combined with XML/XSL processing to enable execution of scripts. Successful exploitation could result in a low impact on the confidentiality, integrity, and availability of the...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77911	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-78441	6.5	MEDI		0.007		Out-of-bounds read in Windows OLE DB allows an unauthorized attacker to disclose information over a network.
CVE-2026-78453	6.5	MEDI		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer underflow (wrap or wraparound) in Microsoft Windows SCSI Class System File allows an unauthorized attacker to disclose information over a network.
CVE-2026-78502	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-78503	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-78515	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information over a network.
CVE-2026-78520	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-78522	6.5	MEDI		0.007	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:word	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-78838	6.5	MEDI		0.004		A reflected cross-site scripting (XSS) vulnerability in the grid_datasource.php component of AppNitro MachForm v30 allows attackers to execute arbitrary Javascript in the context of the victim's browser via injecting a crafted payload into the filter[filters][0][field] parameter.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80073	6.5	MEDI		0.009	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:outlook	Out-of-bounds read in Microsoft Office Outlook allows an unauthorized attacker to disclose information over a network.
CVE-2026-80076	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80078	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80079	6.5	MEDI		0.009	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:word	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-80082	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80084	6.5	MEDI		0.007	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office Outlook allows an unauthorized attacker to disclose information over a network.
CVE-2026-80086	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-80087	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80088	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-80089	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80090	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-80091	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Use of uninitialized resource in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-81377	6.5	MEDI		0.008	microsoft:visual_studio_code	Improper limitation of a pathname to a restricted directory ('path traversal') in Visual Studio Code allows an unauthorized attacker to perform tampering over a network.
CVE-2026-84391	6.5	MEDI		0.002		A use of uninitialized variable vulnerability in Fortinet FortiAnalyzer 7.6.3 through 7.6.6 may allow attacker to denial of service via <insert attack vector here>
CVE-2026-86332	6.5	MEDI		0.002		A flaw was found in odh-dashboard in Red Hat OpenShift AI. The backend-for-frontend route GET /api/nim-serving/:nimResource reads Kubernetes Secrets using the dashboard service account and returns the full Secret object, including .data, without an authorization check. Any authenticated dashboard user can retrieve the cluster NVIDIA NGC API key Secret (apiKeySecret) and the NIM image pull secret (nimPullSecret). C...
CVE-2026-86550	6.5	MEDI		0.003		NuBrowser lacks protocol whitelist validation for the S.browser_fallback_url field of intent://, allowing attackers to inject javascript: URLs via 302 redirects. This results in a universal cross-site scripting (UXSS) vulnerability that enables script execution within the origin of arbitrary websites.
CVE-2026-86597	6.5	MEDI		0.001		Insertion of sensitive information into log files in the Snowflake Python, Go, JDBC, Node.js, PHP PDO, and ODBC drivers allowed authentication tokens, query-result encryption keys, pre-signed cloud-storage URLs, and SAML assertions to be written to diagnostic logs in circumstances where the available log redaction did not cover all affected log paths and data types. An attacker with read access to the log destinat...
CVE-2026-9186	6.5	MEDI		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 allows remote authenticated attackers to bypass localhost-only MCP configuration installation by spoofing X-Forwarded-For: 127.0.0.1 header, enabling arbitrary writes to IDE config files (~/.cursor/mcp.json, etc.).
CVE-2026-3853	6.4	MEDI		0.002		The Divi theme for WordPress is vulnerable to DOM-Based Stored Cross-Site Scripting via the `image_src` attribute of the `et_pb_video_slider_item` shortcode in all versions up to, and including, 4.27.6. This is due to the `image_src` field not being included in the `\$url_options` whitelist (which only contains `url`, `button_link`, `button_url`), so it never receives `esc_url_raw()` at save time. On the server sid...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-66760	6.4	MEDI		0.001	sap:approuter	SAP Approuter does not correctly validate client certificates in certain callback flows. An attacker with low privileges, holding a certificate from the same trusted authority with matching subject values, could bypass the identity check. This complexity makes the attack difficult to execute. Successful exploitation could allow impersonation of a trusted internal component, resulting in a high impact on integrity ...
CVE-2026-69874	6.4	MEDI		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Untrusted pointer dereference in Windows ALPC allows an authorized attacker to elevate privileges locally.
CVE-2026-69878	6.4	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Heap-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code locally.
CVE-2026-70582	6.4	MEDI		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Management Instrumentation allows an authorized attacker to elevate privileges locally.
CVE-2026-71338	6.4	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Double free in Windows Failover Cluster allows an authorized attacker to elevate privileges locally.
CVE-2026-72881	6.4	MEDI		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, database backup and restore command builders in packages/server/src/utlis/backups/utlis.ts and packages/server/src/utlis/restore/utlis.ts interpolate database names, usernames, and passwords into nested shell command strings passed to child_process.exec(). An authenticated administrator with permission to create databases and configur...
CVE-2026-72947	6.4	MEDI		0.003		Integer underflow (wrap or wraparound) in Windows File History Service allows an authorized attacker to elevate privileges locally.
CVE-2026-77887	6.4	MEDI		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an authorized attacker to execute code locally.
CVE-2026-77891	6.4	MEDI		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an authorized attacker to execute code locally.
CVE-2026-63642	6.3	MEDI		0.005		MagicMirror ² is an open source modular smart mirror platform. Prior to 2.37.0, checkArticleUrl in defaultmodules/newsfeed/node_helper.js accepts the CHECK_ARTICLE_URL notification through the unauthenticated Socket.IO namespace /newsfeed and performs fetch(url, { method: "HEAD" }) without validating the attacker-controlled URL. The helper returns ARTICLE_URL_STATUS containing the URL and framing result, providing ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70597	6.3	MEDI		0.001		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, the check Electron uses on macOS to confirm it was launched by a same-signed parent process could be bypassed by a local process. Apps that enable fuse-based hardening restricting ELECTRON_RUN_AS_NODE and NODE_OPTIONS to same-signed parents rely on this check, ...
CVE-2026-81824	6.3	MEDI		0.002		The vulnerability, if exploited, could allow a miscreant to run arbitrary JavaScript code in a browser session of a PIMBoards user who was socially engineered to click on a malicious link.
CVE-2026-81994	6.3	MEDI		0.003	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Improperly Controlled Modification of Object Prototype Attributes ('Prototype Pollution') vulnerability that could lead to arbitrary file system read. An attacker could exploit this vulnerability to access sensitive files and directories outside the intended access scope. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is chan...
CVE-2026-81997	6.3	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Incorrect Authorization vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized write access. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is changed.
CVE-2026-83610	6.3	MEDI		0.004		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom version 0.6.0 and earlier, Document.createEntityReference(name) accepts an invalid name and the ENTITY_REFERENCE_NODE serializer emits the resulting nodeName directly in &name; form. Directly serializing the node or fragment with XMLSerializer.s...
CVE-2026-84942	6.3	MEDI		0.003		Improper input validation in the Vega expression function implementation in OpenSearch Dashboards allows a remote authenticated actor with dashboard write permissions to execute arbitrary JavaScript in the context of other users' browser sessions by saving a crafted Vega visualization. The checkForFunctionProperty validation routine failed to recurse into arrays of objects, allowing a function property nested insi...
CVE-2026-86079	6.3	MEDI		0.003	n8n:n8n	n8n is an open source workflow automation platform. Prior to 1.123.76, 2.37.7, and 2.38.2, the Elasticsearch and ElasticSecurity nodes interpolated workflow-controlled index and document identifiers directly into REST request paths. An identifier containing path separators or dot segments could select another index or a cluster administration endpoint under the stored Elasticsearch credential. The affected request...
CVE-2026-86590	6.3	MEDI		0.004		In Eclipse Che versions 7.79.0 through 7.121.0, the dashboard backend's POST /dashboard/api/data/resolver endpoint passes a caller-supplied URL directly to an outbound HTTP GET request with no host filtering. An authenticated user can exploit this server-side request forgery (SSRF) to read responses from internal network addresses, including the cloud instance metadata service (169.254.169.254), loopback interface...
CVE-2026-81859	6.2	MEDI		0.001		CP4BA - IBM Enterprise Records could allow a local attacker to obtain sensitive information due to the use of a broken or risky cryptographic algorithm.
CVE-2026-86314	6.2	MEDI		0.001		Integer overflow in the source-bounds check in Memory::init() (src/runtime/Memory.cpp) in Samsung walrus on all platforms allows a remote attacker to cause an out-of-bounds heap read and denial of service via a crafted WebAssembly module in which a 32-bit unsigned addition wraps around and bypasses the bounds check. This issue affects Walrus: ff3bf5ff5c4878f8e5572c9593d303f6bc997443.
CVE-2026-86315	6.2	MEDI		0.001		An out-of-bounds write caused by numeric truncation Samsung Open Source Escargot on Linux x86-64 allows an attacker who can supply JavaScript for execution to corrupt native memory and crash the host process via a crafted class definition whose instance initialization entry count exceeds UINT16_MAX. This issue affects Escargot: 5dc93606abd42b859045add05d704a038e197359.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-24291	6.1	MEDI		0.004	versa-networks:versa_director	The Versa Director SD-WAN orchestration platform provides functionality to upload various types of files. However, the Java code handling file uploads contains an argument injection vulnerability. By appending additional arguments to the file name, an attacker can bypass MIME type validation, allowing the upload of arbitrary file types. This flaw can be exploited to place a malicious file on disk. Versa Network...
CVE-2026-32773	6.1	MEDI		0.007	apache:spark	There is a lack of XSS escaping in the Spark History Server prior to 3.5.8 which allows a malicious Spark job to generate arbitrary unescaped frontend code which could lead to a minimal privilege escalation in browser. Users are encouraged to upgrade to Spark 3.5.8 or later. This CVE is marked as "low" since the path to exploit requires both relatively high permissions (ability to launch a Spark job) and requires...
CVE-2026-52773	6.1	MEDI		0.005		YesWiki is a wiki system written in PHP. From version 4.1.0 to before version 4.6.6, YesWiki's archived-revision view reflects the time GET parameter into a hidden HTML input in handlers/page/show.php without escaping. Because MySQL coerces malformed DATETIME strings, an attacker can append HTML or JavaScript to a valid archived revision timestamp, still load that archived revision, and execute arbitrary JavaScript...
CVE-2026-52774	6.1	MEDI		0.005		YesWiki is a wiki system written in PHP. Prior to version 4.6.6, YesWiki's Bazar widget handler reflects the id GET parameter into HTML attributes using strip_tags() only. Because strip_tags() does not escape double quotes, an attacker can break out of the attribute value, inject an event handler such as onmouseover, and execute arbitrary JavaScript in the victim's browser. This issue is reachable without authenti...
CVE-2026-63523	6.1	MEDI		0.007	microsoft:skype_for_business_server, microsoft:skype_for_business_server_subscription_edition	Improper neutralization of input during web page generation ('cross-site scripting') in Skype for Business allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-69642	6.1	MEDI		0.003	microsoft:skype_for_business_server, microsoft:skype_for_business_server_subscription_edition	Improper neutralization of input during web page generation ('cross-site scripting') in Skype for Business allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-76002	6.1	MEDI		0.007		ColdFusion is affected by a reflected Cross-Site Scripting (XSS) vulnerability. If an attacker is able to convince a victim to visit a URL referencing a vulnerable page, malicious JavaScript content may be executed within the context of the victim's browser. Scope is changed.
CVE-2026-80180	6.1	MEDI		0.002		Stored XSS via markdown HTML processing in Apache Allura. This issue affects Apache Allura: from through 1.20.0. Users are recommended to upgrade to version 1.21.0, which fixes the issue.
CVE-2026-80190	6.1	MEDI		0.002		Apache Allura: stored XSS via SVN code repositories. Git repositories are not known to be affected. The vulnerability is likely mitigated via default CSP headers. This issue affects Apache Allura: through 1.20.0. Users are recommended to upgrade to version 1.21.0, which fixes the issue.
CVE-2026-8447	6.1	MEDI		0.002	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 suffer from a stored cross-site scripting vulnerability in the Playground chat interface.
CVE-2026-85229	6.1	MEDI		0.002		** UNSUPPORTED WHEN ASSIGNED ** Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Apache SkyWalking Booster UI. This issue affects Apache SkyWalking UI : from 10.2.0 through 10.4.0. Users are recommended to upgrade to Horizon UI 1.0.0, which fixes the issue.
CVE-2026-85484	6.1	MEDI		0.003		HTML::FormHandler versions before 0.410002 for Perl render option group labels and radio button labels into HTML without escaping. The Select, RadioGroup, CheckboxGroup and HorizCheckboxGroup widgets render a group label unescaped, Select into a label attribute and the other three into element content. RadioGroup also renders each radio button's own label unescaped. Any application whose option list is built fro...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85485	6.1	MEDI		0.002		HTML::FormHandler versions before 0.410002 for Perl render some error messages into HTML without escaping. The Table form layout and the Bootstrap 2 and 3 wrappers splice each error string straight into the surrounding markup. Version 0.410000, the fix for CVE-2026-19872, escaped the equivalent values in the other layouts and wrappers, and 0.410002 extended that to these three. Error messages that contain attack...
CVE-2026-85630	6.1	MEDI		0.003		HTML::FormHandler versions before 0.410002 for Perl render field attributes into HTML without escaping using the process_attrs method. Any application with fields or field labels where some attributes are built from data rather than literals allows attacker-influenced text in an attribute value that can override the field attributes or embed JavaScript in rendered pages. For example, the RadioGroup widget uses t...
CVE-2026-70603	6.0	MEDI		0.001		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.6, 40.9.0, 41.1.1, and 42.0.0-beta.1, shell.openPath() did not reject paths containing embedded null bytes. Apps that perform string-only validation of file paths, for example checking the file extension, before passing them to shell.openPath() could be bypassed, allowing an attacker-controlled pat...
CVE-2026-78552	6.0	MEDI		0.003		The Okta Access Gateway does not apply its Lua directive restriction to the application-level custom configuration field. The field is interpolated directly into the nginx server block without inspection, resulting in execution of injected directives.
CVE-2026-78622	6.0	MEDI		0.001		The Okta Verify for Windows uninstaller does not verify whether the user data directory is a filesystem junction before deleting its contents with elevated privileges. The delete operation follows the junction target, resulting in recursive deletion of unintended directory contents.
CVE-2026-82056	6.0	MEDI		0.002	mongodb:mongodb	A race condition in MongoDB server's text index query parsing can cause a heap use-after-free read when handling upsert retry paths. Under certain concurrent index lifecycle operations, a raw pointer to internal text index metadata may be dereferenced after the underlying structures have been freed, leading to a server crash. An authenticated user with readWrite privileges can trigger this condition through specif...
CVE-2026-82059	6.0	MEDI		0.003	mongodb:mongodb	An internal aggregation expression in MongoDB Server was incorrectly registered as accessible to any authenticated user rather than being restricted to internal cluster operations. By crafting a malformed index specification within this expression, an authenticated user with read-only privileges could trigger an assertion failure in the index key generation code path. In certain build configurations, this assertio...
CVE-2026-82063	6.0	MEDI		0.003	mongodb:mongodb	A use-after-free security issue in the cursor management component of MongoDB Server allows an authenticated user to cause a denial of service. Under specific timing conditions during cursor operations, a stale pointer to a freed resource may be retained and subsequently dereferenced during cursor cleanup, leading to a server process crash.
CVE-2017-4971	5.9	MEDI		0.168	broadcom:spring_web_flow	An issue was discovered in Pivotal Spring Web Flow through 2.4.4. Applications that do not change the value of the MvcViewFactoryCreator useSpringBinding property which is disabled by default (i.e., set to 'false') can be vulnerable to malicious EL expressions in view states that process form submissions but do not have a sub-element to declare explicit data binding property mappings.
CVE-2017-8039	5.9	MEDI		0.01	broadcom:spring_web_flow	An issue was discovered in Pivotal Spring Web Flow through 2.4.5. Applications that do not change the value of the MvcViewFactoryCreator useSpringBinding property which is disabled by default (i.e., set to 'false') can be vulnerable to malicious EL expressions in view states that process form submissions but do not have a sub-element to declare explicit data binding property mappings. NOTE: this issue exists becau...
CVE-2026-55854	5.9	MEDI		0.003		MariaDB Connector/Node.js is used to connect applications developed on Node.js to MariaDB and MySQL databases. Prior to 3.2.4, 3.3.3, 3.4.6, and 3.5.3, MariaDB Connector/Node.js can disclose an account password when PAM dialog authentication is negotiated over an insecure transport. In lib/cmd/handshake/auth/pam-password-auth.js and lib/cmd/handshake/authentication.js, the SendPamAuthPacketFactory behavior for the...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55856	5.9	MEDI		0.002		MariaDB Connector/J is used to connect applications developed in Java to MariaDB and MySQL databases. Prior to 2.7.14, 3.3.5, 3.4.3, and 3.5.9, when a Java application connects with sslMode=verify-full or sslMode=verify-ca, supplies a password, and does not configure serverSslCert or trustStore, Connector/J can accept an untrusted self-signed certificate through the fallbackToSystemTrustStore=true ephemeral trust ...
CVE-2026-55857	5.9	MEDI		0.002		MariaDB Connector/J is used to connect applications developed in Java to MariaDB and MySQL databases. Prior to 2.7.14, 3.3.5, 3.4.3, and 3.5.9, PAM dialog authentication can be coerced into transmitting the account password over an insecure connection. The mysql_clear_password plugin is gated behind a secure transport, but the sibling PAM handler SendPamAuthPacketFactory, named dialog by the server, does not decla...
CVE-2026-55858	5.9	MEDI		0.003		MariaDB Connector/J is used to connect applications developed in Java to MariaDB and MySQL databases. Prior to 2.7.14, 3.3.5, 3.4.3, and 3.5.9, the connector encodes and decodes protocol text and performs client-side escaping under the assumption that the connection character set is UTF-8. The server can report a mid-session change to character_set_client through OK-packet session-state tracking, including a chang...
CVE-2026-55859	5.9	MEDI		0.003		MariaDB Connector/R2DBC is a non-blocking MariaDB and MySQL client implemented in Java. Prior to 1.4.1, org.mariadb:r2dbc-mariadb encodes and decodes all character data under the assumption that the connection character set is UTF-8. A server can announce a mid-session change to character_set_client through the OK-packet session-state-tracking mechanism, including through SET NAMES executed by a stored routine or ...
CVE-2026-55860	5.9	MEDI		0.002		MariaDB Connector/R2DBC is a non-blocking MariaDB and MySQL client implemented in Java. Prior to 1.4.1, org.mariadb:r2dbc-mariadb does not gate clear-text password authentication plugins on transport encryption because the AuthenticationPlugin interface has no capability for a plugin to require a secure connection. A hostile or man-in-the-middle MariaDB server can send an AuthSwitchRequest naming mysql_clear_passw...
CVE-2026-58237	5.9	MEDI		0.002	sap:approuter	WebSocket of SAP Approuter does not perform sufficient authorization checks in certain functionality. An attacker with low privileges could exploit this to access restricted functionality. Successful exploitation could allow the attacker to read sensitive information and perform limited modifications, resulting in a high impact on confidentiality and a low impact on integrity. There is no impact on availability.
CVE-2026-58238	5.9	MEDI		0.003	sap:approuter	SAP Approuter does not sufficiently handle certain requests under specific conditions. An unauthenticated attacker could send specially crafted input that causes the component to crash and restart. Successful exploitation requires specific runtime conditions to be met, making the attack complex to execute. This results in a high impact on availability. There is no impact on confidentiality and integrity.
CVE-2026-66776	5.9	MEDI		0.001	sap:approuter	SAP Approuter does not consistently enforce integrity verification on certain session-related request headers under specific conditions. An attacker with low privileges could send a specially crafted request that bypasses the integrity check and loads another user's session context. Successful exploitation requires the attacker to have previously observed matching session values out-of-band, which makes the attack...
CVE-2026-66777	5.9	MEDI		0.003	sap:approuter	SAP Approuter does not sufficiently validate certain incoming requests before forwarding them to backend destinations. Due to the complexity of the required conditions, an attacker with low privileges could send specially crafted requests to bypass authorization checks and reach protected resources beyond their assigned scope. Successful exploitation could allow the attacker to read sensitive data and perform limi...
CVE-2026-69304	5.9	MEDI		0.008		Improper handling of highly compressed data (data amplification) in ASP.NET Core allows an unauthorized attacker to deny service over a network.
CVE-2026-69382	5.9	MEDI		0.004		Use of a broken or risky cryptographic algorithm in Microsoft Exchange Server allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70091	5.9	MEDI		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Concurrent execution using shared resource with improper synchronization ('race condition') in Windows DNS allows an unauthorized attacker to deny service over a network.
CVE-2026-70599	5.9	MEDI		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.7, 40.9.0, 41.2.0, and 42.0.0-beta.1, serial-port and media permission checks made from an iframe passed the top-level frame origin to session.setPermissionCheckHandler instead of the requesting iframe origin. Origin-based handler logic could grant a cross-origin iframe device access intended only ...
CVE-2026-70605	5.9	MEDI		0.003		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, when following HTTP redirects, net.fetch() and net.request() did not restrict which schemes a redirect could target. A remote server could redirect a request to a local resource, and if the app returns or forwards the response body, local file contents could be...
CVE-2026-70606	5.9	MEDI		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 40.10.6, 41.9.1, 42.5.1, and 43.0.0, when a custom protocol handler returned a ProtocolResponse with a url and no session, Electron made the upstream request through defaultSession instead of the session that handled the protocol. A cached response could then be reused across otherwise isolated session ...
CVE-2026-72978	5.9	MEDI		0.008		Allocation of resources without limits or throttling in Active Directory Federation Services (AD FS) allows an unauthorized attacker to deny service over a network.
CVE-2026-78221	5.9	MEDI		0.001		An incorrect buffer size calculation in the Windows Interactive Service in OpenVPN 2.7_alpha1 through 2.7.6 allows local authenticated users to cause memory corruption or disclose sensitive information via crafted NRPT inputs.
CVE-2026-78620	5.9	MEDI		0.003		The Okta Access Gateway Kerberos configuration handler does not validate file paths specified in event payloads before writing file contents. The path from the event payload is used directly as the write destination, resulting in files being written to unintended locations on the appliance filesystem.
CVE-2026-84185	5.9	MEDI		0.001		A flaw was found in the jwcrypto library, which is used for implementing Javascript Object Signing and Encryption (JOSE) standards. The issue occurs when the library verifies a General JSON Serialization JWS using a set of keys. Due to a coding error, the library fails to correctly identify the specific key ID (kid) and may instead accept a signature made by any valid key in the set. This can allow an attacker wit...
CVE-2026-69559	5.8	MEDI		0.003		Origin validation error in Microsoft Teams for Android allows an authorized attacker to disclose information over a network.
CVE-2026-74866	5.8	MEDI		0.002	fastify:fastifyV/busyboy	@fastify/busboy is a multipart form-data parser for Node.js. Its multipart part-header parser splits header lines only on the two-byte carriage-return line-feed sequence, so a lone carriage return or line feed embedded in a part header is not treated as a line break and is carried verbatim into the parsed Content-Disposition filename and field name handed to the application. An attacker who uploads a file whose fi...
CVE-2026-84193	5.8	MEDI		0.003		LibreNMS through 26.2.0 contains a stored cross-site scripting vulnerability in legacy PHP template pages that render unescaped SNMP-sourced data fields including BGP peer descriptions, VRF names, process information, and SLA tags. Attackers with device management access or network access to enroll a rogue SNMP device can inject malicious JavaScript that executes when admins view affected routing and device pages,...
CVE-2026-68874	5.7	MEDI		0.008		Out-of-bounds read in Windows Program Compatibility Assistant Service allows an authorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69349	5.7	MEDI		0.008		Use of uninitialized resource in Windows Management Instrumentation allows an authorized attacker to disclose information over a network.
CVE-2026-69372	5.7	MEDI		0.008		Out-of-bounds read in Windows Network File System allows an authorized attacker to deny service over a network.
CVE-2026-69393	5.7	MEDI		0.008		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to disclose information over a network.
CVE-2026-69405	5.7	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing release of memory after effective lifetime in Windows DHCP Server allows an authorized attacker to deny service over an adjacent network.
CVE-2026-69416	5.7	MEDI		0.006		Buffer over-read in Windows DHCP Server allows an authorized attacker to deny service over an adjacent network.
CVE-2026-69507	5.7	MEDI		0.008		Insertion of sensitive information into externally-accessible file or directory in Microsoft Windows Search Component allows an authorized attacker to disclose information over a network.
CVE-2026-69552	5.7	MEDI		0.009		Generation of error message containing sensitive information in Windows Print Spooler Components allows an authorized attacker to disclose information over a network.
CVE-2026-69569	5.7	MEDI		0.009		Untrusted pointer dereference in Windows Print Spooler Components allows an authorized attacker to deny service over a network.
CVE-2026-69572	5.7	MEDI		0.009		Out-of-bounds read in Windows SMB Client allows an authorized attacker to disclose information over a network.
CVE-2026-69591	5.7	MEDI		0.009	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to disclose information over a network.
CVE-2026-69637	5.7	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an authorized attacker to deny service over an adjacent network.
CVE-2026-69679	5.7	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an authorized attacker to deny service over an adjacent network.
CVE-2026-69723	5.7	MEDI		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of sensitive system information to an unauthorized control sphere in Windows Kernel allows an authorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70609	5.7	MEDI		0.004		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.7, 40.9.0, 41.2.0, and 42.0.0-beta.1, the mode option of webContents.openDevTools() was not sanitized before use by the DevTools frontend. If an attacker can influence this value, script under their control may run in the DevTools context, which in unsandboxed configurations has access to Node.js, ...
CVE-2026-78043	5.6	MEDI		0.002		The Windows Interactive Service in OpenVPN 2.7_alpha1 through 2.7.6 allows local authenticated users to bypass the trusted configuration directory constraint and load arbitrary configuration files via specially crafted paths
CVE-2026-78629	5.6	MEDI		0.001		The Okta Hyperdrive agent plugin returns a success response without a signed SAML assertion when the organization's policy requires no MFA for a given user. The response contains only a bare boolean validation indicator with no cryptographic artifact, resulting in an unverifiable authentication verdict being delivered to the relying application.
CVE-2026-81830	5.6	MEDI		0.001		The Windows interactive service in OpenVPN 2.4.0 through 2.6.22 allows local authenticated users to bypass the trusted configuration directory constraint via incorrect file path validation
CVE-2026-83557	5.6	MEDI		0.006		DefaultBaseTypeLimitingValidator is the PolymorphicTypeValidator applied automatically whenever @JsonTypeInfo is used without an explicitly configured custom validator. It denies polymorphic resolution only for a fixed set of "unsafe base types", and its isSafeSubType method returns true unconditionally for every base type outside that set. java.lang.Comparable was absent from the list despite being implemented by...
CVE-2023-53292	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: blk-mq: fix NULL dereference on q->elevator in blk_mq_elv_switch_none After grabbing q->sysfs_lock, q->elevator may become NULL because of elevator switch. Fix the NULL dereference on q->elevator by checking it with lock.
CVE-2025-48651	5.5	MEDI		0.001	google:android	In importWrappedKey of KMKeymasterApplet.java, there is a possible way access keys that should be restricted due to improper input validation. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-16689	5.5	MEDI		0.001	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a local attacker to obtain sensitive information due to improper logging of credentials.
CVE-2026-18858	5.5	MEDI		0.001	ibm:i	IBM i 7.6, and 7.5 could allow a local authenticated attacker to obtain information from a privileged file when using SSH.
CVE-2026-23255	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: add proper RCU protection to /proc/net/ptype Yin Fengwei reported an RCU stall in ptype_seq_show() and provided a patch. Real issue is that ptype_seq_next() and ptype_seq_show() violate RCU rules. ptype_seq_show() runs under rcu_read_lock(), and reads pt->dev to get device name without any barrier. At the same time, concurrent writers ca...
CVE-2026-23399	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: nf_tables: nft_dynset: fix possible stateful expression memleak in error path If cloning the second stateful expression in the element via GFP_ATOMIC fails, then the first stateful expression remains in place without being released. unreferenced object (percpu) 0x607b97e9cab8 (size 16): comm "softirq", pid 0, jiffies 4294931867 hex...
CVE-2026-28584	5.5	MEDI		0.001	google:android	In createSessionInternal of PackageInstallerService.java, there is a possible way to permanently DoS the device due to a logic error in the code. This could lead to local denial of service with no additional execution privileges needed. User interaction is not needed for exploitation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-28596	5.5	MEDI		0.001	google:android	In parseInterventionFromXml of GameManagerService.java, there is a possible permanent denial of service due to resource exhaustion. This could lead to local denial of service with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28617	5.5	MEDI		0.001	google:android	In add of WifiNetworkSuggestionsManager.java, there is a possible persistent DOS due to resource exhaustion. This could lead to local denial of service with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28633	5.5	MEDI		0.001	google:android	In initForUserNoTracing of VoiceInteractionManagerService.java, there is a possible persistent denial of service due to resource exhaustion. This could lead to local denial of service with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-31681	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: xt_multiport: validate range encoding in checkentry ports_match_v1() treats any non-zero pflags entry as the start of a port range and unconditionally consumes the next ports[] element as the range end. The checkentry path currently validates protocol, flags and count, but it does not validate the range encoding itself. As a result, ...
CVE-2026-43085	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nfnetlink_log: initialize nfgenmsg in NLMSG_DONE terminator When batching multiple NFLOG messages (inst->qlen > 1), __nf_nl_send() appends an NLMSG_DONE terminator with sizeof(struct nfgenmsg) payload via nlmsg_put(), but never initializes the nfgenmsg bytes. The nlmsg_put() helper only zeroes alignment padding after the payload, not...
CVE-2026-43089	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: xfrm_user: fix info leak in build_mapping() struct xfrm_usersa_id has a one-byte padding hole after the proto field, which ends up never getting set to zero before copying out to userspace. Fix that up by zeroing out the whole structure before setting individual variables.
CVE-2026-43216	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: Drop the lock in skb_may_tx_timestamp() skb_may_tx_timestamp() may acquire sock::sk_callback_lock. The lock must not be taken in IRQ context, only softirq is okay. A few drivers receive the timestamp via a dedicated interrupt and complete the TX timestamp from that handler. This will lead to a deadlock if the lock is already write-locked on...
CVE-2026-43492	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: lib/crypto: mpi: Fix integer underflow in mpi_read_raw_from_sgl() Yiming reports an integer underflow in mpi_read_raw_from_sgl() when subtracting "lzeros" from the unsigned "nbytes". For this to happen, the scatterlist "sgl" needs to occupy more bytes than the "nbytes" parameter and the first "nbytes + 1" bytes of the scatterlist must be zero. ...
CVE-2026-45376	5.5	MEDI		0.003		Decidim is a participatory democracy framework. Prior to 0.30.9, from 0.31.0 before 0.31.5, and in 0.32.0.rc1 before 0.32.0.rc2, the GET /admin/organization/users search interpolates params[:term] into raw Arel.sql ORDER BY similarity expressions before sanitization, allowing an authenticated organization administrator to execute blind PostgreSQL expressions and infer data through timing differences. This issue is...
CVE-2026-45841	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nfnetlink_osf: fix divide-by-zero in OSF_WSS_MODULO nf_osf_match_one() computes ctx->window % f->wss.val in the OSF_WSS_MODULO branch with no guard for f->wss.val == 0. A CAP_NET_ADMIN user can add such a fingerprint via nfnetlink; a subsequent matching TCP SYN divides by zero and panics the kernel. Reject the bogus fingerprint in nf...
CVE-2026-46021	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: thermal: core: Fix thermal zone governor cleanup issues If thermal_zone_device_register_with_trips() fails after adding a thermal governor to the thermal zone being registered, the governor is not removed from it as appropriate which may lead to a memory leak. In turn, thermal_zone_device_unregister() calls thermal_set_governor() without acquir...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-46040	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: inotify: fix watch count leak when fsnotify_add_inode_mark_locked() fails When fsnotify_add_inode_mark_locked() fails in inotify_new_watch(), the error path calls inotify_remove_from_idr() but does not call dec_inotify_watches() to undo the preceding inc_inotify_watches(). This leaks a watch count, and repeated failures can exhaust the max_user_...
CVE-2026-46046	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ext4: fix missing brelse() in ext4_xattr_inode_dec_ref_all() The commit c8e008b60492 ("ext4: ignore xattrs past end") introduced a refcount leak in when block_csum is false. ext4_xattr_inode_dec_ref_all() calls ext4_get_inode_loc() to get iloc.bh, but never releases it with brelse().
CVE-2026-46086	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: bridge: use a stable FDB dst snapshot in RCU readers Local FDB entries can be rewritten in place by `fdb_delete_local()`, which updates `f->dst` to another port or to `NULL` while keeping the entry alive. Several bridge RCU readers inspect `f->dst`, including `br_fdb_fillbuf()` through the `brforward_read()` sysfs path. These readers curre...
CVE-2026-46101	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: reject zero shift in nft_bitwise Reject zero shift operands for nft_bitwise left and right shift expressions during initialization. The carry propagation logic computes the carry from the adjacent 32-bit word using BITS_PER_TYPE(u32) - shift. A zero shift operand turns this into a 32-bit shift, which is undefined behaviour. Reject z...
CVE-2026-46132	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: rtnetlink: zero ifla_vf_broadcast to avoid stack infoleak in rtnl_fill_vfinfo rtnl_fill_vfinfo() declares struct ifla_vf_broadcast on the stack without initialisation: struct ifla_vf_broadcast vf_broadcast; The struct contains a single fixed 32-byte field: /* include/uapi/linux/if_link.h */ struct ifla_vf_broadcast { __u8 broadcast[...
CVE-2026-46172	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ipv6: xfrm6: release dst on error in xfrm6_rcv_encap() xfrm6_rcv_encap() performs an IPv6 route lookup when the skb does not already have a dst attached. ip6_route_input_lookup() returns a referenced dst entry even when the lookup resolves to an error route. If dst->error is set, xfrm6_rcv_encap() drops the skb without attaching the dst to the ...
CVE-2026-46193	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: xfrm: ah: account for ESN high bits in async callbacks AH allocates its temporary auth/ICV layout differently when ESN is enabled: the async ahash setup appends a 4-byte seqhi slot before the ICV or auth_data area, but the async completion callbacks still reconstruct the temporary layout as if seqhi were absent. With an async AH implementation ...
CVE-2026-52930	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ipc/shm: serialize orphan cleanup with shm_nattch updates shm_destroy_orphaned() walks the shm idr under shm_ids(ns).rwsem, but that does not serialize all fields tested by shm_may_destroy(). In particular, shm_nattch is updated while holding shm_perm.lock, and attach paths can do that without holding the rwsem. Do not decide that an orphaned ...
CVE-2026-52970	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nft_ct: fix missing expect put in obj eval nft_ct_expect_obj_eval() allocates an expectation and may call nf_ct_expect_related(), but never drops its local reference. Add nf_ct_expect_put(exp) before return to balance allocation.
CVE-2026-53001	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: xtables: restrict several matches to inet family This is a partial revert of: commit ab4f21e6fb1c ("netfilter: xtables: use NFPROTO_UNSPEC in more extensions") to allow ipv4 and ipv6 only. - xt_mac - xt_owner - xt_physdev These extensions are not used by ebtables in userspace. Moreover, xt_realn is only for ipv4, since dst->tbl...
CVE-2026-53012	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: nexthop: fix IPv6 route referencing IPv4 nexthop syzbot reported a panic [1] [2]. When an IPv6 nexthop is replaced with an IPv4 nexthop, the has_v4 flag of all groups containing this nexthop is not updated. This is because nh_group_v4_update is only called when replacing AF_INET to AF_INET6, but the reverse direction (AF_INET6 to AF_INET) is mi...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-53134	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nft_fib: fix stale stack leak via the OIFNAME register For NFT_FIB_RESULT_OIFNAME the destination register is declared with len = IFNAMSIZ (four 32-bit registers), but on the lookup-fail, RTN_LOCAL and oif-mismatch paths nft_fib{4,6}_eval() only writes one register via "*dest = 0". The remaining three registers are left as whatever wa...
CVE-2026-53218	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nft_exthdr: fix register tracking for F_PRESENT flag nft_exthdr_init() passes user-controlled priv->len to nft_parse_register_store(), which marks that many bytes in the register bitmap as initialized. However, when NFT_EXTHDR_F_PRESENT is set, the eval paths write only 1 byte (nft_reg_store8) or 4 bytes (*dest = 0 on TCP/DCCP error ...
CVE-2026-53219	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: x_tables: avoid leaking percpu counter pointers The native and compat get-entries paths copy the fixed rule entry header from the kernelized rule blob to userspace before overwriting the entry's counter fields with a sanitized counter snapshot. On SMP kernels, entry->counters.pcnt contains the percpu allocation address used by x_tabl...
CVE-2026-53236	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: tcp: restrict SO_ATTACH_FILTER to priv users This patch restricts the use of SO_ATTACH_FILTER (cBPF) on TCP sockets to users with CAP_NET_ADMIN capability. This blocks potential side-channel attack where an unprivileged application attaches a filter to leak TCP sequence/acknowledgment numbers.
CVE-2026-53249	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ipv4: restrict IPOPT_SSRR and IPOPT_LSRR options This patch restricts setting Loose Source and Record Route (LSRR) and Strict Source and Record Route (SSRR) IP options to users with CAP_NET_RAW capability. This prevents unprivileged applications from forcing packets to route through attacker-controlled nodes to leak TCP ISN and possibly other p...
CVE-2026-53269	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: synproxy: add mutex to guard hook reference counting As the synproxy infrastructure register netfilter hooks on-demand when a user adds the first iptables target or nftables expression, if done concurrently they can race each other. Introduce a mutex to serialize the refcount control blocks access from both frontends. While a per nam...
CVE-2026-53295	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: mailbox: add sanity check for channel array Fail gracefully if there is no channel array attached to the mailbox controller. Otherwise the later dereference will cause an OOPS which might not be seen because mailbox controllers might instantiate very early. Remove the comment explaining the obvious while here.
CVE-2026-64369	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: s390: Revert support for DCACHE_WORD_ACCESS load_unaligned_zeropad() reads eight bytes from unaligned addresses and may cross page boundaries. It handles exceptions which may happen if reading from the second page results in an exception. For pages which are donated to the Ultravisor for secure execution purposes the do_secure_storage_access() ...
CVE-2026-64370	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: posix-cpu-timers: Fix pid refcount leak in do_cpu_nanosleep() error path In do_cpu_nanosleep(), posix_cpu_timer_create() takes a pid reference via get_pid() and stores it in timer.it.cpu.pid. If the subsequent posix_cpu_timer_set() call fails, the function returns immediately without calling posix_cpu_timer_del() to release the pid reference, ca...
CVE-2026-64371	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: proc: protect ptrace_may_access() with exec_update_lock (part 1) Fix the easy cases where procfs currently calls ptrace_may_access() without exec_update_lock protection, where the fix is to simply add the extra lock or use mm_access(): - do_task_stat(): grab exec_update_lock - proc_pid_wchan(): grab exec_update_lock - proc_map_files_lookup()...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-64376	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: firmware_loader: fix device reference leak in firmware_upload_register() firmware_upload_register() -> fw_create_instance() -> device_initialize() After fw_create_instance() succeeds, the lifetime of the embedded struct device is expected to be managed through the device core reference counting, since fw_create_instance() has already cal...
CVE-2026-64425	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: io_uring/io-wq: re-check IO_WQ_BIT_EXIT for each linked work item commit 10dc95939817 ("io_uring/io-wq: check IO_WQ_BIT_EXIT inside work run loop") fixed the obvious case where io_worker_handle_work() took one exit-bit snapshot before draining pending work, but the fix stops one level too early. io_worker_handle_work() now re-checks IO_WQ_BIT_E...
CVE-2026-68830	5.5	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper link resolution before file access ('link following') in Windows Universal Plug and Play (UPnP) Device Host allows an authorized attacker to disclose information locally.
CVE-2026-68831	5.5	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Files or directories accessible to external parties in Windows Defender Firewall Service allows an authorized attacker to disclose information locally.
CVE-2026-68842	5.5	MEDI		0.004	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1	Exposure of sensitive system information to an unauthorized control sphere in Windows MIDI Service Module allows an authorized attacker to disclose information locally.
CVE-2026-68843	5.5	MEDI		0.003		Use after free in Microsoft Office Word allows an authorized attacker to disclose information locally.
CVE-2026-68851	5.5	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Buffer over-read in Windows NTFS allows an authorized attacker to disclose information locally.
CVE-2026-68852	5.5	MEDI		0.003		Use of uninitialized resource in Microsoft Account allows an authorized attacker to disclose information locally.
CVE-2026-68873	5.5	MEDI		0.005		Insertion of sensitive information into log file in Windows Program Compatibility Assistant Service allows an authorized attacker to disclose information locally.
CVE-2026-68881	5.5	MEDI		0.003		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-68886	5.5	MEDI		0.005		Use after free in Windows Network Connection Broker allows an authorized attacker to disclose information locally.
CVE-2026-69286	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to disclose information locally.
CVE-2026-69288	5.5	MEDI		0.003		Use of uninitialized resource in Windows GDI+ allows an authorized attacker to disclose information locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69294	5.5	MEDI		0.003		Generation of error message containing sensitive information in Microsoft COM for Windows allows an authorized attacker to disclose information locally.
CVE-2026-69308	5.5	MEDI		0.004		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-69315	5.5	MEDI		0.005		Exposure of sensitive system information to an unauthorized control sphere in Windows License Manager allows an authorized attacker to disclose information locally.
CVE-2026-69318	5.5	MEDI		0.004		Out-of-bounds read in Windows Imaging Component allows an authorized attacker to disclose information locally.
CVE-2026-69321	5.5	MEDI		0.003		Missing authentication for critical function in Windows Power Dependency Coordinator allows an authorized attacker to perform tampering locally.
CVE-2026-69339	5.5	MEDI		0.005		Exposure of sensitive system information to an unauthorized control sphere in Windows MIDI Service Module allows an authorized attacker to disclose information locally.
CVE-2026-69343	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Overlay Filter allows an authorized attacker to disclose information locally.
CVE-2026-69344	5.5	MEDI		0.004		Out-of-bounds read in Windows Print Spooler Components allows an authorized attacker to disclose information locally.
CVE-2026-69345	5.5	MEDI		0.004		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-69351	5.5	MEDI		0.005		Exposure of private personal information to an unauthorized actor in Windows Universal Plug and Play (UPnP) Device Host allows an authorized attacker to disclose information locally.
CVE-2026-69353	5.5	MEDI		0.004		Out-of-bounds read in Windows Text Shaping allows an authorized attacker to disclose information locally.
CVE-2026-69367	5.5	MEDI		0.004		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-69369	5.5	MEDI		0.003		Out-of-bounds read in Windows DNS allows an authorized attacker to disclose information locally.
CVE-2026-69376	5.5	MEDI		0.004		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-69390	5.5	MEDI		0.004		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to disclose information locally.
CVE-2026-69403	5.5	MEDI		0.003		Missing authorization in Windows SMB Server allows an authorized attacker to disclose information locally.
CVE-2026-69406	5.5	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of sensitive system information to an unauthorized control sphere in Windows Kernel allows an authorized attacker to disclose information locally.
CVE-2026-69453	5.5	MEDI		0.003		Missing authorization in Microsoft Windows Search Component allows an authorized attacker to perform tampering locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69457	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows USB Driver allows an authorized attacker to disclose information locally.
CVE-2026-69504	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to disclose information locally.
CVE-2026-69527	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows USB Mass Storage Class Driver allows an authorized attacker to disclose information locally.
CVE-2026-69531	5.5	MEDI		0.003		Unintended proxy or intermediary ('confused deputy') in Microsoft Windows Speech allows an authorized attacker to perform tampering locally.
CVE-2026-69554	5.5	MEDI		0.003		Missing authentication for critical function in Microsoft Windows Search Component allows an authorized attacker to perform tampering locally.
CVE-2026-69568	5.5	MEDI		0.004		Out-of-bounds read in Windows Storage Spaces Controller allows an authorized attacker to disclose information locally.
CVE-2026-69609	5.5	MEDI		0.004		Out-of-bounds read in Windows Win32K allows an authorized attacker to disclose information locally.
CVE-2026-69616	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Remote Desktop Services allows an authorized attacker to disclose information locally.
CVE-2026-69618	5.5	MEDI		0.004		Out-of-bounds read in Windows SMB Client allows an authorized attacker to disclose information locally.
CVE-2026-69627	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Remote Desktop Licensing Service allows an authorized attacker to disclose information locally.
CVE-2026-69672	5.5	MEDI		0.004		Use of uninitialized resource in Windows DNS allows an authorized attacker to disclose information locally.
CVE-2026-69674	5.5	MEDI		0.003		Missing authentication for critical function in Windows Modern Device Management (MDM) allows an authorized attacker to bypass a security feature locally.
CVE-2026-69684	5.5	MEDI		0.005		Generation of error message containing sensitive information in Windows Error Reporting allows an authorized attacker to disclose information locally.
CVE-2026-69741	5.5	MEDI		0.004		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to disclose information locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69770	5.5	MEDI		0.004		Use of uninitialized resource in Windows Spaceport.sys allows an authorized attacker to disclose information locally.
CVE-2026-69794	5.5	MEDI		0.004		Buffer over-read in Windows Encrypting File System (EFS) allows an authorized attacker to disclose information locally.
CVE-2026-69808	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Win32K allows an authorized attacker to disclose information locally.
CVE-2026-69862	5.5	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Wireless Wide Area Network Service allows an authorized attacker to disclose information locally.
CVE-2026-70145	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Microsoft Windows Search Component allows an authorized attacker to disclose information locally.
CVE-2026-70290	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use of uninitialized resource in Windows Win32 Kernel Subsystem allows an authorized attacker to disclose information locally.
CVE-2026-70592	5.5	MEDI		0.003		Ghost is a Node.js content management system. From 1.20.1 until 6.54.1, an Administrator-level user could remotely overwrite certain files on the filesystem through the database backup filename, leading to integrity and availability issues. The database export endpoint failed to reject path separators in the caller-supplied filename. This issue is fixed in version 6.54.1.
CVE-2026-71341	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Partition Management Driver allows an authorized attacker to disclose information locally.
CVE-2026-71441	5.5	MEDI		0.002	adobe:illustrator, apple:macos, microsoft:windows	Illustrator is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-72945	5.5	MEDI		0.004		Use of uninitialized resource in Windows Task Scheduler allows an authorized attacker to disclose information locally.
CVE-2026-72964	5.5	MEDI		0.003		Missing authentication for critical function in Windows Internet Connection Sharing (ICS) allows an authorized attacker to perform tampering locally.
CVE-2026-72966	5.5	MEDI		0.003		Missing authorization in Windows Remote Access Connection Manager allows an authorized attacker to perform tampering locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73004	5.5	MEDI		0.002		Missing authentication for critical function in Windows Autopilot allows an authorized attacker to perform tampering locally.
CVE-2026-73008	5.5	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of private personal information to an unauthorized actor in Windows Biometric Service allows an authorized attacker to disclose information locally.
CVE-2026-77488	5.5	MEDI		0.003	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Integer underflow (wrap or wraparound) in SQL Server allows an authorized attacker to disclose information locally.
CVE-2026-77491	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows GDI allows an unauthorized attacker to disclose information locally.
CVE-2026-78454	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows CD-ROM Driver allows an authorized attacker to disclose information locally.
CVE-2026-78506	5.5	MEDI		0.005	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Improper null termination in Microsoft Office Word allows an unauthorized attacker to disclose information locally.
CVE-2026-78513	5.5	MEDI		0.005	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information locally.
CVE-2026-79910	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-80160	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-80162	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81387	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Exposure of sensitive system information to an unauthorized control sphere in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81390	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81391	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Use of uninitialized resource in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81392	5.5	MEDI		0.005	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81393	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81394	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Exposure of sensitive system information to an unauthorized control sphere in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81395	5.5	MEDI		0.005	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81399	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Buffer over-read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81400	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81401	5.5	MEDI		0.005	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Access of resource using incompatible type ('type confusion') in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81958	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Use of uninitialized resource in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81977	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Integer Underflow (Wrap or Wraparound) vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81978	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81982	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81984	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81991	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81993	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Heap-based Buffer Overflow vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-82001	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Uncontrolled Resource Consumption vulnerability that could lead to application denial-of-service. An attacker could exploit this vulnerability to exhaust system resources, resulting in an application denial-of-service condition. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-83501	5.5	MEDI		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Out-of-bounds read in Windows Virtualization-Based Security (VBS) Enclave allows an authorized attacker to disclose information locally.
CVE-2026-83949	5.5	MEDI		0.004	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:word	Buffer over-read in Microsoft Office Word allows an unauthorized attacker to disclose information locally.
CVE-2026-83951	5.5	MEDI		0.004	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:word	Buffer over-read in Microsoft Office Word allows an unauthorized attacker to disclose information locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83991	5.5	MEDI		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Missing authentication for critical function in Windows Cloud Files Mini Filter Driver allows an authorized attacker to perform tampering locally.
CVE-2026-85875	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-86220	5.5	MEDI		0.003		A vulnerability was detected in SourceCodester Class and Exam Timetabling System 1.0. The affected element is the function mysqli_query of the file /admin/modal_add_course.php. The manipulation of the argument course results in sql injection. The attack can be launched remotely. The exploit is now public and may be used.
CVE-2026-86221	5.5	MEDI		0.003		A flaw has been found in SourceCodester Class and Exam Timetabling System 1.0. The impacted element is the function mysqli_query of the file /admin/modal_add_course1.php. This manipulation of the argument course causes sql injection. The attack may be initiated remotely. The exploit has been published and may be used.
CVE-2026-86223	5.5	MEDI		0.003		A vulnerability was found in SourceCodester Class and Exam Timetabling System 1.0. This impacts the function mysqli_query of the file /admin/modal_add_coursea.php. Performing a manipulation of the argument course results in sql injection. Remote exploitation of the attack is possible. The exploit has been made public and could be used.
CVE-2026-86225	5.5	MEDI		0.003		A vulnerability was identified in SourceCodester Class and Exam Timetabling System 1.0. Affected by this vulnerability is the function mysqli_query of the file /admin/modal_add_room.php. The manipulation of the argument room_name leads to sql injection. The attack is possible to be carried out remotely. The exploit is publicly available and might be used.
CVE-2026-86261	5.5	MEDI		0.004		A weakness has been identified in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. The impacted element is an unknown function of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Controller. Executing a manipulation of the argument userIdnf can lead to authorization bypass. The attack can be executed remotely. The exploit has been made available to the ...
CVE-2026-86263	5.5	MEDI		0.004		A vulnerability was detected in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. This impacts the function orderRecordsService.cancelOrder of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Cancellation. The manipulation of the argument ID results in authorization bypass. The attack may be performed from remote. The exploit is now public and may be used...
CVE-2026-86274	5.5	MEDI		0.004		A security vulnerability has been detected in projeto-siga siga up to 11.0.2.10/11.0.2.13/11.1.1. This affects the function ExAutenticacaoController.autenticar of the file sigaex/src/main/java/br/gov/jfrj/siga/vraptor/ExAutenticacaoController.java of the component Authentication Flow. Such manipulation of the argument cod/jwt leads to missing authorization. The attack may be launched remotely. The exploit has been...
CVE-2026-86282	5.5	MEDI		0.003		A weakness has been identified in jaychouchannel Tourism-Management-System up to 8122bf020d91199eddfff3ee02d1632a70a9a132. Affected is an unknown function of the file travel/src/main/java/com/controller/CommonController.java of the component CommonDao. Executing a manipulation of the argument table/column/xColumn/yColumn can lead to sql injection. The attack can be launched remotely. The exploit has been made avai...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86284	5.5	MEDI		0.003		A security vulnerability has been detected in jaychouchannel Tourism-Management-System up to 8122bf020d91199eddf3ee02d1632a70a9a132. Affected by this vulnerability is the function getOption of the file travel/src/main/java/com/controller/CommonController.java. The manipulation of the argument tableName/columnName leads to information disclosure. The attack may be initiated remotely. The exploit has been disclose...
CVE-2026-86318	5.5	MEDI		0.004		A flaw has been found in java-json-tools json-patch up to 1.13. Affected is the function JsonMergePatch.fromJson of the file JsonMergePatchDeserializer.java. Executing a manipulation can lead to stack-based buffer overflow. The attack may be performed from remote. The exploit has been published and may be used. The project was informed of the problem early through an issue report but has not responded yet.
CVE-2026-86321	5.5	MEDI		0.004		A vulnerability was found in java-json-tools jackson-coreutils 2.0. Affected by this issue is the function JsonLoader.fromURL of the file src/main/java/com/github/fge/jackson/JsonLoader.java of the component URL Validation. The manipulation results in server-side request forgery. It is possible to launch the attack remotely. The exploit has been made public and could be used. The project was informed of the proble...
CVE-2026-86511	5.5	MEDI		0.004		A vulnerability was found in java-json-tools jackson-coreutils 2.0. Affected by this vulnerability is the function BigDecimal.toPlainString of the file src/main/java/com/github/fge/jackson/JacksonUtils.java. Performing a manipulation results in resource consumption. The attack may be initiated remotely. The exploit has been made public and could be used. The project was informed of the problem early through an iss...
CVE-2026-86513	5.5	MEDI		0.004		A security flaw has been discovered in java-json-tools jackson-coreutils 2.0. This vulnerability affects the function TreePointer.tokensFromInput of the file src/main/java/com/github/fge/jackson/jsonpointer/TreePointer.java of the component JSON Pointer parser. The manipulation results in allocation of resources. The attack can be executed remotely. The exploit has been released to the public and may be used for a...
CVE-2026-86672	5.5	MEDI		0.003		A vulnerability has been found in ningzichun Student Management System up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected is an unknown function of the file example.7z of the component Backup Handler. The manipulation leads to information disclosure. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used. Continuous delivery with rolling releases is used by this pr...
CVE-2026-86673	5.5	MEDI		0.003		A vulnerability was determined in ningzichun Student Management System up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected by this issue is the function mysqli_connect of the file config/database.php of the component Database Connection. This manipulation causes hard-coded credentials. The attack may be initiated remotely. The exploit has been publicly disclosed and may be utilized. This product uses a rollin...
CVE-2024-11831	5.4	MEDI		0.011		A flaw was found in npm-serialize-javascript. The vulnerability occurs because the serialize-javascript module does not properly sanitize certain inputs, such as regex or other JavaScript object types, allowing an attacker to inject malicious code. This code could be executed when deserialized by a web browser, causing Cross-site scripting (XSS) attacks. This issue is critical in environments where serialized data...
CVE-2025-64542	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-64584	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64588	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64589	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64610	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64618	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64830	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64838	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64854	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64866	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64868	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-16892	5.4	MEDI		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to bypass security restrictions due to improper authentication during service-name matching.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19135	5.4	MEDI		0.002		A JEXL expression sandbox bypass exists in multiple versions of OpenNMS Meridian and Horizon. A low-privileged authenticated user can submit a crafted expression to the Measurements REST API that escapes the sandbox and loads arbitrary Java classes on the server. This can potentially allow an attacker to gain access to confidential information and compromise integrity. The solution is to upgrade to Meridian 2024....
CVE-2026-19479	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-19612	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-19644	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-19713	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-21269	5.4	MEDI		0.005	adobe:coldfusion	ColdFusion is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-27222	5.4	MEDI		0.003	adobe:bridge, apple:macos, microsoft:windows	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-27227	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-27258	5.4	MEDI		0.002	adobe:dng_software_development_kit	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-69402	5.4	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-69417	5.4	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-69690	5.4	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70610	5.4	MEDI		0.005		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.9, 40.9.2, 41.2.2, and 42.0.0-beta.4, objects copied across the contextBridge boundary from untrusted content could carry an attacker-influenced prototype, enabling prototype-pollution-style attacks against preload code despite context isolation being enabled. Apps are only affected if their preloa...
CVE-2026-70612	5.4	MEDI		0.005		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, requests to open external protocol URLs from web content did not take iframe sandbox restrictions into account, so a sandboxed iframe could cause an OS-registered external application to be launched. The frame sandbox state was also not made available to the ap...
CVE-2026-71356	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-71357	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-71388	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-71440	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-71565	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-72626	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-72627	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75629	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75635	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75636	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75637	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75639	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75640	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75642	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75643	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75644	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75646	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75647	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75651	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75652	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75657	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75659	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75660	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75661	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75666	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75667	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75668	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75669	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75670	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75671	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75672	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75674	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75675	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75677	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75678	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75679	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75680	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75681	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75683	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75685	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75687	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75690	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75691	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75692	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75693	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75694	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75695	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75696	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75700	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75701	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75702	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75704	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75705	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75706	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75707	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75708	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75709	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75710	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75711	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75712	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75713	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75714	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75715	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75716	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75717	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75718	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75719	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75720	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75722	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75724	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75725	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75727	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75729	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75730	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75731	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75733	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75734	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75735	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75736	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75737	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75738	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75739	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75740	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75741	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75742	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-79905	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-82396	5.4	MEDI		0.002		Sulu is an open-source PHP content management system based on the Symfony framework. Prior to versions 2.6.25 and 3.0.8, src/Sulu/Bundle/MediaBundle/Controller/MediaStreamController.php allows the /media/{id}/download/{slug} route and its administration variant to honor the inline query parameter for scriptable MIME types. The vulnerable stored Content-Type values include text/html, application/xhtml+xml, text/xml...
CVE-2026-84385	5.4	MEDI		0.001		A improper access control vulnerability in Fortinet FortiSOAR PaaS 7.6.0 through 7.6.6, FortiSOAR PaaS 7.5.0 through 7.5.3, FortiSOAR PaaS 7.4 all versions, FortiSOAR PaaS 7.3 all versions, FortiSOAR on-premise 7.6.0 through 7.6.6, FortiSOAR on-premise 7.5.0 through 7.5.3, FortiSOAR on-premise 7.4 all versions, FortiSOAR on-premise 7.3 all versions may allow attacker to escalation of privilege via <insert attack v...
CVE-2026-14350	5.3	MEDI		0.003		IBM Cloud Pak for Data System 11.3.0.2 through Interim Fix 001 could allow an unauthorized user to inject data into log messages due to improper neutralization of special elements when written to log files.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19032	5.3	MEDI		0.005		jackson-databind's deserializer for java.nio.file.Path resolves an attacker-supplied URI without restricting the URI scheme. In JDKFromStringDeserializer.NioPathHelper.deserialize, a string bound from untrusted JSON is passed to new URI(value) and then to Path.of(uri). When that throws FileSystemNotFoundException, the code enumerates ServiceLoader<FileSystemProvider> and calls provider.getPath(uri) on the first pr...
CVE-2026-19670	5.3	MEDI		0.002		Malcolm's nginx Lua role-based access control (RBAC) layer decides whether an authenticated user may reach a role-restricted path (e.g. /htadmin, /auth, /admin_login, /arkime/api/esadmin, NetBox, upload endpoints) by pattern-matching the raw, percent-encoded request URI. Nginx itself, however, selects which location block actually serves the request using the percent-decoded, normalized URI. Because the RBAC check...
CVE-2026-47680	5.3	MEDI		0.003		The source-controller is a Kubernetes operator, specialised in artifacts acquisition from external sources such as Git, OCI, Helm repositories and S3-compatible buckets. In versions 0.0.17 through 1.8.4, an actor with the ability to influence the contents of a bucket referenced by a `Bucket` resource can cause source-controller to write fetched object data to paths outside the per-reconciliation working directory....
CVE-2026-50159	5.3	MEDI		0.006		Mermaid is a JavaScript tool that uses Markdown-inspired text to create and modify diagrams and charts. Prior to 10.9.8 and 11.16.1, Mermaid is vulnerable to CSS injection via sibling combinator selectors generated from diagram-supplied class or id names. An attacker who can supply diagram text can inject arbitrary CSS into the rendered page, potentially altering the appearance or behavior of unrelated page elemen...
CVE-2026-56704	5.3	MEDI		0.002		Adminer before 5.4.3 inserts unsanitized database server version strings into script tags with valid CSP nonces without proper validation. Attackers controlling a rogue MySQL server can return crafted version strings that break out of the JavaScript context and execute arbitrary code, bypassing Content Security Policy protections.
CVE-2026-66778	5.3	MEDI		0.002	sap:approuter	SAP Approuter does not sufficiently sanitize certain request headers before forwarding traffic to internal components. An unauthenticated attacker could send a specially crafted request to obtain limited unauthorized access to information. This results in a low impact on confidentiality. There is no impact on integrity and availability.
CVE-2026-70466	5.3	MEDI		0.003	fortinet:fortiweb	A incomplete list of disallowed inputs vulnerability in Fortinet FortiWeb 8.0.0 through 8.0.2, FortiWeb 7.6.0 through 7.6.5, FortiWeb 7.4 all versions, FortiWeb 7.2 all versions, FortiWeb 7.0 all versions may allow attacker to improper access control via <insert attack vector here>
CVE-2026-70575	5.3	MEDI		0.008		Null pointer dereference in Windows Schannel allows an authorized attacker to deny service over a network.
CVE-2026-70607	5.3	MEDI		0.004		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, some window options supplied by web content in the window.open() features string were applied to the new BrowserWindow without an allowlist. Untrusted content could set window options it should not control, including options that cause the main process to acces...
CVE-2026-71216	5.3	MEDI		0.001		PagerDuty alarm hook transmits the integration routing key over cleartext HTTP. PagerDuty serves this endpoint over HTTPS and will normally answer plain HTTP with a redirect. That does not remove the exposure. The initial POST -- including the JSON body containing the routing key -- is written to the socket unencrypted before any redirect response is received. Redirection affects only whether the request is ret...
CVE-2026-71408	5.3	MEDI		0.005	fortinet:fortios	A allocation of resources without limits or throttling vulnerability in Fortinet FortiOS 7.6.0 through 7.6.6, FortiOS 7.4 all versions, FortiOS 7.2 all versions may allow attacker to denial of service via <insert attack vector here>
CVE-2026-71436	5.3	MEDI		0.004		Mermaid is a JavaScript tool that uses Markdown-inspired text to create and modify diagrams and charts. From version 10.6.0 until 10.9.8 and 11.16.1, Mermaid XY Charts are vulnerable to an infinite loop denial of service in the setXAxisRangeData function when configuring an X-Axis with invalid parameters. Because each loop iteration appends an element to an array, this generally causes a RangeError to appear after...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-71439	5.3	MEDI		0.004		Mermaid is a JavaScript tool that uses Markdown-inspired text to create and modify diagrams and charts. From version 11.6.0 until 11.16.1, Mermaid Radar Diagrams allow arbitrary large values for the ticks parameter, which can cause high CPU usage and freeze the rendering webpage or JavaScript process for long periods of time, potentially until the process is killed from memory exhaustion. This issue is fixed in ve...
CVE-2026-72834	5.3	MEDI		0.002		filebrowser before 2.63.19 contains a permission bypass in the /api/resources endpoint. The checksum (?checksum=) branch of resourceGetHandler reads the entire file to compute a digest and returns it without performing a Perm.Download check (unlike the sibling raw, preview, and subtitle paths). As a result, an authenticated user provisioned with Perm.Download=false can obtain a content-hash oracle for any same-sco...
CVE-2026-73840	5.3	MEDI		0.002		OpenChoreo is a complete, open-source developer platform for Kubernetes. Prior to 1.0.3, 1.1.3, and 1.2.0-rc.2, the POST /api/v1alpha1/autobuild endpoint in internal/openchoreo-api/api/handlers/webhook_handler.go selected a webhook provider from caller-controlled X-Event-Key, accepted Bitbucket requests without HMAC-SHA256 in X-Hub-Signature or a configured bitbucket-secret, and allowed unauthenticated build trigg...
CVE-2026-78446	5.3	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Distributed File System (DFS) allows an authorized attacker to deny service over a network.
CVE-2026-78631	5.3	MEDI		0.001		The Okta Hyperdrive Agent writes the decoded SAML bearer assertion to a local application log file at the default log level on every successful MFA completion. This insertion of sensitive information into the log file makes a live authentication credential readable by any local user with access to the log file.
CVE-2026-82066	5.3	MEDI		0.002	mongodb:mongodb	A heap out-of-bounds read security issue exists in the query planning component of MongoDB Server. An authenticated user with database read and write privileges can trigger the security issue through crafted query operations, causing the server to read memory beyond allocated buffer boundaries. The revealed memory contents may be partially observable through diagnostic query statistics output.
CVE-2026-84191	5.3	MEDI		0.002		LibreNMS before 26.5.0 contains stored cross-site scripting vulnerabilities in VRF display pages where mplsVpnVrfDescription, vrf_name, and mplsVpnVrfRouteDistinguisher fields from SNMP polling are rendered without sanitization. Attackers controlling a monitored network device can inject arbitrary JavaScript through SNMP responses that executes in the browser of any user viewing VRF-related pages.
CVE-2026-85158	5.3	MEDI		0.002		AVideo through commit c91b5975d contains a reflected cross-site scripting vulnerability in videoEmbedded.php that echoes the link parameter inside an HTML comment with zero escaping. Attackers can close the comment with --> and inject arbitrary JavaScript that executes when victims visit the crafted embed URL.
CVE-2026-85159	5.3	MEDI		0.002		AVideo through commit c91b5975d contains a reflected cross-site scripting vulnerability in userLogin.php where the cancelUri parameter is echoed in an href attribute after isSafeRedirectURL checks protocol only, not HTML characters. Unauthenticated attackers can inject event handlers via relative URLs with embedded quotes to execute arbitrary JavaScript when users interact with the Cancel button.
CVE-2026-85577	5.3	MEDI		0.003		AVideo through commit c91b5975d contains a reflected cross-site scripting vulnerability in userLogin.php that allows unauthenticated attackers to inject arbitrary JavaScript by closing the script tag with </script>. Attackers can craft a malicious URL with an error parameter containing script breakout sequences to execute arbitrary JavaScript in the victim's browser context on the login page.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-71404	5.1	MEDI		0.004		better-auth versions after v0.0.2 and before 1.1.16 contain a reflected cross-site scripting (XSS) vulnerability on the /api/auth/error page, where the value of the 'error' URL parameter is reflected as HTML without proper neutralization. An attacker who coerces a user into visiting a specially-crafted URL can execute arbitrary JavaScript in the context of the user's browser. The issue is fixed in version 1.1.16.
CVE-2026-48550	5.1	MEDI		0.003		Nagios Core before 4.5.14 and Nagios XI before 2026R1.7 are vulnerable to reflected cross-site scripting in cmd.cgi via the NagFormId parameter. An unauthenticated remote attacker can craft a malicious link that, when followed by an authenticated user, executes arbitrary JavaScript in the victim's browser.
CVE-2026-48552	5.1	MEDI		0.002		Nagios Core before 4.5.14 and Nagios XI before 2026R1.7 are vulnerable to DOM-based cross-site scripting in jquery.js. Unencoded JSON string values reflected from stored fields are inserted into the DOM without sanitization, allowing attackers to run arbitrary JavaScript in the victim's browser.
CVE-2026-67333	5.1	MEDI		0.002		better-auth before 1.6.13 (and pre-release builds 1.7.0-beta.0 through 1.7.0-beta.3) fail to validate the scheme of redirect_uris registered via the deprecated oidc-provider plugin and the mcp plugin (which wraps the same provider). An attacker can register an OAuth client with a javascript: redirect_uri, which the authorization server later returns unchanged in the consent response. If the deployment's consent pa...
CVE-2026-71503	5.1	MEDI		0.002		Dolibarr before 24.0.0 contains a reflected cross-site scripting vulnerability in the extra fields administration template where the type request parameter is echoed without JavaScript-context encoding into an inline script block and no Content-Security-Policy header is emitted. An unauthenticated attacker can cause an authenticated administrator to open a crafted URL to execute arbitrary JavaScript in that sessio...
CVE-2026-72747	5.1	MEDI		0.003		AVideo fails to sanitize the phone field during user registration, allowing unauthenticated attackers to inject malicious JavaScript that persists in the database. When administrators visit the users management page, the unsanitized phone value is rendered via innerHTML, executing the injected script in the admin's browser session.
CVE-2026-73319	5.1	MEDI		0.003	xenforo:xenforo	XenForo before 2.3.13 contains a cross-site scripting vulnerability in the dynamic redirect handler that allows unauthenticated attackers to execute arbitrary JavaScript in the board origin by crafting a malicious javascript: URI that bypasses host validation. Attackers can embed the board hostname in the URI authority component and use percent-encoded newlines to evade server-side filters, causing authenticated u...
CVE-2026-73409	5.1	MEDI		0.002		Budibase is an open-source low-code platform. Prior to 3.40.1, packages/server/src/integrations/mongodb.ts passed builder-controlled tlsCertificateKeyFile and tlsCAFile values directly to MongoClient on Budibase Cloud. A builder could submit absolute server paths through /api/datasources/verify and distinguish readable existing files from missing files by comparing the driver error, exposing a filesystem existence...
CVE-2026-75107	5.1	MEDI		0.002		Grav Form Plugin before 9.1.19 fails to escape field-definition properties including prepend, append, spacer text, section text, and select option labels in form templates. Attackers with form authoring privileges can inject arbitrary HTML and JavaScript that executes for all form visitors through unescaped raw filters and unquoted attributes.
CVE-2026-75831	5.1	MEDI		0.003		Grav before 2.0.15 contains a stored cross-site scripting vulnerability in the audio and video media rendering through the sourceParsedownElement method. The media URL fragment is concatenated unescaped into rawHtml source elements, allowing attackers to inject arbitrary HTML and JavaScript that executes in viewers' sessions.
CVE-2026-75834	5.1	MEDI		0.002		Grav before 2.0.14 contains a stored cross-site scripting vulnerability in the Security::detectXss() function (system/src/Grav/Common/Security.php). All XSS detection patterns use the PCRE /u (UTF-8) modifier, so a single invalid UTF-8 byte anywhere in page content causes preg_match() to return false for every pattern, silently bypassing the save-time XSS safety gate (Validation::checkSafety()). An authenticated a...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82024	5.1	MEDI		0.001		LearnPress WordPress Plugin before 4.4.6 contains a stored cross-site scripting vulnerability that allows authenticated attackers with the Instructor role to inject persistent malicious payloads by submitting unsanitized input into quiz question answer title fields. Attackers can store arbitrary JavaScript through the answer title parameter, which is rendered through an unescaped HTML sink to execute in the browse...
CVE-2026-82069	5.1	MEDI		0.003	mongodb:mongodb	A security issue in MongoDB Server's query statistics serialization on the router allows users with monitoring privileges to access unredacted search query text from other users' operations. An improper conditional check in the serialization logic causes the data redaction mechanism to be bypassed when processing search queries through the sharded cluster router. This results in sensitive query literals being stor...
CVE-2026-82881	5.1	MEDI		0.002		Aix-DB through 1.2.4 renders markdown with raw HTML enabled into v-html bindings without sanitization, allowing stored cross-site scripting attacks. Attackers can inject malicious HTML and JavaScript through markdown content in chat responses, skill descriptions, or knowledge messages that execute in users' browsers when viewed.
CVE-2026-84386	5.1	MEDI		0.001		A unverified ownership vulnerability in Fortinet FortiClientWindows 7.4.0 through 7.4.7, FortiClientWindows 7.2 all versions may allow attacker to improper access control via <insert attack vector here>
CVE-2026-85599	5.1	MEDI		0.002		Grav Shortcode Core before 6.2.5 contains stored cross-site scripting vulnerabilities in the [lorem] tag parameter and [details] summary parameter that are written to rendered pages without escaping. Attackers with page-edit access can inject arbitrary HTML and JavaScript that executes in the browsers of all page visitors, including administrators.
CVE-2026-85781	5.1	MEDI		0.003		Unverified ownership of a storage access point in the volume deletion component of the Amazon EFS CSI Driver before v3.4.1 might allow an authenticated Kubernetes user with PersistentVolume creation privileges to cause recursive deletion of directories on an EFS filesystem they are not authorized to access, via a crafted PersistentVolume volumeHandle that pairs an access point from one filesystem with a different ...
CVE-2026-86516	5.1	MEDI		0.002		A vulnerability was detected in elenavanengelenmaslova mocknest-serverless 0.9.0. The affected element is an unknown function of the file deployment/aws/shared/github-oidc-role.yaml of the component AWS GitHub OIDC Deployment Helper Script. Performing a manipulation results in improper privilege management. It is possible to initiate the attack remotely. The patch is named 6ab3147282d867c1993f995272750db091c2290b....
CVE-2026-4361	5.0	MEDI		0.003		The Divi theme for WordPress is vulnerable to Server-Side Request Forgery in all versions up to, and including, 4.27.6. This is due to the `et_pb_set_video_oembed_thumbnail_resolution()` function using `wp_remote_get()` instead of `wp_safe_remote_get()` to fetch a remote image URL, which does not restrict requests to private or reserved IP ranges. This makes it possible for authenticated attackers, with Contributo...
CVE-2026-70588	5.0	MEDI		0.003		Ghost is a Node.js content management system. From 5.26.0 until 6.54.1, the Universal Import feature in Ghost Admin failed to properly sanitize imported content resulting in XSS in post content. This issue is fixed in version 6.54.1.
CVE-2026-72976	5.0	MEDI		0.004	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Word allows an authorized attacker to disclose information locally.
CVE-2026-78635	5.0	MEDI		0.002		The Okta Privileged Access client URL handler does not insert an option terminator before appending the target value to the command-line arguments. When a scaleft:// protocol handler link contains a value beginning with a hyphen, the underlying CLI framework interprets it as a command-line flag, causing unintended modification of the SSH client's behavior.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-16693	4.9	MEDI		0.001	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to obtain sensitive information due to the use of hardcoded cryptographic constants to obfuscate encryption keys.
CVE-2026-22575	4.9	MEDI		0.002		An improper access control vulnerability in Fortinet FortiManager 7.6.0 through 7.6.4, FortiManager 7.4.0 through 7.4.10, FortiManager 7.2 all versions, FortiManager Cloud 7.6.2 through 7.6.4, FortiManager Cloud 7.4.1 through 7.4.10, FortiManager Cloud 7.2 all versions may allow an administrator to bypass the approval process for workflow sessions via crafted HTTP or HTTPS requests.
CVE-2026-68785	4.9	MEDI		0.008	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-78624	4.9	MEDI		0.004		The Okta Access Gateway backup restore function does not validate the filename embedded in an encrypted backup payload. This results in writing file contents to unintended locations on the appliance filesystem.
CVE-2026-45572	4.8	MEDI		0.002		Decidim is a participatory democracy framework. Prior to 0.30.9, from 0.31.0 before 0.31.5, and in 0.32.0.rc1 before 0.32.0.rc2, an administrator with landing-page editing privileges can store arbitrary HTML and JavaScript in an HTML content block, which Decidim::ContentBlocks::HtmlCell#html_content renders without sanitization, causing the script to execute in visitors' browsers. This issue is fixed in versions 0...
CVE-2026-69474	4.8	MEDI		0.007		Use after free in Windows Overlay Filter allows an authorized attacker to disclose information over a network.
CVE-2026-69615	4.8	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-70589	4.8	MEDI		0.002		Ghost is a Node.js content management system. From 4.22.0 until 6.54.1, a missing validation check allowed users to redeem subscription offers that were no longer active. This issue is fixed in version 6.54.1.
CVE-2026-70590	4.8	MEDI		0.002		Ghost is a Node.js content management system. Prior to 6.54.1, any staff-level user was able to leak the hashed passwords of other staff users through the Ghost Admin API. An offline password-guessing attack against the hashes could lead to account takeover if successful, but Device Verification should have prevented an attacker from logging in with a recovered password. Depending on the database used, leaked hash...
CVE-2026-75904	4.8	MEDI		0.001		libmodplug through 0.8.9.1 contains an out-of-bounds read in pat_smplooped in src/load_pat.cpp. The function validates only the upper bound of its sample index against MAXSMP and then subtracts one before indexing the 191-byte static array pat_loops, so an index of zero reads pat_loops[-1], one byte before the array. The index is the smpno field of a parsed MIDI event, which is initialised to zero and only later o...
CVE-2026-78560	4.8	MEDI		0.002		The Okta Access Gateway includes an optional pass-through authentication source that accepts user identity from a client-supplied HTTP header without cryptographic validation. In architectures where this optional source is enabled without an upstream reverse proxy or firewall configured to sanitize and enforce client headers, an unauthenticated user can supply an arbitrary identity value to initiate a session.
CVE-2026-85541	4.8	MEDI		0.003		DreamMaker developed by Interinfo has a Reflected Cross-site Scripting vulnerability. Authenticated remote attackers can execute arbitrary JavaScript codes in user's browser via a malicious website.
CVE-2026-18567	4.7	MEDI		0.001	ibm:db2_mirror_for_i	IBM Db2 Mirror for i 7.4, 7.5, and 7.6 could allow a local attacker to obtain information due to a race condition involving a predictable Unix domain socket path in a world-writable directory.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-53352	4.7	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: signal: clear JOBCTL_PENDING_MASK for caller in zap_other_threads() When a multi-threaded process receives a stop signal (e.g., SIGSTOP), do_signal_stop() sets JOBCTL_STOP_PENDING and JOBCTL_STOP_CONSUME on all threads and sets signal->group_stop_count to the number of threads. If one of the threads concurrently calls execve(), de_thread() invok...
CVE-2026-62845	4.7	MEDI		0.002		Kamaji is the Hosted Control Plane Manager for Kubernetes. Prior to 26.7.4-edge, the PostgreSQL and MySQL datastore drivers build DDL statements by interpolating the user-supplied DataStoreUsername/DataStoreSchema directly into SQL via fmt.Sprintf, without escaping identifiers. These fields have no format validation, so a value containing a quote character breaks out of the quoted identifier — SQL injection execut...
CVE-2026-64373	4.7	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: cpufreq: Fix hotplug-suspend race during reboot During system reboot, cpufreq_suspend() is called via the kernel_restart() -> device_shutdown() path. Unlike the normal system suspend path, the reboot path does not call freeze_processes(), so userspace processes and kernel threads remain active. This allows CPU hotplug operations to run concurre...
CVE-2026-68849	4.7	MEDI		0.002	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Out-of-bounds read in Windows Bluetooth Port Driver allows an authorized attacker to disclose information locally.
CVE-2026-68891	4.7	MEDI		0.002		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-69316	4.7	MEDI		0.003		Buffer over-read in Windows Overlay Filter allows an authorized attacker to disclose information locally.
CVE-2026-69425	4.7	MEDI		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1	Improper link resolution before file access ('link following') in Windows NTFS allows an authorized attacker to perform tampering locally.
CVE-2026-69483	4.7	MEDI		0.003		Out-of-bounds read in Windows Image Acquisition allows an authorized attacker to disclose information locally.
CVE-2026-69771	4.7	MEDI		0.003		Improper link resolution before file access ('link following') in Windows Container Manager Service allows an authorized attacker to bypass a security feature locally.
CVE-2026-69792	4.7	MEDI		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Win32K allows an authorized attacker to bypass a security feature locally.
CVE-2026-69832	4.7	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of sensitive system information to an unauthorized control sphere in Windows Win32K allows an authorized attacker to disclose information locally.
CVE-2026-69853	4.7	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use of uninitialized resource in Windows Win32K allows an authorized attacker to disclose information locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69895	4.7	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to disclose information locally.
CVE-2026-72931	4.7	MEDI		0.003		Missing release of resource after effective lifetime in Windows Secure Socket Tunneling Protocol (SSTP) allows an authorized attacker to deny service locally.
CVE-2026-69381	4.6	MEDI		0.004		Out-of-bounds read in Windows Storage Port Driver allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-69548	4.6	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows RNDIS allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-76959	4.6	MEDI		0.001		SAP S/4HANA Finance (Advanced Payment Management) does not perform sufficient Cross-Site Request Forgery protection on certain requests due to this an attacker with low privileges could craft a malicious link or page. If an authenticated victim interacts with it, unintended actions could be triggered on the web server on their behalf. This results in a low impact on confidentiality and integrity. There is no impac...
CVE-2026-78452	4.6	MEDI		0.005	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Out-of-bounds read in Microsoft Windows SCSI Class System File allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-78508	4.6	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows CD-ROM Driver allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-18073	4.4	MEDI		0.001	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local authenticated attacker to inject parameters into a CL command due to improper neutralization of special elements.
CVE-2026-69713	4.4	MEDI		0.003		Dependency on vulnerable third-party component in Windows Secure Boot allows an authorized attacker to bypass a security feature locally.
CVE-2026-72980	4.4	MEDI		0.003		Uncontrolled search path element in Windows Hello allows an authorized attacker to bypass a security feature locally.
CVE-2026-55547	4.3	MEDI		0.003		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs omits SystemPrivilege.ControlAccess checks from IamApi.listRoles, IamApi.getRole, and IamApi.listPrivileges in yamcs-core/src/main/java/org/yamcs/http/api/IamApi.java. Any authenticated account can call GET /api/roles, GET /api/roles/{name}, and GET /api/privileges to enumerate available system privileges and configured role mappings. The disc...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55566	4.3	MEDI		0.003		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs processes attacker-controlled data from the /ext URL route in yamcs-web/src/main/webapp/projects/webapp/src/app/core/routes/extension.matcher.ts, extension.component.ts, and app.component.ts without checking registered plugin IDs before DOM rendering through innerHTML. A crafted URL can execute JavaScript when opened by a user. The script can ...
CVE-2026-66761	4.3	MEDI		0.002	sap:approuter	SAP Approuter does not enforce sufficient flow control in certain functionality. An attacker with low privileges could send high volumes of data without consuming responses, causing unbounded memory growth. This results in a low impact on availability. There is no impact on confidentiality and integrity.
CVE-2026-66775	4.3	MEDI		0.001	sap:approuter	SAP Approuter does not enforce cross-site request forgery protection on the authentication flow by default. An unauthenticated attacker could craft a malicious link and trick a victim into following it. Successful exploitation could allow the attacker to bind the victim's session to an attacker-controlled identity, resulting in a low impact on integrity. There is no impact on confidentiality and availability.
CVE-2026-70427	4.3	MEDI		0.003	jenkins:jenkins	Jenkins 2.575 and earlier, LTS 2.568.1 and earlier does not safely handle symbolic links with effectively empty names during the extraction of `.tar` and `.tar.gz` archives, allowing attackers able to control agent processes to provide crafted archives to the controller to write files to arbitrary locations on the file system, restricted only by file system access permissions of the user running Jenkins.
CVE-2026-70428	4.3	MEDI		0.003	jenkins:jenkins	Jenkins 2.575 and earlier, LTS 2.568.1 and earlier improperly identifies file paths attempting path traversal in file parameter names, allowing attackers with Item/Configure and Item/Build permission to write files to arbitrary locations on the controller file system.
CVE-2026-70596	4.3	MEDI		0.002		Ghost is a Node.js content management system. From 4.9.0 until 6.54.1, an input validation issue allowed any staff user to create a post with content in feature_image_caption that could be used to hijack another staff user's Ghost Admin session, resulting in privilege escalation. This issue is fixed in 6.54.1.
CVE-2026-71322	4.3	MEDI		0.002		Lemur manages TLS certificate creation. Prior to 1.9.3, CertificateExport placed its CertificatePermission ownership check inside the plugin.requires_key branch for POST /api/1/certificates/export. A plugin declaring requires_key false bypassed that check, and the handler still passed cert.private_key as an argument and recorded a key_view audit event. The bundled JavaTruststoreExportPlugin ignored the key, so th...
CVE-2026-73019	4.3	MEDI		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper resolution of path equivalence in Windows URL Moniker allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-76962	4.3	MEDI		0.002		SAP S/4HANA (Manage Bank Chains app) does not perform sufficient authorization checks within certain affected functionality. An attacker with low privileges could send specially crafted requests to delete specific entries that should not be accessible to them. This results in a low impact on availability. There is no impact on confidentiality and integrity.
CVE-2026-76963	4.3	MEDI		0.002		Due to a missing authorization check in Application Server ABAP of SAP NetWeaver and ABAP Platform, an authenticated attacker could gain unauthorized access to sensitive system configuration information. Successful exploitation could result in exposure of security relevant settings and internal system details, resulting in low impact on confidentiality while integrity and availability remain unaffected.
CVE-2026-76977	4.3	MEDI		0.002		SAP UI5 does not sufficiently validate the parent frame's origin against the configured allowlist. An unauthenticated attacker could host a malicious page to bypass framing restrictions. If an authenticated victim visits the attacker's page and interacts with it, the attacker could trick the victim into performing unintended actions, resulting in a low impact on integrity. There is no impact on confidentiality and...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78455	4.3	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Xbox allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-78516	4.3	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Buffer over-read in Windows Storage allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-78593	4.3	MEDI		0.002		An insufficiently validated configuration field in Kibana's Cribl integration allows an authenticated user holding Kibana Fleet management privileges to inject attacker-controlled expressions into a server-side script template, resulting in an Elasticsearch ingest pipeline being written beyond the caller's authorized Elasticsearch permissions.
CVE-2026-70591	4.1	MEDI		0.002		Ghost is a Node.js content management system. From 0.10.0 until 6.54.1, a Server-Side Request Forgery in Ghost Admin image fetching allowed any staff-level user to perform a blind HTTP GET request against internal hosts. No output was returned, but this could have been used to probe open ports on internal hosts. This issue is fixed in version 6.54.1.
CVE-2026-28581	4.0	MEDI		0.001	google:android	In fixInitiatingUserIfNecessary of CallIntentProcessor.java, there is a possible way to make an emergency call due to a logic error in the code. This could lead to local escalation with User execution privileges needed. User interaction is needed for exploitation.
CVE-2026-70595	4.0	MEDI		0.002		Ghost is a Node.js content management system. From 6.26.0 until 6.54.1, a validation issue allowed some functionality, such as Webmentions, to be abused by an unauthenticated user to make limited HTTP requests to hosts in the Ghost server's internal network. A successful attack would not result in any response data being returned. This vulnerability is fixed in 6.54.1.
CVE-2026-80159	4.0	MEDI		0.001	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Untrusted Search Path vulnerability that could result in privilege escalation. An attacker with high privileges could leverage this vulnerability to gain elevated access. Exploit depends on conditions beyond the attacker's control. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-70598	3.9	LOW		0.001		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.10, 40.9.0, 41.2.1, and 42.0.0-beta.3, offscreen rendering frame data received from the GPU process was not fully validated by the main process. A compromised GPU process could cause the main process to read out-of-bounds memory while producing paint event images, disclosing memory or crashing the ...
CVE-2026-70467	3.8	LOW		0.002	fortinet:fortisiem	A server-side request forgery (ssrf) vulnerability in Fortinet FortiSIEM 7.5.0, FortiSIEM 7.4.0 through 7.4.2, FortiSIEM 7.3.0 through 7.3.5, FortiSIEM 7.2 all versions, FortiSIEM 7.1 all versions, FortiSIEM 7.0 all versions, FortiSIEM 6.7 all versions, FortiSIEM 6.6 all versions, FortiSIEM 6.5 all versions may allow attacker to execute unauthorized code or commands via <insert attack vector here>
CVE-2026-55785	3.7	LOW		0.003		free5GC is an open-source implementation of the 5G core network. Prior to 1.4.5, the AUSF component performs cryptographic authentication comparisons in internal/sbi/processor/ue_authentication.go with ordinary equality helpers. Auth5gAkaConfirmRequestProcedure compares RES* and XRES* with strings.EqualFold and logs the expected XRES* value at INFO level before comparison. EapAuthConfirmRequestProcedure compares A...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-58239	3.7	LOW		0.002	sap:approuter	SAP Approuter does not sufficiently validate tenant context in inbound requests. An unauthenticated attacker could send specially crafted requests to spoof the tenant context under conditions not fully within their control. Successful exploitation could allow limited access to another tenant's information, resulting in a low impact on confidentiality. There is no impact on integrity and availability.
CVE-2026-66774	3.7	LOW		0.002	sap:approuter	SAP Approuter does not consistently handle certain error conditions. An attacker with low privileges could exploit this under a non-default configuration. Successful exploitation is highly complex, as it depends on conditions outside the attacker's control. This could result in a low impact on availability. There is no impact on confidentiality and integrity.
CVE-2026-69904	3.5	LOW		0.006	microsoft:sharepoint_server	Server-side request forgery (ssrf) in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.
CVE-2026-76960	3.5	LOW		0.001		SAP S/4HANA Finance (Advanced Payment Management) does not perform sufficient Cross-Site Request Forgery protection on certain requests, due to this an attacker with low privileges could craft a malicious link or page. If an authenticated victim interacts with it, unintended actions could be triggered on the web server on their behalf. This results in a low impact on confidentiality and integrity. There is no impa...
CVE-2026-76961	3.5	LOW		0.001		SAP S/4HANA Finance (Advanced Payment Management) does not perform sufficient Cross-Site Request Forgery protection on certain requests, due to this an attacker with low privileges could craft a malicious link or page. If an authenticated victim interacts with it, unintended actions could be triggered on the web server on their behalf. This results in a low impact on confidentiality and integrity. There is no impa...
CVE-2026-28582	3.3	LOW		0.001	google:android	In onCreate of ConfirmDeviceCredentialActivity.java, there is a possible unauthorized access to and modification of device credentials due to a missing permission check. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28622	3.3	LOW		0.001	google:android	In getQueryBuilderInternal of MediaProvider.java, there is a possible way to retrieve location metadata due to a permissions bypass. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28623	3.3	LOW		0.001	google:android	In writeToParcel of BleRssiRangingCapabilities.java, there is a possible way to obtain the Bluetooth MAC address due to a missing permission check. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28638	3.3	LOW		0.001	google:android	In multiple functions of XmpDataParser.java, there is a possible improper data sanitization due to a logic error in the code. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28671	3.3	LOW		0.001		In updateInternal of MediaProvider.java, there is a possible expose contents of files due to a race condition. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-45521	3.3	LOW		0.001		In openFile of AppFuseBridge.java, there is a possible information disclosure due to a missing permission check. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-59326	3.3	LOW		0.001	broadcom:spring_tools	The Spring Boot language server logs the raw value of the https_proxy/HTTPS_PROXY/http_proxy/HTTP_PROXY environment variable at INFO level whenever it creates an outbound HTTP client and no explicit http.proxy workspace setting is configured. Corporate proxy URLs frequently embed Basic-auth credentials in the form http://user:pass@proxy:8080, and the language server writes this value to its log file without any re...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86503	3.3	LOW		0.001		In JetBrains IntelliJ IDEA before 2026.2.2 opening an untrusted project could trigger SSRF via Kubernetes spec-source URL fetching
CVE-2026-28652	3.1	LOW		0.002	google:android	In multiple functions of RangingServiceImpl.java, there is a possible MITM due to a missing permission check. This could lead to remote information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-70600	3.1	LOW		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, the native autofill popup could be positioned by a cross-origin iframe outside that iframe's bounds, over the embedding page's UI, enabling clickjacking or spoofing of trusted UI. Apps are only affected if they embed untrusted content in iframes within windows ...
CVE-2026-84389	3.1	LOW		0.001		A url redirection to untrusted site ('open redirect') vulnerability in Fortinet FortiSIEM 7.5.0 through 7.5.1, FortiSIEM 7.4.1 through 7.4.2 may allow attacker to execute unauthorized code or commands via <insert attack vector here>
CVE-2026-70430	2.7	LOW		0.002	jenkins:jenkins	Jenkins 2.575 and earlier, LTS 2.568.1 and earlier does not restrict the types of objects that can be instantiated as part of the project naming strategy configuration, allowing attackers with Overall/Manage permission to instantiate arbitrary types related to configuration, including those intended for configuration only by administrators.
CVE-2026-84392	2.7	LOW		0.003		A NULL Pointer Dereference vulnerability [CWE-476] vulnerability in Fortinet FortiOS 7.4 all versions, FortiOS 7.2 all versions, FortiPAM 1.9.0, FortiPAM 1.8 all versions, FortiPAM 1.7 all versions, FortiPAM 1.6 all versions, FortiPAM 1.5 all versions, FortiPAM 1.4 all versions, FortiPAM 1.3 all versions, FortiPAM 1.2 all versions, FortiPAM 1.1 all versions, FortiPAM 1.0 all versions, FortiProxy 7.6.0 through 7.6....
CVE-2026-71438	2.4	LOW		0.002		Mermaid is a JavaScript tool that uses Markdown-inspired text to create and modify diagrams and charts. Prior to 10.9.8 and 11.16.1, Mermaid's configuration setters (mermaid.initialize, mermaidAPI.setConfig, and mermaidAPI.updateSiteConfig) merge caller-supplied configuration into Mermaid's internal config using the assignWithDepth deep-merge helper, which is vulnerable to prototype pollution. This is only exploit...
CVE-2026-81738	2.3	LOW		0.003		OpenVPN 2.5.0 through 2.7.6 on Windows using the tap-windows6 driver allows attackers to trigger an out-of-bounds write via crafted DOMAIN-SEARCH entries
CVE-2026-82060	2.3	LOW		0.002	mongodb:mongodb	In MongoDB, insufficient validation of shard key values during document insertion allowed authenticated users to store documents with specially crafted, operator-shaped objects as shard key values in sharded collections. When change stream events for such documents were processed with the updateLookup full document mode, the crafted values were embedded into internal post-image lookup queries without proper saniti...
CVE-2026-58234	2.2	LOW		0.002		SAP Process Integration (SOAP Adapter) allows a privileged user to send specially crafted requests containing deeply nested entity definitions, which under certain conditions could temporarily increase processor load and degrade system responsiveness. Successful exploitation results in low impact on availability with no impact on confidentiality and integrity.
CVE-2026-86228	2.1	LOW		0.002		A security vulnerability has been detected in JeecgBoot up to 3.9.3. This vulnerability affects the function exportXls of the file jeecg-boot/jeecg-boot-module/jeecg-boot-module-airag/src/main/java/org/jeecg/modules/airag/llm/controller/AiragModelController.java. Such manipulation of the argument credential leads to improper access controls. It is possible to launch the attack remotely. The exploit has been disclo...
CVE-2026-86264	2.1	LOW		0.003		A flaw has been found in sfturing ssm_pro up to 627f426331da8086ce8fff2017d65b1ddef384f8. Affected is an unknown function of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Endpoint. This manipulation of the argument hospitalName/officesName/doctorName causes cross site scripting. It is possible to initiate the attack remotely. The exploit has been published and may be us...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86512	2.1	LOW		0.002		A vulnerability was identified in java-json-tools json-patch up to 1.13. This affects the function CopyOperation.apply/MoveOperation.apply of the file src/main/java/com/github/fge/jsonpatch/CopyOperation.java of the component Copy Move Operations. The manipulation leads to improper access controls. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. The project was i...
CVE-2026-86517	2.1	LOW		0.002		A flaw has been found in itsourcecode Sales and Inventory System 1.0. The impacted element is the function mysqli_query of the file /pages/us_searchfrm.php. Executing a manipulation of the argument ID can lead to sql injection. It is possible to launch the attack remotely. The exploit has been published and may be used.
CVE-2026-86674	2.1	LOW		0.002		A vulnerability was found in ningzichun Student Management System up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected by this vulnerability is the function session_start of the file login.php. The manipulation results in session fixation. The attack can be launched remotely. The exploit has been made public and could be used. This product does not use versioning. This is why information about affected and un...
CVE-2026-85643	2.0	LOW		0.002		A flaw has been found in code-projects Online Shopping System 1.0. Impacted is the function mysqli_query of the file admin/adduser.php. Executing a manipulation of the argument mobile can lead to sql injection. The attack may be performed from remote. The exploit has been published and may be used.
CVE-2026-82312	1.8	LOW		0.001		OpenVPN 2.0.0 through 2.6.22 and 2.7_alpha1 through 2.7.6 on Windows allows local authenticated users to cause a denial of service via a NULL DACL on named IPC objects
CVE-2025-40196				0.002		In the Linux kernel, the following vulnerability has been resolved: fs: quota: create dedicated workqueue for quota_release_work There is a kernel panic due to WARN_ONCE when panic_on_warn is set. This issue occurs when writeback is triggered due to sync call for an opened file(ie, writeback reason is WB_REASON_SYNC). When f2fs balance is needed at sync path, flush for quota_release_work is triggered. By default...
CVE-2026-63810				0.002		In the Linux kernel, the following vulnerability has been resolved: block: Avoid mounting the bdev pseudo-filesystem in userspace The bdev pseudo-filesystem is an internal kernel filesystem with which userspace should not interfere. Unregister it so that userspace cannot even attempt to mount it. This fixes a bug [1] that occurs when attempting to access files, because the system call move_mount() uses pointers...
CVE-2026-64538				0.002		In the Linux kernel, the following vulnerability has been resolved: ipv6: Fix null-ptr-deref in fib6_nh_mtu_change(). fib6_nh_mtu_change() re-fetches idev via __in6_dev_get(arg->dev) and dereferences idev->cnf.mtu6 without a NULL check. addrconf_ifdown() clears dev->ip6_ptr with RCU_INIT_POINTER() after rt6_disable_ip() has released tb6_lock, so the RA-driven MTU walk can observe a NULL idev and oops. The caller...
CVE-2026-72885	0.0	NONE		0.007		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, dockerContextPath accepted by apps/dokploy/components/dashboard/application/build/show.tsx flows through getDockerContextPath in packages/server/src/utlis/filesystem/directory.ts into the unquoted cd command in packages/server/src/utlis/builders/docker-file.ts before execution by execAsync, allowing an authenticated application editor...

P3/P4 items (2813) are in the Excel report. Unsourced CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.